



Specifiche tecniche infrastruttura di sicurezza

GDL-O “Sicurezza”

Informazioni preliminari

.....

Contatti

Riferimento operativo del documento:

Gregorio Canal
Ruolo: Responsabile Unità Testing & Standard
Mail: gcanal@consorzioarsenal.it

Informazioni generali

Nome documento:

Infrastruttura di sicurezza GDL-O Sicurezza

Stato di avanzamento:

Definitiva

Data di prima emissione:

09/05/2013

Ultimo aggiornamento:

28/06/2024

Versione:

2.14

Numero di pagine:

120

Autori del documento:

Mauro Zanardini, Matteo Girardello, Andrea Volpini,
Isabella Sgro, Alessia Favero

Documento verificato da:

Gregorio Canal
Ruolo: Responsabile Unità Testing & Standard
Mail: gcanal@consorzioarsenal.it

Data di verifica:

28/06/2024

Responsabile del documento:

Mauro Zanardini
Ruolo: Dirigente Area Tecnica
Mail: mzanardini@consorzioarsenal.it

Status del documento

Versione	Status	Data	Descrizione modifica
0.1	BOZZA	26/04/2013	Versione 0.1 per revisione interna e gruppo ristretto
0.2	BOZZA	10/05/2013	pronto per revisione del GDL-O Sicurezza: Definizione di UTENTE e RESPONSABILE Sistema richiedente di asserzioni sviluppa WS solo sincroni Eliminato l'utilizzo di SPNameQualifier="farmaciaDiPippo" SPProvidedID="titolare" sia in Subject che Issuer. (Il ruolo è un'informazione aggiunta SOLO dal provider di asserzioni ed è associata al processo di autenticazione). Modifica sequence diagram per descrivere i trigger event della richiesta di asserzione. Aggiunta use-case Dematerializzazione. (Sequence Diagram). Creato nuovo actor diagram per lo use-case dematerializzazione. Aggiunta una frase per specificare la gestione di errori in caso di utilizzo di token non validi sezione 3.2. Aggiornamento Open Issues/Closed Issues.
1.0	PUBLIC COMMENT Version 1	12/06/2013	pronto per public comment: Modifica/Chiusura Open Issues. Modifica Introduzione. Aggiunta di un cappello introduttivo destinato ai responsabili dei sistemi informativi (Summary). Aggiunta sezione specifica per i todo aziendali. Definizione di una sezione relativa alla sincronizzazione dei sistemi. Definizione infrastruttura Auditing. Completamento sezione sulla comunicazione sicura tra nodi della rete (mutua autenticazione dei nodi). Modifica parametri richiesta e asserzione. Aggiunta specificazione dei controlli che deve svolgere l'attore Identity and Assertion Provider. Aggiunta struttura Audit Messages RVE-1. Aggiunta specificazione relativa alla struttura dei Fault per la richiesta di servizi con asserzione. Aggiunte appendici A e B (Appendice B vuota per ora)
1.1	Review PUBLIC COMMENT	29/07/2013	Review e integrazione commenti: Attore territoriale sincronizzato direttamente sul server di Galileo Ferraris e definita una frequenza minima di allineamento (10 minuti). Modifica TODO aziendali: gestione Certificati a livello regionale e aggiornamento a cascata CRL aziendali.

			Definizione transazione RVE-2 Update Password. Aggiunta TODO aziendale gestione di un certificato "ULSSX.cer" per criptare il contenuto del tag newPassword per la transazione UpdatePassword [RVE-2]. Aggiunta contesto "Amministratore di sistema". Correzione refusi figura 8, 9. Ristrutturati i contenuti del paragrafo 3.1. Aggiornamento tabella per Error Code Failed Authentication.
1.2	PUBLIC COMMENT Version 2	17/10/2013	Review a seguito della sperimentazione. Modifica relativa a processo di autenticazione: al posto della funzione SHA1 deve essere utilizzata la criptatura (in quanto reversibile). Aggiunta del WSDL del servizio IAP e xsd per UdatePassword. Modifica dello standard SOAP da 1.1 a 1.2 (strutturalmente i messaggi restano identici. Modifiche da standard sul protocollo SOAP da utilizzare sul trasporto http). In accordo a questo è stata apportata una modifica alla struttura dei messaggi di fault (per renderli compliant soap1.2).
1.3	PUBLIC COMMENT Version 3	03/03/2014	Review a seguito di sperimentazione e deploy. Eliminati refusi nel WSDL, negli xsd, negli esempi di messaggi. Aggiunto il sotto caso d'uso 1.1 per l'audience Restriction. Aggiunta una prima bozza di infrastruttura per l'autenticazione degli attori aziendali (massima generalità in quanto la soluzione è fortemente condizionata dall'infrastruttura aziendale. Si sono descritti due differenti casi d'uso, ed una possibile gestione del rilascio dell'asserzione in una condizione di TRUST APPLICATIVO e con uno smart-middleware).
1.4	Review PUBLIC COMMENT	29/05/2014	Review a seguito di valutazione TSE e GDL-O Sicurezza. Definizione 3 casi d'uso ammissibili per attori aziendali. Specificazione requisiti transazione RVE-1.b (Assertion provider per applicazioni trusted). Aggiunta di due Ruoli R.1.32 e R.1.33.
1.4.1		07/06/2014	Eliminazione Refusi. Specificazione algoritmo crittografico per il campo pw.
2.0	Definitiva	13/06/2014	Versione in Unità di Regia
2.1	Definitiva	06/10/2014	Aggiunta Operatore Socio Sanitario R.1.34. Aggiunta appendice D.

2.2	Definitiva	09/01/2015	Aggiunta Utente Applicativo R.5. Modifica nella semantica del messaggio AuthenticateAndGetAssertionResponse all'interno della transazione [RVE-1.b] (applicativi Trusted).
2.3	Definitiva	09/09/2016	Aggiunta Contesto C.6.5 Aggiunta CodStruttura nell'ASERZIONE. Aggiunta vincoli UTENZE APPLICATIVE.
2.3.1	Definitiva	10/11/2017	Aggiunta Contesto C.1.4 Rimozione Contesto C.6.4
2.4	Definitiva	14/05/2018	Aggiunta modalità autenticazione Web per single sign on regionale.
2.4.1	Definitiva	16/05/2018	Aggiunta sezione 2.4.1 per la generazione degli audit message da parte del retrieve gateway.
2.4.2	Definitiva	17/07/2018	Aggiunto l'errore ERR_00063 nella sezione A.4.5 wsse:FailedAuthentication.
2.4.3	Definitiva	03/08/2018	Eliminati i riferimenti alle porte di dominio sostituendo con rete internet. Aggiunta per la generazione degli audit anche la codifica del reparto.
2.4.4	Definitiva	06/08/2018	Modificato in sezione 1.1.1.1.1 la descrizione dell'elemento attributeStatement/attribute relativo al Reparto_branca cambiandone il nome in codReparto specificandone l'opzionalità e che dev'essere valorizzato secondo la codifica in appendice F. Aggiunte in sezione 5.1.4.1.3.1 le azioni che deve effettuare l'attore Identity and Assertion Provider in relazione alla presenza o meno in richiesta dell'attributo relativo al codReparto.
2.4.5	Definitiva	08/02/2019	Chiarito in Appendice F: estensione regionale della codifica HSP12 l'utilizzo di tale codifica.
2.5	Definitiva	29/07/2019	Aggiunte specifiche per gestire le informazioni relative al privilegio di accesso ad una data applicazione per l'utente autenticato: Aggiunto in sezione 5.1.4.2.2.2 l'elemento UserGrants, con esempio di valorizzazione nell'asserzione. Aggiunto in Tabella 1 di sezione 5.15 l'elemento UserGrants. Aggiunta Appendice A.5 CodeSystem Applicazione, Privilegio di accesso. Aggiunta sezione Autenticazione Web – Single Sign On regionale. Aggiunta sezione Attribute Provider.
2.6	Definitiva	09/08/2019	Definizione utilizzo Token RVE1.c in sezione Autenticazione Web – Single Sign On regionale.

2.7	Definitiva	01/10/2019	Correzione refuso sezione 1.1.1.1.1.1.
2.8	Definitiva	15/11/2019	Aggiunta la struttura degli audit nel caso di RVE-1b (sezione 5.2.7) ed RVE-1c (sezione 7.2).
2.9	Definitiva	01/06/2021	Riorganizzazione del documento inserendo Volume 1 e Volume 2. Aggiunte transazioni RVE-1.d, GET Metadata WAYF, GET Snippet nel Volume 2. • Aggiunti/esplicitati i casi d'uso per: • Attori Aziendali (Extra SIO) • Attori Aziendali (SIO) • Autenticazione Web – Single Sign On regionale
2.10	Definitiva	01/07/2022	• inseriti elementi codUdO, codUO, codSpecialitaUO all'interno dell'elemento <saml:AttributeStatment> all'interno del paragrafo 4.4.6.2.2 • Integrata Tabella 4 in appendice A con ruoli R.4.3, R.4.4 e R.4.5
2.11	Definitiva	03/11/2022	• Inserito attributo MotivazioneAccesso all'interno della transazione RVE-1.d per veicolare veicola la motivazione della richiesta di accesso ai documenti nel caso di forzatura della presa in carico e relativa tabella delle codifiche in Appendice A • Modificata descrizione macro attività e contesto contesto per il codice C.10 in Tabella 5, Appendice A • Aggiunta possibilità di specificare gli attributi e codStruttura, codUdO, codUO nel messaggio di RVE-1.d request. Aggiornato paragrafo sulle Expected Actions ed aggiornati i parametri codStruttura, codUdO e codUO del messaggio RVE-1.d response • Rimosso attributo codReparto dai messaggi RVE-1.a request e RVE-1.b request
2.12	Definitiva	23/11/2023	• Esplicitata possibilità di utilizzo di parametri aggiuntivi in fase di richiesta all'interno delle progettualità regionali nel paragrafo "Message Semantics" relativo alla transazione [RVE-1.b] Authenticate And Get Assertion-b. • Integrata Tabella 5 con Contesto C.12 relativo al Dossier Cittadino • Corretto esempio soap fault in sezione 4.7.1 • Ripristinate Figure 11 e 15 • Inserito parametro codOTP all'interno dei messaggi [RVE-1.a] Request e Response e [RVE-1.b] Request • Inserito parametro codVerifica all'interno dei messaggi [RVE-1.a] Response • Aggiunto codice di errore ERR_00064 in

			Appendice A.5 Tabella 12 • Aggiornata sezione Message Semantics all'interno dei paragrafi 4.1, 4.2, 4.3 e 4.4 con riferimenti alle Specifiche Tecniche - ATNA - Security Considerations • Aggiornata descrizione Ruolo 4.2 e aggiunto Ruolo 4.6 in Appendice A.1 Tabella 4 • Rimossa Appendice B relativa al WSDL • Corretto refuso nella valorizzazione del <soap:Action> relativamente alla transazione [RVE-1.d] Response
2.13	Definitiva	17/01/2024	Esplicitato in sezione 3.3.1 che, per le utenze applicative, è possibile censire, in LDAP, la P.IVA del fornitore a cui fa riferimento l'utenza applicativa al posto del CF
2.14	Definitiva	28/06/2024	Aggiunti codici U1 e U2 in Tabella 7, relativi all'accesso in emergenza Esplicitato in sezione 4.6 che per servizi REST il token SAML 2.0 di asserzione deve essere veicolato previo Deflate e Base64 Encode. Aggiunto relativo esempio in sezione 4.6.

Indice del documento

.....

Acronimi e definizioni	13
Open Issue	14
Closed Issue	14
Iter di approvazione documentale	15
Introduzione	18
1. Attori e Transazioni	21
1.1. Attori	22
1.2. Transazioni	23
2. Infrastruttura di Sicurezza	24
3. Casi d'uso	25
3.1. Use-case: Attori Territoriali	25
3.1.1. Audience Restriction use-case	25
3.2. Use-case: Attori Aziendali (SIO)	27
3.3. Use-case: Attori Aziendali (Extra SIO)	29
3.3.1. Requisiti Applicativi / Organizzativi di accessibilità ai servizi RVE	30
3.3.2. Applicativo Evoluto	30
3.3.2.1. Applicativo Integrato con Directory Server	31
3.3.2.2. Applicativo Trusted (Integrato o NON integrato con LDAP)	32
3.3.3. Applicativo Obsoleto	34
3.4. Autenticazione Web – Single Sign On regionale	34
3.4.1. WAYF Service	37
3.4.1.1. Metadata	37
3.5. Sincronizzazione degli applicativi	38
3.6. Comunicazione sicura tra sistemi ([ITI-19] Authenticate Node)	39
3.6.1. Creazione Certificati Applicativi Labeling	40
3.6.1.1. Requisiti dei certificati	41
3.6.2. Transazioni sicure tra WS: "WS-I Basic Security Profile"	42
3.6.3. Standard di riferimento	42
3.7. Audit degli Eventi ([ITI-20] Record Audit Event)	42
3.7.1. Infrastruttura Auditing	42
3.7.1.1. Interrogazione di un sistema di ARR federato	44
3.7.2. Struttura degli Audit messages	44
3.7.2.1. Audit Messages generato dal Retrieve Gateway	45
3.7.3. Standard di riferimento	45
4. Transazioni	47
4.1. [RVE-1.a] Authenticate and Get Assertion	47

4.1.1. Scopo	48
4.1.2. Attori e ruoli	49
4.1.3. Standard di riferimento	49
4.1.4. Interaction Diagram	50
4.1.5. AuthenticateAndGetAssertion Request	50
4.1.5.1. Trigger Events	50
4.1.5.2. Message Semantics	51
4.1.5.2.1. SOAP Header	51
4.1.5.2.2. SOAP Body	53
4.1.5.3. Expected Actions	56
4.1.5.3.1. Controlli eseguiti sui parametri della richiesta	58
4.1.6. AuthenticateAndGetAssertion Response	59
4.1.6.1. Trigger Events	59
4.1.6.2. Message Semantics	59
4.1.6.2.1. SOAP Header e Body	59
4.1.6.2.2. Struttura dell'asserzione di identità	60
4.1.6.3. Expected Actions	65
4.1.7. Security e Audit Considerations	65
4.1.8. Sintesi scambio informativo transazione [RVE-1.a]	65
4.2. [RVE-1.b] Authenticate And Get Assertion-b (per applicazioni Trusted)	67
4.2.1. Scopo	67
4.2.2. Attori e ruoli	67
4.2.3. Standard di riferimento	68
4.2.4. Interaction Diagram	68
4.2.5. AuthenticateAndGetAssertion.b Request	68
4.2.5.1. Trigger Events	69
4.2.5.2. Message Semantics	69
4.2.5.3. Expected Actions	72
4.2.5.3.1. Controlli eseguiti sui parametri della richiesta	73
4.2.6. AuthenticateAndGetAssertion.b Response	74
4.2.7. Security e Audit Considerations	74
4.3. [RVE-1.c] Autenticazione Web	75
4.3.1. Scopo	75
4.3.2. Attori e ruoli	75
4.3.3. Standard di riferimento	75
4.3.4. Interaction Diagram	76
4.3.5. Autenticazione Web Request	76
4.3.5.1. Trigger Events	76
4.3.5.2. Message Semantics	76
4.3.5.3. Expected Actions	76
4.3.6. Autenticazione Web Response	77
4.3.6.1. Trigger Events	77

4.3.6.2. Message Semantics	77
4.3.7. Security e Audit Considerations	77
4.3.8. [RVE-1.d] Authenticate And Get Assertion-d	77
4.3.9. Scopo	78
4.3.10. Attori e ruoli	78
4.3.11. Standard di riferimento	78
4.3.12. Interaction Diagram	79
4.3.13. AuthenticateAndGetAssertion.d Request	79
4.3.13.1. Trigger Events	79
4.3.13.2. Message Semantics	79
4.3.13.3. Expected Actions	82
4.3.14. AuthenticateAndGetAssertion.d Response	83
4.3.14.1. Trigger Events	83
4.3.14.2. Message Semantics	83
4.3.14.2.1. SOAP Header e Body	83
4.3.14.2.2. Struttura dell'asserzione di attributo	84
4.3.14.3. Expected Actions	89
4.3.15. Security e Audit Considerations	89
4.4. GET Metadata WAYF	89
4.4.1. Scopo	90
4.4.2. Attori e ruoli	90
4.4.3. Standard di riferimento	90
4.4.4. Interaction Diagram	90
4.4.5. Metadata WAYF Request	91
4.4.5.1. Trigger Events	91
4.4.5.2. Message Semantics	91
4.4.5.3. Expected Actions	91
4.4.6. Metadata WAYF Response	91
4.4.6.1. Trigger Events	91
4.4.6.2. Message Semantics	91
4.4.6.3. Expected Actions	92
4.5. GET Snippet	92
4.5.1. Scopo	92
4.5.2. Attori e ruoli	92
4.5.3. Standard di riferimento	92
4.5.4. Interaction Diagram	93
4.5.5. Snippet Request	93
4.5.5.1. Trigger Events	93
4.5.5.2. Message Semantics	93
4.5.5.3. Expected Actions	94
4.5.6. Snippet Response	94
4.5.6.1. Trigger Events	94

4.5.6.2. Message Semantics	94
4.5.6.2.1. Esempio	94
4.5.6.3. Expected Actions	95
4.6. Richiesta Servizi: [ITI-40] Provide X-User Assertion	95
4.6.1. Gestione delle condizioni di Errore (Fault)	98
4.7. [RVE-2] Update Password	100
4.7.1. Scopo	100
4.7.2. Attori e Ruoli	100
4.7.3. Standard di riferimento	100
4.7.4. Interaction Diagram	101
4.7.5. PasswordUpdate Request message	101
4.7.5.1. Trigger Events	101
4.7.5.2. Message Semantic	101
4.7.5.3. Expected Actions	103
4.7.6. PasswordUpdate Response message	103
4.7.6.1. Trigger Events	103
4.7.6.2. Message Semantic	103
4.7.6.3. Expected Actions	104
4.7.7. Security e Audit Considerations	105
4.7.7.1. Audit Identity and Assertions Provider	105
4.7.7.2. Audit X-Service User	106
Appendici	109
Appendice A: CodeSystems	109
A.1. CodeSystem Ruoli (attributo "Role")	109
A.2. CodeSystem Contesti Clinici (attributo "RequestContext")	111
A.3. CodeSystem UserClientAuthentication	112
A.4. CodeSystem Motivazione Accesso (attributo "MotivazioneAccesso")	113
A.5. Error Codes, dialect RVE:FSE	114
A.5.1. wsse:FailedCheck	114
A.5.2. wsse:SecurityTokenUnavailable	114
A.5.3. wsse:MessageExpired	115
A.5.4. wsse:InvalidSecurityToken	115
A.5.5. wsse:FailedAuthentication	115
Appendice B: Schemi .XSD definiti per messaggi	116
Appendice C: Criteri Complessità Password	117
Appendice D: Gestione Utente Applicative	117
Appendice E: estensione regionale della codifica HSP12	117
Appendice F:	118
F.1. Valori Previsti UserGrants	119
Bibliografia	120

Acronimi e definizioni

.....

ATNA	Audit Trail and Node Authentication
ARR	Audit Record Repository
CF	codice fiscale
IHE	integrating the healthcare enterprise
LDAP	lightweight directory access protocol
NTP	Network Time Protocol
CT	Consistent Time
CRL	Certificate Revocation List
PHI	Protected Health Information
XUA	Cross-Enterprise User Assertions
XML	eXtensible Mark-up Language
XDS	Cross-Enterprise Document Sharing
SAML	Security Assertion Markup Language
SAR	Servizio di Accoglienza Regionale
PKI	Public Key Infrastructure
IETF	Informatic Enginneer Task Force
Utente	utilizzatore di un sistema applicativo che vuole accedere a determinati servizi.
Responsabile	Possessore di credenziali conosciute da un Identity Provider in grado di asserire l'identità del responsabile stesso e di tutti gli utenti di cui questo responsabile è garante
TLS	Transport Layer Security
CA	Certification Authority

Open Issue

.....

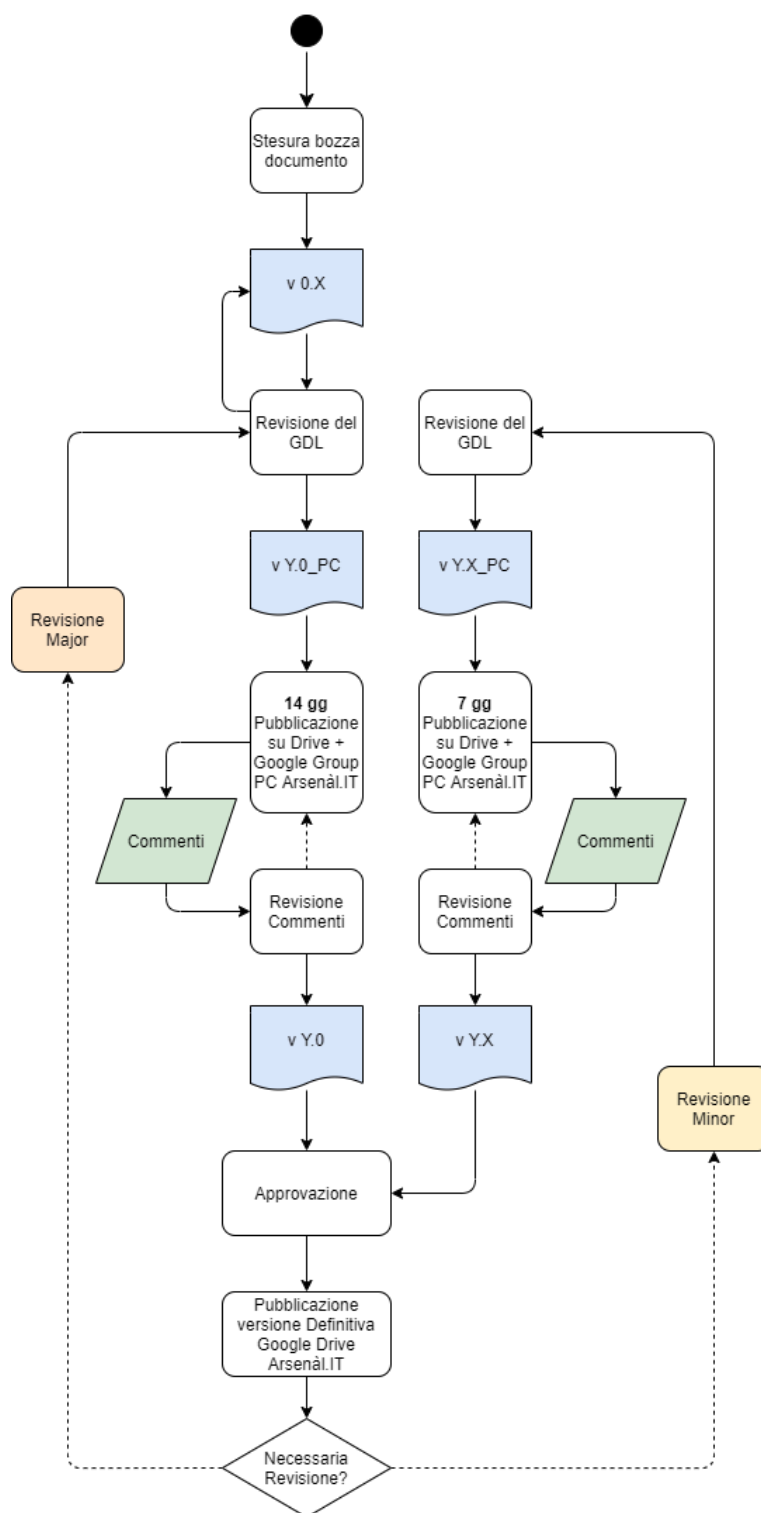
1. Gestione delle CRL regionali e aziendali e loro allineamento.
2. Si richiede un'analisi delle specifiche relative agli attori aziendali.

Closed Issue

.....

Nessuna.

Iter di approvazione documentale



Descrizione dell'iter di approvazione documentale

La sintassi ammessa per il versionamento dei documenti è la seguente:

- Y.X dove
 - “Y” numero versione Major (da 0 a n)
 - “.” separatore
 - “X” numero versione Minor (da 0 a n)

Versione “Bozza” (v0.X)

Il documento è redatto all'interno del GDL di competenza, in questa fase il documento è in versione bozza (0.X).

L'aggiornamento della versione bozza, al fine di tenere traccia delle modifiche, si ha incrementando la prima variabile dopo il separatore (X).

Versione “Public Comment” (vY.0_PC) (OPZIONALE in base ai requisiti di progetto)

Successivamente, se il progetto per il quale il deliverable è stato prodotto richiede una fase di public comment, il documento in formato PDF viene pubblicato su Drive e su Google Group dedicati ai *public comment*. In questa fase la versione passa a (Y.0_PC) con Y=1 per la prima versione del documento. Tutti gli stakeholder interessati possono lasciare un proprio commento al documento pubblicato. I commenti saranno rilasciati seguendo delle specifiche istruzioni, disponibili sul sito di Arsenà.IT.

Durante il periodo di *public comment*, della durata di 14 gg, Arsenà.IT analizzerà i commenti rilasciati, proponendo una possibile soluzione. Ogni commento e la relativa risposta rimarranno visibili all'intera comunità che potrà intervenire nella discussione.

Alla fine del periodo di *public comment* tutti i commenti analizzati da Arsenà.IT verranno sottoposti al GDL di competenza. In caso di approvazione i cambiamenti verranno integrati nel documento di riferimento.

L'iter di pubblicazione e revisione si conclude nel momento in cui non sono apportati cambiamenti sostanziali al documento secondo decisione del GDL di competenza.

Versione “Pubblica” (VY.0)

Una volta ottenuta una versione definitiva, essa andrà quindi in approvazione con le seguenti modalità:

- se il documento deve essere inviato al cliente, la validazione è in carico al Dirigente dell'Area Tecnica;
- se il documento non deve essere inviato al cliente ma deve essere inoltrato ad un altro gruppo di lavoro interno ad Arsenà (es. per la produzione di altra documentazione) l'approvazione deve avvenire da parte del Responsabile di Unità (o dell'Ufficio) produttore del documento.

Dopo l'approvazione si ha la pubblicazione della versione definitiva su Google Drive di Arsenà.IT.

In questa fase la versione passa a (Y.0) con Y=1 per la prima versione del documento.

Dopo questa fase, se è necessaria la revisione del documento si possono seguire due percorsi: Revisione Major e Revisione Minor.

Nel caso in cui sia necessario revisionare un documento interno condiviso con un'altra Unità/Ufficio del Consorzio, la definizione dell'entità dell'aggiornamento (Minor / Major) deve essere concertata tra l'Unità/Ufficio inviante e l'Unità/Ufficio ricevente. In questo caso la nuova versione deve essere approvata da entrambi i referenti di Unità/Ufficio.

Revisione Major

La Revisione Major avviene quando si devono apportare modifiche sostanziali (ad esempio cambiamento dello standard utilizzato per le transazioni) al documento da parte del GDL, il percorso è il medesimo descritto precedentemente, con un eventuale periodo di *public comment* della durata di 14 gg.

Durante l'eventuale periodo di *public comment*, Arsenà.IT analizzerà i commenti rilasciati, proponendo una possibile soluzione. Ogni commento e la relativa risposta rimarranno visibili all'intera comunità che potrà intervenire nella discussione.

Alla fine del periodo di *public comment* tutti i commenti analizzati da Arsenà.IT verranno sottoposti al GDL di competenza. In caso di approvazione i cambiamenti verranno integrati nel documento di riferimento

L'aggiornamento della versione si ha in questo caso, incrementando la parte intera (Y).

Revisione Minor

La Revisione Minor avviene quando si devono apportare modifiche di minore rilevanza al documento (ad esempio la modifica dell'obbligatorietà di un campo di un tracciato).

Durante l'eventuale periodo di *public comment*, per le Revisioni Minor della durata di 7 gg, Arsenà.IT analizzerà i commenti rilasciati, proponendo una possibile soluzione. Ogni commento e la relativa risposta rimarranno visibili all'intera comunità che potrà intervenire nella discussione.

Alla fine del periodo di *public comment* tutti i commenti analizzati da Arsenà.IT verranno sottoposti al GDL di competenza. In caso di approvazione i cambiamenti verranno integrati nel documento di riferimento.

L'aggiornamento della versione si ha in questo caso, incrementando la prima cifra decimale (X).

L'iter di condivisione documentale può subire delle leggere modifiche su richiesta del cliente, può quindi variare da un progetto all'altro. In caso di cambiamenti rispetto a quanto suesposto, l'iter deve essere stabilito con il cliente, approvato e allegato alla Scheda di Sviluppo Esecutivo del progetto in questione.

Introduzione

.....

Il primo obiettivo del seguente documento è descrivere i requisiti minimi di sicurezza che gli applicativi devono soddisfare per l'integrazione nei processi e servizi definiti nel Fascicolo Sanitario Elettronico regionale. Secondo obiettivo di questo documento è definire le specifiche tecniche per il processo di autenticazione degli utenti che necessitano di accedere ai servizi del Fascicolo Sanitario Elettronico regionale.

Il documento è strutturato in due sezioni che descrivono rispettivamente l'infrastruttura del sistema per gli attori territoriali (MMG, Farmacie, RSA, ecc.) e l'infrastruttura per gli attori aziendali.

Attori Territoriali:

Ogni attore coinvolto deve essere considerato un nodo sicuro. Per questo motivo le comunicazioni saranno permesse solo tra sistemi in grado di effettuare una mutua autenticazione attraverso verifica diretta della validità di certificati applicativi installati sugli applicativi. Questi certificati verranno rilasciati ad ogni main release dell'applicativo una volta superata la fase di labeling eseguita da consorzio Arsenàl.IT.

Una volta verificata l'attendibilità del certificato applicativo (attraverso l'utilizzo del protocollo TLS) viene aperto un canale di comunicazione sicuro attraverso il quale possono transitare le richieste di servizi. Ogni richiesta di servizi eseguita da uno specifico utente deve necessariamente essere corredata da un'asserzione d'identità (strutturata attraverso lo standard OASIS SAML 2.0). L'asserzione di identità è creata dall'azienda sanitaria di competenza a seguito di una richiesta applicativa (Authentication Request) dell'attore territoriale. Tale richiesta deve veicolare le seguenti informazioni:

- le credenziali (user/password) di un utente "responsabile" della richiesta e conosciute dell'Identity Provider aziendale;
- il contesto clinico della richiesta (es. ricovero ordinario, screening ecc.);
- le modalità di autenticazione che l'utente ha eseguito sul client (es. User-Password, Smart Card, ecc.);
- il ruolo dichiarato dal responsabile delle credenziali (es. Medico, Infermiere, Tecnico, ecc.);
- un identificativo specifico per l'installazione dell'applicativo: (formato: ApplicationID^^Main_Release^^ID_installazione);
- Codice Fiscale del Responsabile delle Credenziali di autenticazione;
- Codice Fiscale dell'utente che sta effettuando la richiesta

L'attore aziendale che riceve la richiesta di asserzione deve effettuare le seguenti verifiche prima di generare un'asserzione di identità:

- Verificare in modo applicativo specifiche inibizioni associate al Client caratterizzato da uno specifico identificativo di installazione (black-list)
- Verificare la correttezza e la validità delle credenziali del responsabile utilizzate nella richiesta

- Verificare che il contesto clinico dichiarato è tra i contesti clinici in cui può operare l'applicativo caratterizzato da uno specifico ApplicationID (questi contesti sono assegnati durante la fase di labeling)

L'asserzione d'identità generata dall'attore aziendale conterrà le seguenti informazioni:

- Il contesto di autenticazione che ha determinato la generazione dell'asserzione
- Il codice fiscale dell'utente che ha effettuato la richiesta di asserzione
- Il codice fiscale del responsabile possessore delle credenziali utilizzate dall'utente
- Il ruolo del responsabile delle credenziali di autenticazione
- Il contesto clinico della richiesta
- Il periodo di validità dell'asserzione di identità

L'asserzione d'identità così ottenuta deve essere veicolata all'interno dei messaggi di richiesta di servizi del Fascicolo Sanitario Elettronico regionale.

Attori Aziendali (Extra-SIO):

Tutte le comunicazione devono avvenire in rete pubblica internet.

Ogni richiesta di servizi eseguita da uno specifico utente deve necessariamente essere corredata da un'asserzione d'identità (strutturata attraverso lo standard OASIS SAML 2.0). L'asserzione d'identità è creata dall'azienda sanitaria di competenza a seguito di una richiesta applicativa eseguita dall'applicativo aziendale utilizzato dall'utente stesso. La richiesta di servizi sarà veicolata mediante il middleware verso rete pubblica internet e quindi inoltrata all'identificato Service Provider. L'asserzione di identità veicola gli stessi parametri contenuti nei token di identità degli utenti territoriali (vedere sezione [Struttura dell'asserzione d'identità](#)).

Gli applicativi aziendali possono essere considerati di due tipologie: attori in grado di integrarsi in modo standard direttamente con i servizi di autenticazione e fascicolo, e attori che necessitano del supporto di un middleware per accedere a tali servizi. Nel primo caso il Middleware aziendale esegue un semplice proxy delle richieste, nel secondo caso è proprio il middleware a garantire l'integrabilità tra applicativo e servizi fascicolo/autenticazione. In certi casi è presumibile che il Middleware esponga dei servizi ad hoc (protocollo e comunicazione non standardizzate) che permettano la creazione dell'asserzione di identità per gli utenti.

Attori Aziendali (SIO):

Ogni richiesta di servizi eseguita da uno specifico utente deve necessariamente essere corredata da un'asserzione di attributo (strutturata attraverso lo standard OASIS SAML 2.0). L'asserzione di attributo viene creata dall'attore SIO a seguito dell'autenticazione da parte dell'operatore tramite la transazione RVE-1.c.

Attori Regionali:

Tutte le comunicazione devono avvenire in rete pubblica internet.

Ogni richiesta di servizi eseguita da uno specifico utente deve necessariamente essere corredata da un'asserzione di attributo (strutturata attraverso lo standard OASIS SAML 2.0). L'asserzione di attributo viene creata dall'attore SIO a seguito dell'autenticazione da parte

dell'operatore tramite la transazione RVE-1.c e dell'ottenimento dell'asserzione tramite transazione RVE-1d.

Volume 1

1. Attori e Transazioni

Di seguito viene riportato il diagramma sinottico con gli attori e le transazioni previsti dall'infrastruttura di sicurezza:

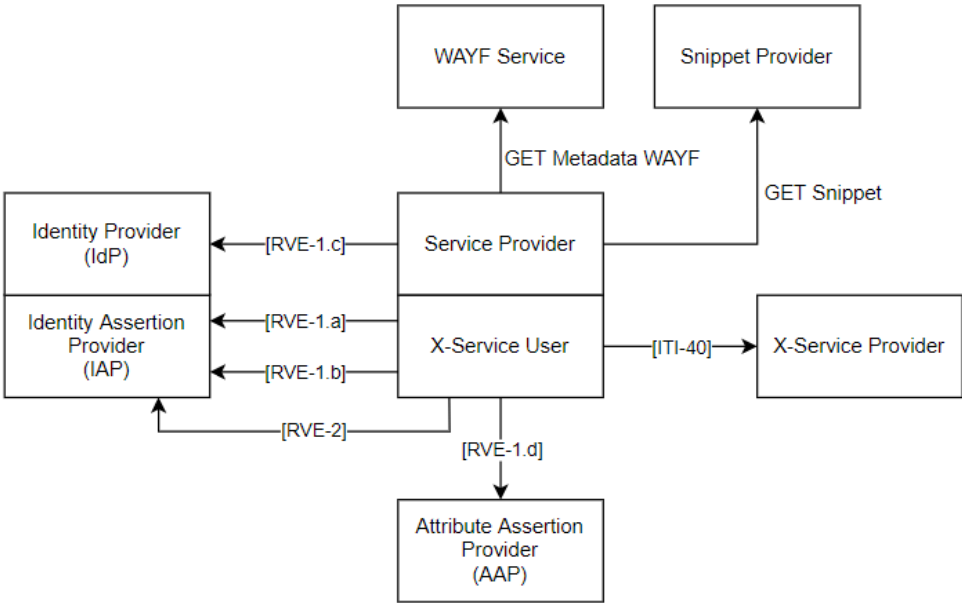


Figura 1. Diagramma sinottico attori e integrazioni infrastruttura di sicurezza

Tabella 1. Tabella degli attori e delle transazioni

Attore	Transazione	Opzionalità
X-Service User	RVE-1.a Authenticate and Get Assertion	R
	RVE-1.b Authenticate And Get Assertion-b	R
	RVE-1.d Authenticate And Get Assertion-d	R
	RVE-2 Update Password	R
	ITI-40 Provide X-User Assertion	R
	GET Metadata WAYF	R
	GET Snippet	R

Service Provider	RVE-1.c Authenticate And Get Assertion-c	R
X-Service Provider	ITI-40 Provide X-User Assertion	R
Identity Assertion Provider	RVE-1.a Authenticate and Get Assertion	R
	RVE-1.b Authenticate And Get Assertion-b	R
	RVE-2 Update Password	R
Identity Provider	RVE-1.c Authenticate And Get Assertion-c	R
Attribute Assertion Provider	RVE-1.d Authenticate And Get Assertion-d	R
WAYF Service	GET Metadata WAYF	R
Snippet Provider	GET Snippet	R

1.1. Attori

Gli attori coinvolti sono:

- **X-Service User:** richiede l'asserzione di identità o di attributo che verrà utilizzata successivamente per ottenere l'erogazione di servizi applicativi da parte di un attore X-Service Provider.
- **Service Provider:** provider che, dopo aver richiesto l'autenticazione dell'utente all'Identity Provider, ne gestisce l'autorizzazione sulla base degli attributi restituiti da quest'ultimo, ed eroga il servizio richiesto.
- **X-Service Provider:** permette all'attore X-Service User di usufruire dei servizi applicativi richiesti.
- **Identity Assertion Provider:** provider di autenticazione che consente agli utenti o ai processi di sistema di affermare la propria identità mediante l'utilizzo di token.
- **Identity Provider:** gestisce gli utenti e la procedura di autenticazione.
- **Attribute Assertion Provider:** utilizza la lista di attributi collezionata all'interno dell'Attribute Provider per firmare un'asserzione di attributo spendibile per l'accesso ai servizi da parte dell'X-Service User.
- **WAYF Service:** Invia al Service Provider l'elenco dei metadata federati a livello regionale.
- **Snippet Provider:** Restituisce la lista degli IdP attivi al Service Provider.

1.2. Transazioni

Le transazioni previste sono:

[RVE-1.a] Authenticate and Get Assertion

Questa transazione verrà utilizzata dall'attore X-Service User per richiedere all'attore Identity and Assertions Provider di produrre un token SAML 2.0 che asserisca l'identità e il ruolo di un utente che si è autenticato nel proprio sistema.

[RVE-1.b] Authenticate And Get Assertion-b

Questa transazione verrà utilizzata dall'attore X-Service User trusted per richiedere all'attore Identity and Assertions Provider di produrre un token SAML 2.0 che asserisca l'identità e il ruolo di un utente che si è autenticato nell'applicativo rappresentato dall'X-Service User trusted.

[RVE-1.c] Authenticate And Get Assertion-c

Questa transazione verrà utilizzata dall'attore Service Provider per richiedere all'attore Identity Provider di produrre un'asserzione SAML 2.0 che asserisca l'identità di un utente che si è autenticato nell'applicativo rappresentato dal Service Provider

[RVE-1.d] Authenticate And Get Assertion-d

Questa transazione verrà utilizzata dall'attore X-Service User trusted per richiedere all'attore Attribute and Assertions Provider di produrre un token SAML 2.0 che asserisca l'identità e gli attributi di un utente che si è autenticato nell'applicativo rappresentato dall'X-Service User trusted.

[RVE-2] Update Password

Questa transazione permette all'attore X-Service User di aggiornare, in modo applicativo, la password (gestita dall'azienda di riferimento) utilizzata per richiedere asserzioni di identità.

[ITI-40] Provide X-User Assertion

Questa transazione descrive come un attore X-Service User deve utilizzare un'asserzione di identità ottenuta dall'attore Identity and Assertions Provider per ottenere l'erogazione di servizi applicativi da parte di un attore X-Service Provider.

GET Metadata WAYF

Questa transazione è utilizzata dall'attore Service Provider per richiedere al WAYF Service l'elenco dei metadata federati a livello regionale.

GET Snippet

Questa transazione è utilizzata dall'attore Service Provider verso l'attore Snippet Provider per recuperare la lista degli IdP attivi, l'endpoint dei singoli metadata, l'etichetta da mostrare all'utente per identificare l'IdP e l'icona che lo identifica.

2. Infrastruttura di Sicurezza

Questa sezione permette di descrivere l'Infrastruttura di Sicurezza ed autenticazione per gli attori territoriali/aziendali che devono interfacciarsi ai servizi regionali. Questa infrastruttura può essere applicata a Medici di base, farmacie, RSA, applicativi Aziendali, applicativi regionali, ecc..

TODO Aziendali:

- Mantenere aggiornate la CRL dei sistemi aziendali allineandola periodicamente (ogni 10 minuti max) con la CRL gestita a livello regionale
- Integrazione dell'appliance dell'attore Identity and Assertion Provider
 - Definizione dei connettori necessari per autenticare un Responsabile dotato di credenziali direttamente nell'LDAP aziendale
 - Per garantire una gestione uniforme l'attore Identity and Assertion Provider gestirà delle tabelle di confine contenenti le informazioni utili per verificare l'appropriatezza della richiesta di asserzione. Tali informazioni devono essere mantenute aggiornate attraverso la configurazione di appositi connettori con i sistemi aziendali che tracciano queste informazioni:
 - ID_APPLICATIVO + CONTESTI ammessi (definiti a livello aziendale)
 - CF_titolare + USER_ID
 - CF_titolare + RUOLO + codStruttura

Non è specificato se questo tipo di informazioni debba essere memorizzato all'interno dell'LDAP come attributi aggiuntivi allo schema esistente o attraverso altre modalità.

- Gestione a livello di LDAP degli attori territoriali (MMG, titolari di farmacia) ai quali deve essere assegnata una USER_ID e una PASSWORD.
- L'azienda deve sincronizzare i propri sistemi con il Server NTP di Galileo Ferraris e dovrà esporre un servizio Server NTP per i propri sistemi interni.
- Garantire l'integrazione dell'LDAP aziendale con il servizio applicativo di rinnovo password (transazione [RVE-2])
- Integrazione degli applicativi con i sistemi ATNA Audit Record Repository
- Gestione a livello di DS (o altro sistema di gestione delle utenze) di tutti gli attori aziendali ai quali deve essere assegnata una USER_ID e una PASSWORD;
- Associare ad ogni utente ruolo e CF (utilizzando LDAP o altro DB)

3. Casi d'uso

3.1. Use-case: Attori Territoriali

In questa sezione verrà descritto lo use-case di un utente territoriale/aziendale (extra-SIO) che vuole autenticare la propria identità per accedere attraverso l'utilizzo di un applicativo locale (X-Service User) ai servizi regionali (X-Service Provider). L'architettura del sistema di autenticazione degli utenti dovrà essere federata, in quanto l'Identity Provider dell'utente è generalmente non integrato al Service Provider dei servizi regionali. I servizi verranno dunque esposti senza poter verificare direttamente l'identità dell'utente che richiede il servizio. L'utente è l'utilizzatore di un sistema applicativo che vuole accedere a determinati servizi. Il Responsabile è un possessore di credenziali conosciute da un Identity Provider in grado di asserire l'identità del responsabile stesso e di tutti gli utenti di cui questo responsabile è garante. L'utente di un sistema si autenticerà localmente all'interno del proprio applicativo utilizzando specifiche credenziali locali (UserPassword dell'utente, SmartCard, ecc...). Utilizzando le credenziali del proprio responsabile, l'utente eseguirà una richiesta di asserzione verso l'Identity and Assertion Provider di riferimento. La richiesta veicherà ulteriori informazioni relative a contesto e motivazioni della richiesta, utili a valutare la richiesta stessa ed a strutturare l'asserzione di identità. La Response di questa richiesta conterrà un'asserzione di identità firmata digitalmente utilizzabile come token SAMLper accedere a servizi esposti dal FSEr/FSSEzero.

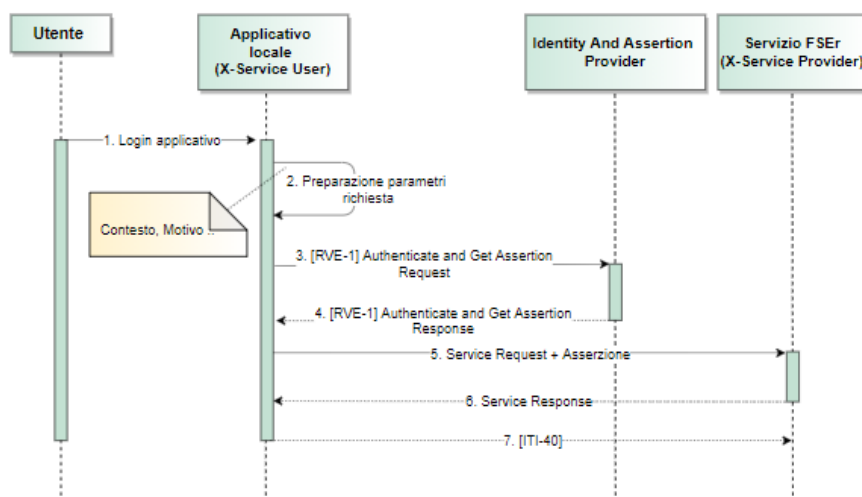


Figura 2. Use-case autenticazione FSEr

3.1.1. Audience Restriction use-case

Esistono servizi ad elevata confidenzialità (consultazione di documenti clinici, ecc...) la cui accessibilità è condizionata da scelte (documenti di consenso, policy, ecc...) o informazioni, che sono gestite a livello aziendale. Per esempio, se un paziente è Ricoverato in un

determinato reparto, è noto ai sistemi aziendali ma non ai sistemi regionali. Per questo motivo, il Server regionale che deve garantire l'accesso ad una particolare risorsa, può rifiutare asserzioni create in modo generico (cioè senza specificarne che tipo di utilizzo ne verrà fatto), ma può essere configurato in modo da accettare solamente asserzioni espressamente richieste per accedere a tale servizio.

Questo permette di gestire a livello di servizio di autenticazione, il rilascio di asserzioni parametrizzate in modo diverso a seconda della tipologia di servizio per cui sono richieste. Di seguito viene presentato un caso d'uso di esempio.

Un MMG inizia la propria attività giornaliera prescrivendo ricette per i propri pazienti. Il servizio di invio ricette non richiede asserzioni specifiche, quindi il Client del medico esegue delle richieste al servizio autenticazione senza la necessità di specifici parametri. Durante l'attività di routine emerge la necessità di consultare un documento condiviso a livello di fascicolo sanitario elettronico regionale. Il client del medico tenterà di accedere a tale servizio con l'asserzione precedentemente utilizzata per l'invio delle ricette. Tuttavia la risorsa richiesta (il documento clinico), non può essere ottenuta (generazione di uno specifico codice di errore) se non con un'asserzione che identifica il servizio di recupero documenti (es: <https://fser.regione.veneto.it/Registry>) come target per l'utilizzo dell'asserzione stessa. Deve quindi essere effettuata una nuova richiesta di asserzione al servizio di autenticazione specificando tale parametro. Generalmente queste operazioni sono trasparenti all'utente e vengono eseguite in modo automatico in funzione del codice di errore generato (nello stesso modo in cui viene generato l'errore per asserzione scaduta per esempio). Le logiche applicative del dell'attore Identity and Assertion Provider permettono la creazione di un'asserzione con parametri specifici (durata, delegabilità, riusabilità, ecc...) dipendenti dal servizio che si vuole accedere (l'asserzione generica ha durata di 4 ore ma è possibile definire policy più restrittive per esempio un'asserzione per il recupero di un documento ha durata invece 15 minuti).

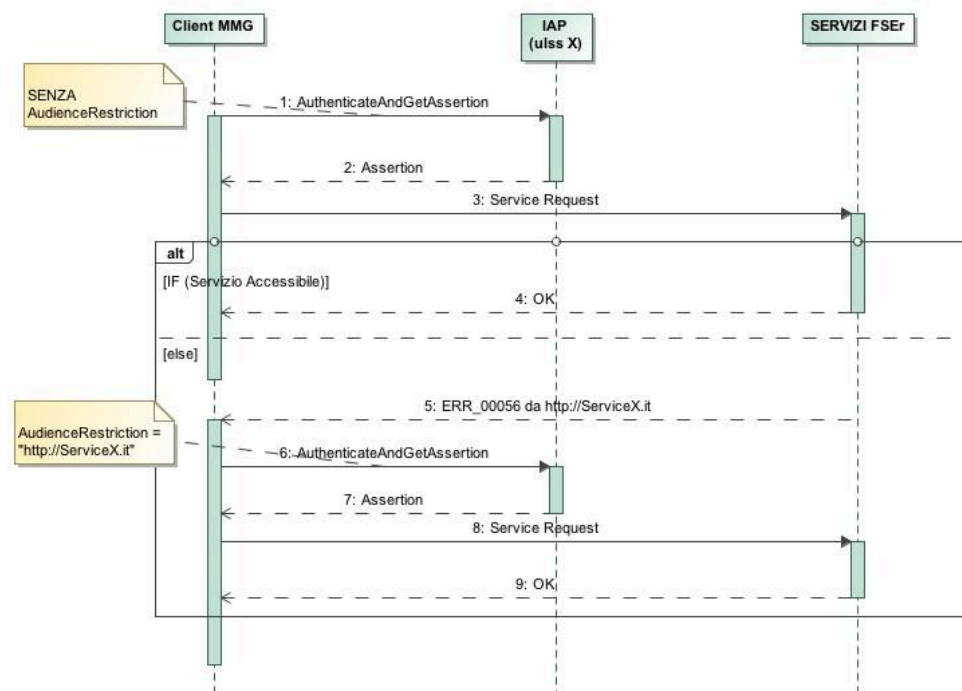


Figura 3. AudienceRestriction use-case

3.2. Use-case: Attori Aziendali (SIO)

In questa sezione verrà descritto lo use-case di un utente aziendale (SIO) che vuole autenticare la propria identità per accedere attraverso l'utilizzo di un applicativo aziendale (X-Service User) ai servizi regionali (X-Service Provider).

L'architettura del sistema di autenticazione degli utenti dovrà essere federata, in quanto l'Identity Provider dell'utente è generalmente non integrato al Service Provider dei servizi. I servizi verranno dunque esposti senza poter verificare direttamente l'identità dell'utente che richiede il servizio.

I sistemi Identity and Assertion Provider forniscono dei servizi Web di autenticazione compliant con le specifiche SPID. Per dettagli si faccia riferimento alla documentazione tecnica : http://www.agid.gov.it/sites/default/files/circolari/spid-regole_tecniche_v1.pdf e successive versioni.

Le applicazioni Web coinvolte nel progetto FSEr o nel dossier FSSEZero devono garantire i seguenti requisiti:

- Supportare il protocollo SPID in qualità di Service Provider, accettando come Identity Provider la rete regionale di asserzione delle identità (IAP)

Il workflow di autenticazione previsto è descritto di seguito. L'applicativo Web si comporta come un Service Provider SPID e richiede all'utente di scegliere il proprio identity provider di riferimento (deve essere possibile per l'utente, impostare una scelta preferita di default). L'applicativo esegue quindi una richiesta di autenticazione SAML SSO web verso i servizi Web del sistema Identity and Assertion Provider scelto. Mediante interazione con lo user agent (browser) l'operatore completerà la schermata di login del corrispondente IdP. Lo IdP genererà un'asserzione SAML veicolata nel body di risposta della chiamata http, e l'applicativo Web dovrà intercettare tale asserzione per generare la sessione.

RICHIESTA ACCESSO SERVIZIO: L'operatore/utente accede al SP o al servizio .

RICHIESTA SNIPPET & METADATA: Il SP effettuerà la popolazione della dropdown box la quale avviene recuperando dal WAYF lo snippet che verrà successivamente presentato all'operatore/utente.

RISPOSTA da SP con DROPDOWN BOX SNIPPET E METADATA: In questa fase verrà restituita all'operatore/utente la possibilità di scegliere dalla dropdown box l'IdP.

RICHIESTA AUTORIZZAZIONE verso IDP SCELTO: Una volta scelto dall'operatore/utente l'IdP viene inviata una request all'IdP il quale nel caso in cui la request sia valida presenterà all'operatore/utente una schermata di login, nel caso in cui invece non sia valida presenterà all'operatore/utente una pagina di errore parlante. Successivamente l'operatore/utente inserirà i dati di login, l'IdP, dopo verifica su Directory Service (o altro sistema messo a

disposizione da Azienda Sanitaria) delle credenziali di accesso fornite, rilascia un token di asserzione.

TOKEN ASERZIONE: Nel caso in cui l'IdP avrà un riscontro positivo delle credenziali dal Directory Service allora il token di asserzione potrà essere speso per accedere al servizio richiesto dall'utente, nel caso in cui invece avesse un riscontro negativo l'IdP "intercetterà" l'errore presentato dal DS e lo restituirà all'operatore/utente con un messaggio di errore parlante. Note:

- L'IdP può presentare un'opzione di annullamento che, se selezionata, rimanda alla pagina indicata da metadata del SP come pagina di atterraggio.
- Come da specifiche SPID, dopo 5 tentativi con credenziali errate, l'IdP deve rimandare alla pagina indicata da metadata del SP come pagina di atterraggio indicando un messaggio di errore comprensibile.
- Nel caso in cui l'autenticazione fosse corretta l'IdP ridirige alla pagina indicata dal metadata del SP con una response che conterrà gli attributi richiesti dal metadata stesso purché ricompresi tra quelli gestiti dall'IdP.

UTILIZZO DEL TOKEN DI SESSIONE: Il SP utilizza il token precedentemente ottenuto per generare una sessione per l'utente autenticato.

RECUPERO TOKEN ATTRIBUTO: L'applicativo web del SIO, a seguito dell'avvenuta autenticazione, deve generare un'asserzione di attributo relativa all'operatore utilizzando il Codice Fiscale dell'utente, e recuperando la lista degli attributi ricavata dall'Attribute Provider.

Il Token di attributo deve essere generato secondo quanto definito in sezione [Struttura dell'asserzione di attributo](#).

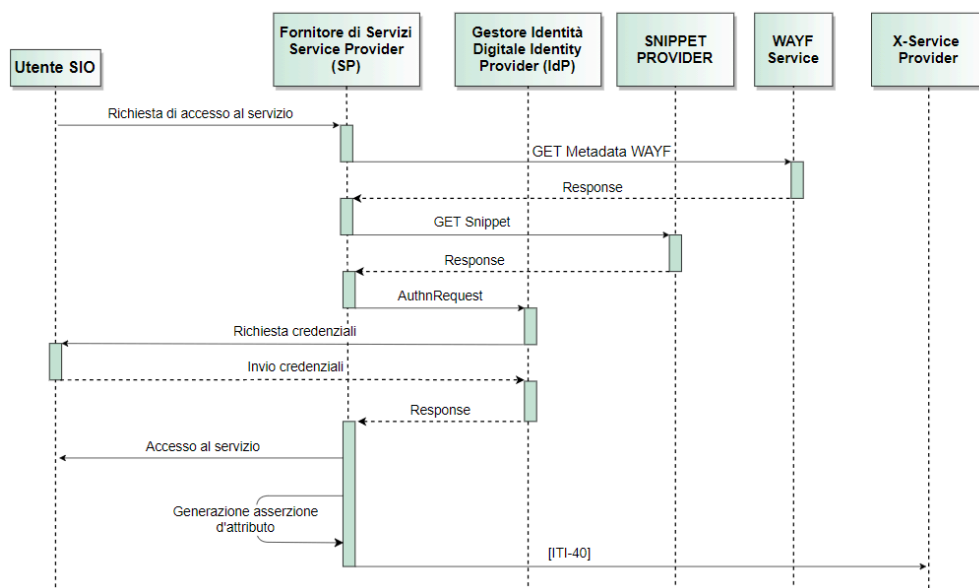


Figura 4. Use-case autenticazione SIO

3.3. Use-case: Attori Aziendali (Extra SIO)

All'interno del dominio aziendale gli applicativi possono essere raggruppati all'interno di due categorie:

- Attori in grado di essere direttamente integrati con i servizi fascicolo, in quanto in grado di interoperare con protocolli e messaggistica standard;
- Attori che interagiscono mediante linguaggio e protocolli proprietari con gli altri sistemi aziendali.

Nel secondo caso il middleware aziendale si fa carico di standardizzare le richieste di servizi e completarle con i parametri necessari.

Di seguito è presentata l'infrastruttura che garantisce l'integrazione tra applicativi aziendali ed i servizi del Fascicolo Sanitario Elettronico regionale.

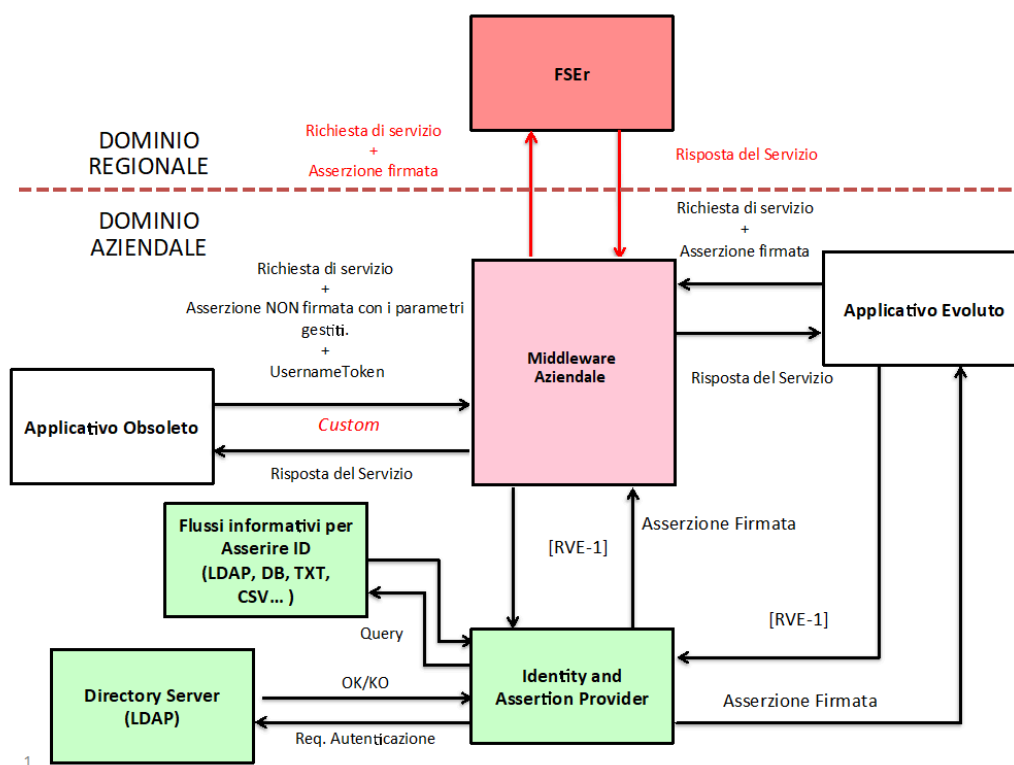


Figura 5. Integrazione FSEr - applicativi aziendali

3.3.1. Requisiti Applicativi / Organizzativi di accessibilità ai servizi RVE

Di seguito sono individuati i requisiti tecnici ed organizzativi minimi che devono essere garantiti da ogni applicativo che deve interfacciarsi sui servizi RVE:

- Tutti gli applicativi devono gestire le password in accordo le misure minime di sicurezza (codice Privacy, allegato B 196/03)
- Tutti gli operatori devono essere autenticati nominalmente nell'applicativo;
- Tutti gli operatori devono essere identificabili in modo univoco in LDAP (o all'interno di un alternativo sistema deputato alla gestione delle utenze della ulss)
- Per ogni utente devono essere mappati CF e Ruolo in LDAP (o all'interno di un alternativo sistema deputato alla gestione delle utenze della ulss)

N.B: per le utenze applicative è possibile censire P.IVA del fornitore a cui fa riferimento l'utenza applicativa al posto del CF

3.3.2. Applicativo Evoluto

Con Applicativo Evoluto si intende un applicativo in grado di realizzare richieste di servizi con semantica e protocolli standard. Questa tipologia di applicativo può utilizzare il middleware aziendale come proxy delle chiamate applicative inoltrandole verso rete pubblica internet.

Questa tipologia di applicativo è in grado di integrarsi con i servizi di autenticazione (AuthenticateAndGetAssertion) in modo standard attraverso due modalità alternative rappresentate dai casi d'uso 1 e 2 per l'autenticazione degli operatori aziendali, come descritto di seguito. Nei grafici di seguito verranno adottate le seguenti convenzioni:

u: username di LDAP;

UU: username locale;

p: password di LDAP;

PP: password locale;

cf: codice fiscale dell'operatore;

aID: applicationID che identifica l'applicativo che richiede asserzione;

Con: Contesto applicativo;

Auth: metodo di autenticazione;

<Q>: richiesta di servizio FSEr (es: presa in carico ricetta)

<resp>: response ad una richiesta di servizio;

role: ruolo associato all'operatore;

SP: Service Provider

DS: Directory Server

L'asserzione ottenuta viene restituita all'applicativo aziendale che è così in grado di creare autonomamente una transazione [ITI-40] Provide X-User Assertion accoppiata con una Richiesta di servizio (vedi sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#)).

3.3.2.1. Applicativo Integrato con Directory Server

L'operatore si autentica nell'applicativo con le credenziali del Directory Server (AD, LDAP, ecc..). Quando l'operatore si autentica viene contemporaneamente richiesta un'asserzione di identità al servizio IAP utilizzando username e password inserite. L'applicativo può fare caching sicuro della password durante la sessione e riutilizzarla per rinnovare l'asserzione di identità in caso di cambi di contesto, o di altri parametri contenuti nell'asserzione. In caso non si gestisca il caching della password, alla scadenza dell'asserzione devono essere digitate nuovamente le credenziali per effettuare una nuova richiesta di asserzione. E' ammissibile che l'applicativo gestisca localmente le password del Directory Server, in tal caso devono essere tenute in considerazione le problematiche connesse alla scadenza e rinnovo delle stesse credenziali.

- **PARAMETRI DA GESTIRE LATO APPLICATIVO:** CF , username e pw del Directory Server, ApplicationID, RequestContext, Metodo di Autenticazione;
- **PARAMETRI DA GESTIRE LATO LDAP:** CF e Ruolo per ogni utente, (alternativa gestire un DB locale o nell'ipam con questi dati)

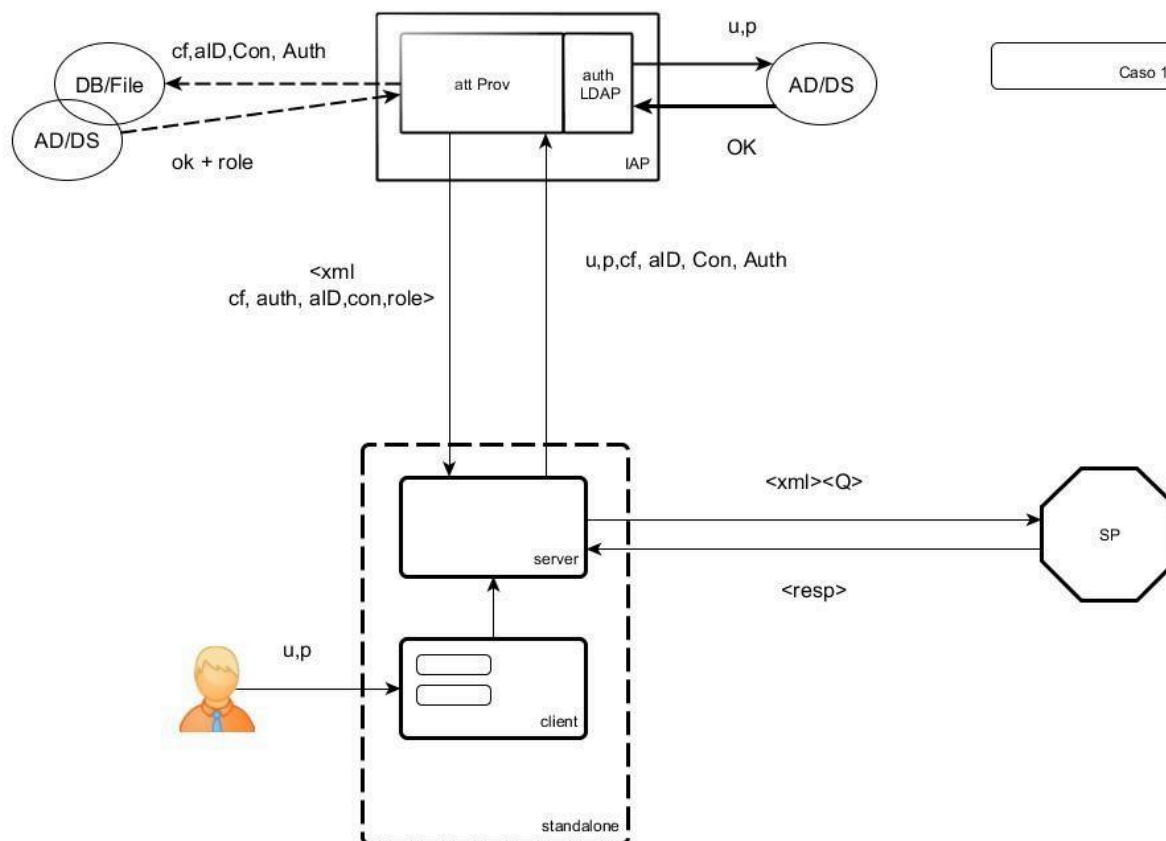


Figura 6. Applicativo Aziendale integrato con LDAP

L'applicativo si connette direttamente al servizio di autenticazione mediante transazione [RVE-1]: questa è la modalità di connessione suggerita nel caso l'applicativo sia in grado di gestire le credenziali USER/PW degli utenti che sono contenute nel Directory Server aziendale. Questa scelta NON necessita di un forte trust applicativo (l'attore IAP accetta request in questo formato da ogni client che si presenta con un certificato client valido emesso dalla CA Sanità Veneto) per garantire l'autenticazione degli utenti, in quanto l'attore Identity and Assertion Provider verifica l'attendibilità delle richieste ricevute effettuando un binding LDAP utilizzando le credenziali dell'utente che richiede l'asserzione di identità. Applicativi in questa condizione devono supportare la transazione [RVE-1] Authenticate and Get Assertion come descritto in sezione [RVE-1.a: Authenticate and Get Assertion](#).

3.3.2.2. Applicativo Trusted (Integrato o NON integrato con LDAP)

L'operatore si autentica nell'applicativo con delle credenziali locali. L'applicativo è trusted in quanto autentica la propria identità digitale (mediante certificato applicativo rilasciato da Regione Veneto per la specifica installazione) sul servizio IAP. L'attore IAP gestisce l'elenco di certificati applicativi che identificano le specifiche installazioni in grado di effettuare richieste di asserzione senza interfacciamento con il Directory Server. L'attore Identity and

Assertion Provider, mediante username del Directory Server (o mappatura tra userID locale e username di Directory Server realizzata attraverso una tabella di transcodifica gestita all'interno del DB aziendale o di un DBMS interno all'attore IAP stesso), recupera tutti i dati necessari per creare un'asserzione di identità.

- **PARAMETRI DA GESTIRE LATO APPLICATIVO:** username DS (o locale se ho una mappatura lato iap), ApplicationID, Contesto, Metodo di Autenticazione ;
- **PARAMETRI DA GESTIRE LATO LDAP:** CF e Ruolo per ogni utente, (alternativa gestire un DB locale o nell'ipam con questi dati). Opzionalmente, una tabella di transcodifica tra userID locale + applicationID in username del Directory Server aziendale.

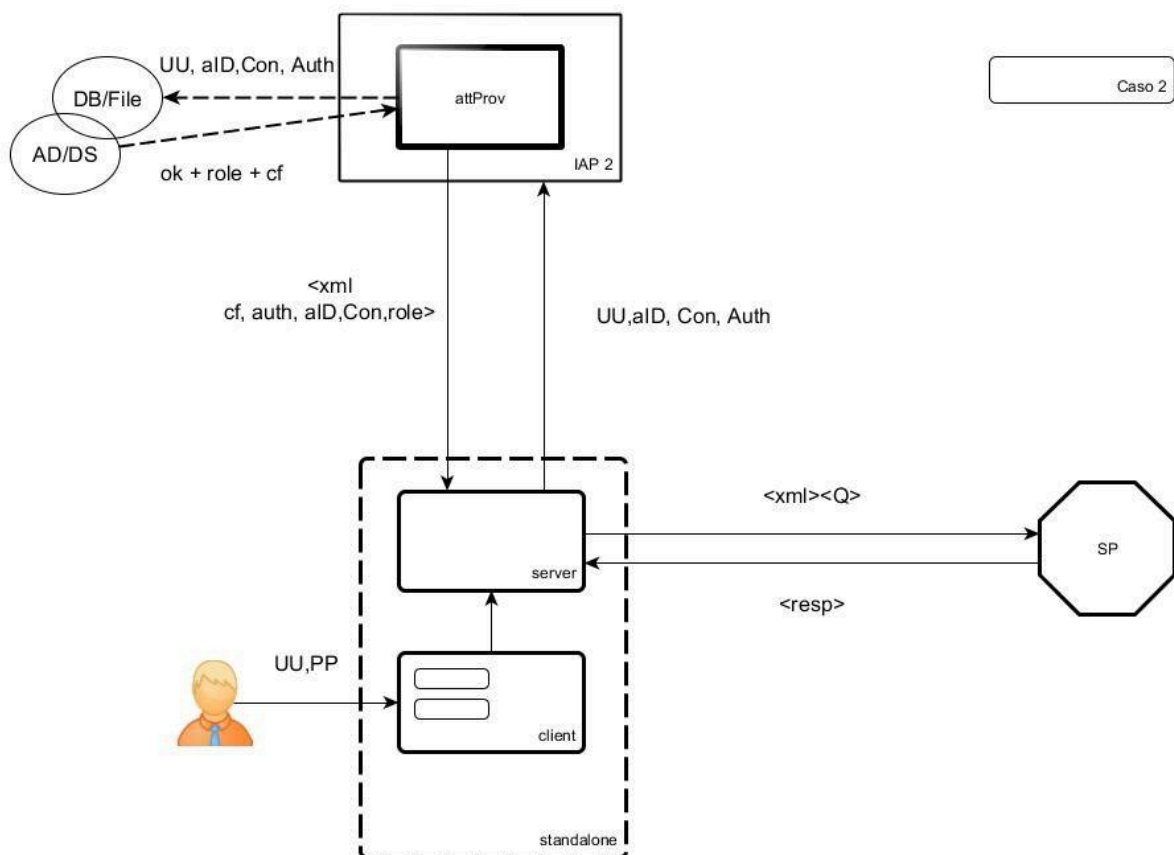


Figura 7. Applicativo Trusted

L'applicativo utilizza la transazione [RVE-1.b] per interfacciarsi verso il servizio IAP. La struttura dell'asserzione prodotta è identica a quella prodotta a seguito di una transazione [RVE-1].

Di seguito sono descritte le specificità della transazione [RVE-1.b], che comporta una modifica del messaggio di Request rispetto alla transazione [RVE-1], e del comportamento atteso dell'attore IAP.

3.3.3. Applicativo Obsoleto

Con Applicativo Obsoleto si intende un applicativo che non è in grado di integrarsi direttamente né con il servizio di autenticazione né con i servizi esposti dal Fascicolo Sanitario Elettronico regionale.

In questo caso si rende necessaria un'integrazione ad-hoc tra l'applicativo e il middleware aziendale. Si richiede solamente che vengano veicolati dei dati che permettano al middleware stesso di identificare l'utente stesso (username) e transcodificare tali dati in modo da completare una richiesta di autenticazione e richiesta di asserzione verso il servizio aziendale `AuthenticateAndGetAssertion`.

Tali informazioni sono veicolate in modo accoppiato a delle richieste di servizio (vengono quindi passati allo stesso tempo i parametri di autenticazione e i parametri di Richiesta). Una volta che il middleware ha ottenuto l'asserzione di identità firmata digitalmente, si fa carico di strutturare con semantica standard le richieste a servizi del Fascicolo Sanitario Elettronico regionale. La richiesta viene inoltrata a livello extra-aziendale mediante middleware inoltrandola verso rete pubblica internet.

La risposta ottenuta dal servizio extra-aziendale deve essere convertita dal middleware in un formato comprensibile per l'applicativo obsoleto che ha iniziato la richiesta.

3.4. Autenticazione Web – Single Sign On regionale

In questa sezione vengono definite le modalità di autenticazione previste per le applicazioni Web coinvolte dell'Infrastruttura FSEr e nel dossier FSSEZero.

I sistemi Identity and Assertion Provider forniscono dei servizi Web di autenticazione compliant con le specifiche SPID. Per dettagli si faccia riferimento alla documentazione tecnica : http://www.agid.gov.it/sites/default/files/circolari/spid-regole_tecniche_v1.pdf e successive versioni.

Le applicazioni Web coinvolte nel progetto FSEr o nel dossier FSSEZero devono garantire i seguenti requisiti:

Supportare il protocollo SPID in qualità di Service Provider, accettando come Identity Provider la rete regionale di asserzione delle identità (IAP)

Utilizzare l'asserzione di identità ottenuta mediante protocollo SAML 2.0 SSO, per:

- Generazione di una sessione utente nell'applicativo;
- Accedere ai servizi RESTful / SOAP offerti da FSEr o FSSEZero (mediante le linee guida definite nei profili di integrazione IHE XUA e IHE IUA).

Il workflow di autenticazione previsto è descritto di seguito. L'applicativo Web si comporta come un Service Provider SPID e richiede all'utente di scegliere il proprio identity provider di riferimento (deve essere possibile per l'utente, impostare una scelta preferita di default). L'applicativo esegue quindi una richiesta di autenticazione SAML SSO web verso i servizi Web del sistema Identity and Assertion Provider scelto. Mediante interazione con lo user agent (browser) l'operatore completerà la schermata di login del corrispondente IAP. Lo IAP genererà un'asserzione SAML veicolata nel body di risposta della chiamata http, e l'applicativo Web dovrà intercettare tale asserzione per generare la sessione. Tale asserzione deve essere mantenuta in cache applicativa per poter essere usata in successive chiamate a servizi RESTful/SOAP regionali.

RICHIESTA ACCESSO SERVIZIO: L'operatore/utente accede al SP o al servizio .

RICHIESTA SNIPPET & METADATA: Il SP effettuerà la popolazione della dropdown box la quale avviene recuperando dal WAYF lo snippet che verrà successivamente presentato all'operatore/utente.

RISPOSTA da SP con DROPDOWN BOX SNIPPET E METADATA: In questa fase verrà restituita all'operatore/utente la possibilità di scegliere dalla dropdown box l'IDP.

RICHIESTA AUTORIZZAZIONE verso IDP SCELTO: Una volta scelto dall'operatore/utente l'IDP viene inviata una request all'IDP il quale nel caso in cui la request sia valida presenterà all'operatore/utente una schermata di login, nel caso in cui invece non sia valida presenterà all'operatore/utente una pagina di errore parlante. Successivamente l'operatore/utente inserirà i dati di login, l'IDP, dopo verifica su Directory Service (o altro sistema messo a disposizione da Azienda Sanitaria) delle credenziali di accesso fornite, rilascia un token di asserzione.

TOKEN ASERZIONE: Nel caso in cui l'IDP avrà un riscontro positivo delle credenziali dal Directory Service allora il token di asserzione potrà essere speso per accedere al servizio richiesto dall'utente, nel caso in cui invece avesse un riscontro negativo l'IdP "intercetterà" l'errore presentato dal DS e lo restituirà all'operatore/utente con un messaggio di errore parlante. Note:

- L'IdP può presentare un'opzione di annullamento che, se selezionata, rimanda alla pagina indicata da metadata del SP come pagina di atterraggio.
- Come da specifiche SPID, dopo 5 tentativi con credenziali errate, l'IdP deve rimandare alla pagina indicata da metadata del SP come pagina di atterraggio indicando un messaggio di errore comprensibile.
- Nel caso in cui l'autenticazione fosse corretta l'IdP ridirige alla pagina indicata dal metadata del SP con una response che conterrà gli attributi richiesti dal metadata stesso purché ricompresi tra quelli gestiti dall'IdP.
- Il token restituito dovrà veicolare al suo interno mediante un elemento di tipo NameIDType gli attributi:

SPNameQualifier: contenente l'url del servizio di Attribute Assertion Provider da invocare per ottenere l'asserzione di Attributo associata all'utente.

SPProvidedID: contenente l'identificativo utilizzato per identificare l'utente all'interno della struttura dell'Attribute Provider

UTILIZZO DEL TOKEN DI SESSIONE: Il SP utilizza il token precedentemente ottenuto per generare una sessione per l'utente autenticato.

RECUPERO TOKEN APPLICATIVO: L'applicazione Web, a seguito dell'avvenuta autenticazione web, deve recuperare un'asserzione nominale relativa all'operatore eseguendo una transazione [RVE-1d] verso l'endpoint dell'Attribute Provider. Il token ottenuto può essere utilizzato per invocare i servizi regionali.

NOTA: i servizi XDS Document Registry e XDS Document Repository devono essere invocati con un'asserzione che veicola il patientID del paziente oggetto della richiesta.

Di seguito viene riportata una tabella di mappatura fra attributi restituiti dall'autenticazione web e il corrispondente campo presente in LDAP aziendale.

Tabella 2. Mappatura attributi SPID e token IAP/IDP SAML 2.0

Attributo	Identificatore SPID/Web authentication	Tipo	Mappatura token IAP/IDP SAML 2.0	Note
Nome	name	xs:string	N/A	Nome dell'operatore ottenuto da LDAP aziendale
Cognome	familyName	xs:string	N/A	Cognome dell'operatore ottenuto da LDAP aziendale
Codice Struttura	registeredOffice	xs:string	codStruttura	Codice della struttura dell'operatore ottenuto da LDAP aziendale. La codifica XXX
Codice fiscale	fiscalNumber	xs:string	ResponsibleParty	Codice Fiscale dell'operatore ricavato da LDAP aziendale
Permessi di accessibilità	companyName		UserGrants	Codifica relativa alle applicazioni ed ai ruoli relativi all'utente prevista da LDAP aziendale. XXX

3.4.1. WAYF Service

Il servizio WAYF (Where Are You From) viene usato per stabilire la connessione tra il Service Provider e l'Identity Provider dell'utente. Esso fornisce un meccanismo per il routing dell'utente da una risorsa alla pagina di Log-In. Il servizio WAYF mostra la lista degli IdP all'interno della quale gli utenti possono scegliere il loro IdP. Il servizio WAYF regionale contatta le aziende sanitarie per ottenere metadata e generare lo snippet.

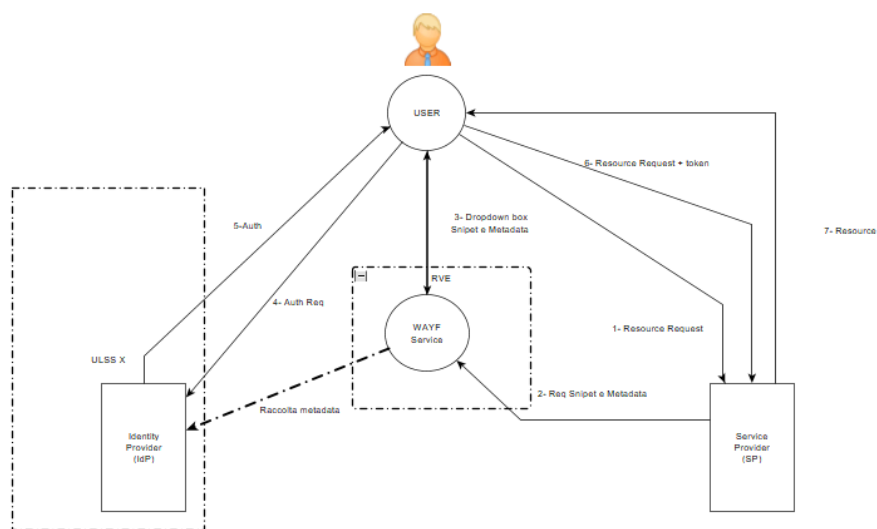


Figura 8. WAYF Service

3.4.1.1. Metadata

Ciascuna entità presente nella federazione regionale è descritta da un file di metadata, che ne riporta il certificato X509, gli endpoint e le altre informazioni necessarie alla comunicazione con le altre entità.

I metadata Identity Provider saranno disponibili per tutte le entità federate attraverso la URL <https://<dominiogestoreidentita>/metadata>. L'accesso deve essere effettuato utilizzando il protocollo TLS nella versione più recente disponibile.

I metadata dei Service Provider saranno disponibili per tutte le entità federate attraverso la URL <https://<dominioserviceprovider>/metadata>. Il metadata pubblico del Service Provider dovrà essere federato da Regione veneto. Risulta quindi necessario che esso venga comunicato preventivamente. L'accesso deve essere effettuato utilizzando il protocollo TLS nella versione più recente disponibile

Per la definizione del metadata fare riferimento alle specifiche tecniche http://www.agid.gov.it/sites/default/files/circolari/spid-regole_tecniche_v1.pdf e successive versioni.

Esempio:

```
<md:EntitiesDescriptor xmlns:md="urn:oasis:names:tc:SAML:2.0:metadata"
  Name="https://wayf.azero.veneto.it/api/metadata">
  <md:EntityDescriptor xmlns:ds="http://www.w3.org/2000/09/xmldsig#"
    xmlns:md="urn:oasis:names:tc:SAML:2.0:metadata"
    ID="BIT4ID_70cdb70bed476e2504c7ddfb29ae972a33b1fdac"
    entityID="https://webauth.ulssX.it/idp/metadata">
    ...
  </md:EntityDescriptor>
  <md:EntityDescriptor xmlns:ds="http://www.w3.org/2000/09/xmldsig#"
    xmlns:md="urn:oasis:names:tc:SAML:2.0:metadata"
    ID="BIT4ID_70cdb70bed476e2504c7ddfb29ae972a33b1fdac"
    entityID="https://webauth.ulssY.it/idp/metadata">
    ....
  </md:EntityDescriptor>
</md:EntitiesDescriptor>
```

3.5. Sincronizzazione degli applicativi

Tutti i sistemi coinvolti all'interno dell'infrastruttura del Fascicolo Sanitario Regionale devono garantire la sincronia. Per questo motivo ogni sistema dovrà garantire i requisiti dell'attore Time Client come definito nel profilo di integrazione IHE Consistent Time (CT) IHE TF-ITI:1 sezione 7. La sincronizzazione è in questo modo garantita con un errore mediano minore di un secondo.

Un attore CT Time Client deve utilizzare il protocollo NTP (Network Time Protocol) definito nello standard RFC 1305 per la transazione [ITI-1] Maintain Time.

L'azienda garantirà la sincronizzazione dei propri sistemi interni, agendo da Time Client raggruppato con Time Server, allineando il proprio clock con il Time Server di Galileo Ferraris a questi NTP Server primario e secondario:

- ntp1.inrim.it (193.204.114.232)
- ntp2.inrim.it (193.204.114.233)

Gli attori territoriali in qualità di Time Client si allineeranno direttamente con il Time Server di Galileo Ferraris utilizzando la transazione [ITI-1] Maintain Time.

I dettagli implementativi della transazione sono descritti negli standard di riferimento e al seguente indirizzo: <http://www.ntp.org>.

Ogni sistema deve garantire l'allineamento del proprio clock con il Time Server effettuando la sincronizzazione almeno ogni 10 minuti.

In Figura [Sincronizzazione dei sistemi](#) viene descritta l'infrastruttura per garantire la sincronizzazione dei sistemi coinvolti nel Fascicolo Sanitario Elettronico regionale.

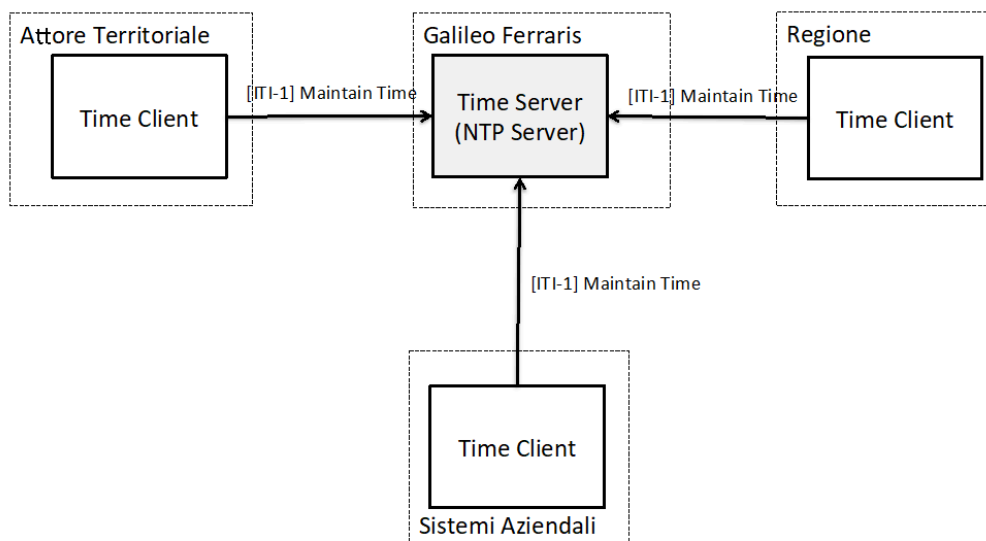


Figura 9. Sincronizzazione dei sistemi

3.6. Comunicazione sicura tra sistemi ([ITI-19] Authenticate Node)

Per garantire l'accessibilità ai servizi del Fascicolo Sanitario Elettronico regionale ai soli sistemi che hanno superato in modo proficuo una sessione di labeling il processo di connessione tra due applicativi avviene attraverso una mutua autenticazione dei sistemi coinvolti in ogni transazione (per ulteriori dettagli relativi al processo di labeling si faccia riferimento alla documentazione di riferimento disponibile sul portale www.consortioarsenal.it). In questa sezione verranno individuate le principali caratteristiche che i sistemi coinvolti nella rete fascicolo dovranno implementare per garantire comunicazioni sicure. I nodi della rete individuati in via preliminare sono tre:

- Nodo Regionale
- Nodo Aziendale
- Nodo Territoriale (MMG, Farmacia ecc...)

Ogni nodo della rete dovrà considerarsi un nodo sicuro (Secure Node/Secure Application IHE). Un Secure Node locale dovrà presentare la propria identità al Secure Node remoto e dovrà a sua volta verificare l'identità Secure Node remoto. Dopo questa mutua autenticazione possono essere instaurate le successive comunicazioni sicure. Il requisito ulteriore di un Secure Node è quello di autenticare lo user che richiede all'accesso dei servizi al nodo stesso. Questo tipo di operazione verrà gestita solo a livello locale e non comporterà nessuna specifica comunicazione con il Secure Node remoto.

Le comunicazioni sicure e la mutua autenticazione devono avvenire in accordo con le linee guida specifiche del protocollo TLS v1.2 (standard IETF RFC5426) con verifica diretta del certificato applicativo installato sul Server e con verifica della firma di un certificato installato

nell'applicativo Client. La firma del certificato Client deve essere effettuata con una chiave pubblica appartenente ad un elenco di CA trustabili.

L'infrastruttura creata per la verifica dell'identità dei nodi e l'apertura di canali sicuri è di tipo PKI: Public Key Infrastructure.

3.6.1. Creazione Certificati Applicativi Labeling

Al termine del processo di Labeling al software testato vengono associati:

- **ApplicationID:** uno specifico identificativo caratterizzante la main release del software che è stata testata;
- **Certificato applicativo** caratterizzante il prodotto e utilizzabile per garantire l'autenticazione dell'applicativo secondo protocollo TLS.

Ad ogni prodotto labellato è assegnata una CA riconosciuta su tutto il territorio regionale. La coppia (Chiave pubblica, Chiave Privata) viene generata dalla Regione del Veneto ed aggiunta alle liste di validità regionali ed aziendali. Il certificato applicativo è self-signed, quindi firmato utilizzando la chiave privata assegnata allo prodotto e corrispondente alla chiave pubblica contenuta nel certificato. La connessione ai sistemi aziendali può avvenire solo da sistemi nei quali è installato un certificato applicativo contenente una chiave pubblica conosciuta (cioè presente nell'elenco delle chiavi pubbliche assegnate durante il processo di labeling) e firmato con una chiave privata associata alla stessa chiave pubblica. La gestione delle liste di revoca (o Certificate Revocation List (CRL)) è realizzata in accordo con lo standard IETF RFC5280 "Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile". Al rilevamento di un'anomalia, i sistemi aziendali possono comunicare alla regione la necessità di revocare un certificato. Le CRL locali mantengono l'aggiornamento rispetto alla CRL regionale mediante un processo periodico di allineamento (10 minuti).

In Figura [PKI Fascicolo Sanitario Elettronico regionale](#) è presentata una schematizzazione dell'Infrastruttura PKI concepita per il Fascicolo Sanitario Elettronico regionale.

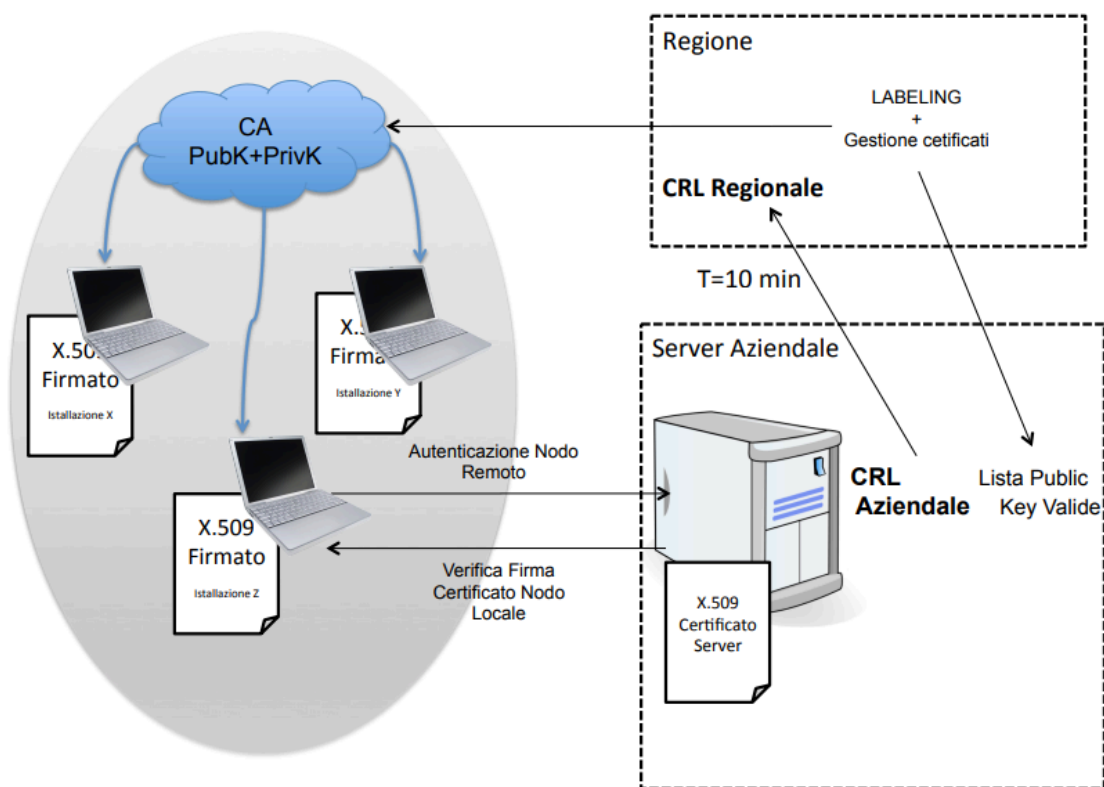


Figura 10. PKI Fascicolo Sanitario Elettronico regionale

Si sottolinea che questa modalità di inibizione di un applicativo dovrebbe essere utilizzata solo in caso di **GRAVE** malfunzionamento del software su più installazioni e viene quindi richiesto di ripetere il processo di labelling.

L'ApplicationID che viene definito in fase di labeling permette di svolgere un'azione di controllo e filtro applicativo sui sistemi. Concatenando l'ApplicationID con un identificativo della "Minor Release" del software e con un identificativo definito per la specifica installazione, è possibile ottenere il codice "ApplicationID" che deve essere veicolato all'interno di una richiesta di autenticazione di un Utente (per i dettagli della transazione di autenticazione degli utenti si veda sezione [RVE-1.a: Authenticate and Get Assertion](#)). I sistemi aziendali possono quindi utilizzare questo parametro per verificare l'attendibilità o meno di una richiesta di autenticazione generata da uno specifico applicativo.

3.6.1.1. Requisiti dei certificati

Sono definiti i seguenti requisiti per i certificati applicativi:

- Non sono richiesti specifici attributi per il contenuto dei certificati

- Certificati per mutua autenticazione devono essere X509 basati su chiave RSA di lunghezza 2048-4096
- Tempo di scadenza dei certificati deve essere al massimo 2 anni
- **Non deve essere utilizzata l'autenticazione del sistema per gestire sistemi di accesso ai dati clinici (Access Policies basate sull'identità dell'utente NON sulla tipologia di prodotto utilizzato). La verifica delle policies di accesso ai dati clinici è garantito dall'asserzione di identità degli user.**

3.6.2. Transazioni sicure tra WS: “WS-I Basic Security Profile”

Una associazione trusted tra due nodi deve essere stabilita utilizzando lo standard WS-I Basic Security Profile Version 1.1. Questa associazione deve essere utilizzata per tutte le transazioni sicure che devono avvenire tra i due nodi.

3.6.3. Standard di riferimento

IETF-RFC2246: The TLS Protocol v. 1.0

WS-I Basic Security Profile Version 1.1

IHE ATNA profile

3.7. Audit degli Eventi ([ITI-20] Record Audit Event)

Questa sezione descrive le modalità per la generazione, e la memorizzazione degli Audit degli eventi di rilevanza dal punto di vista della sicurezza e tracciabilità del sistema. Verrà descritta la distribuzione degli ATNA Audit Record Repository e gli standard di riferimento utili per definire la struttura dei messaggi Syslog che devono essere generati dai sistemi coinvolti.

3.7.1. Infrastruttura Auditing

L'infrastruttura definita per la memorizzazione degli Audit applicativi è federata. Ogni sistema coinvolto all'interno del sistema Fascicolo Sanitario Elettronico regionale DEVE garantire le proprietà di un ATNA Secure Node o ATNA Secure Application (come descritto precedentemente e negli specifici standard di riferimento IHE ITI TF-1: sez. 9) Ogni azienda implementerà un ATNA Audit Record Repository (ARR) in accordo con lo standard ATNA. In questo modo ogni azienda sanitaria sarà responsabile dello storing di tutti gli Audit generati a seguito del tentativo di accesso ai propri sistemi ed al tentativo di consultare documenti o informazioni cliniche memorizzate nei repository aziendali.

Deve essere realizzato anche un ARR a livello regionale in grado di tracciare ogni tentativo di accesso ai servizi regionali (Registry, SAR, ecc.). I flussi informativi vengono così distribuiti su un'architettura federata.

Per quanto riguarda gli attori territoriali, deve essere realizzata un'integrazione tra questi sistemi e l'ARR dell'azienda di riferimento.

Per ogni specifica transazione verrà definito, a seguito di un'analisi di risk assesment, se e in che modalità generare Audit messages. Non è obiettivo di questa documentazione tecnica definire la struttura di tutti gli audit messages generati a seguito delle specifiche transazioni di accesso ai servizi del FSEr.

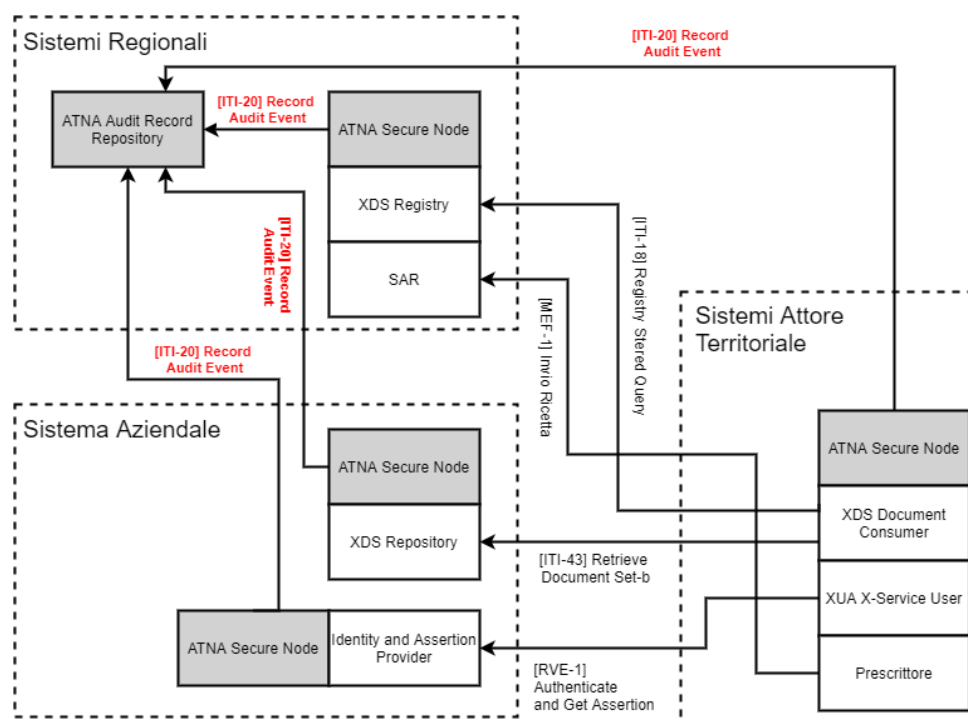


Figura 11. Infrastruttura Auditing FSEr

L'infrastruttura creata permette di verificare analizzando gli Audit memorizzati nel ARR Regionale tutti i tentativi di accesso ai documenti condivisi a livello di FSEr. Per verificare l'effettivo accesso a tali informazioni, è necessario interrogare gli specifici ARR aziendali che tracciano gli accessi ai Repository documentali.

Il processo di autenticazione di un attore territoriale è considerato step fondamentale per tutte le successive interazioni all'interno dei servizi del FSEr. Per questo motivo questo evento deve essere tracciato da una coppia messaggi di Audit:

- il primo inviato dall'applicativo dell'attore territoriale in corrispondenza della richiesta di autenticazione
- il secondo inviato dall'attore Identity and Assertion Provider in corrispondenza della creazione dell'asserzione di identità veicolata all'interno della Response alla transazione [RVE-1]. (per i dettagli relativi alla transazione [RVE-1] ed al contenuto

degli audit messages generati si faccia riferimento alla sezione [RVE-1.a: Authenticate and Get Assertion](#) di questo documento di specifiche).

I messaggi di Audit sono strutturati come descritto in sezione [Struttura degli Audit messages](#). Questi messaggi sono inviati ad un attore ATNA ARR di riferimento attraverso l'utilizzo di una transazione [ITI-20] Record Audit Event descritta all'interno del documento: IHE ITI TF-2a: 3.20.

L'attore ARR può ricevere e memorizzare Audit messages relativi a diverse tipologie di eventi.

L'attore ARR può essere interrogato per ricevere le necessarie informazioni relative all'auditing. Le modalità di interrogazione sono definite in sezione [Interrogazione di un sistema di ARR federato](#). L'interfaccia dell'attore ARR permette di interrogare per eventi associati ad uno specifico paziente, ad uno specifico documento o associati ad uno specifico operatore sanitario.

3.7.1.1. Interrogazione di un sistema di ARR federato

Fare riferimento all' Infrastructure Technical Framework Supplement "Add RESTful ATNA (Query and Feed)"
"https://www.ihe.net/uploadedFiles/Documents/ITI/IHE_ITI_Suppl_RESTful-ATNA.pdf"

3.7.2. Struttura degli Audit messages

L'auditing degli eventi di rilevanza dal punto di vista della sicurezza è di fondamentale importanza. Per distribuire i carichi di comunicazione tra i sistemi si è concepita un'infrastruttura di Audit Trail federata con più ARR (Audit Record Repository). La generazione di Audit Record avviene a livello di Secure Node/Secure Application. I messaggi di Audit sono generati secondo il protocollo Syslog (RFC-5424), veicolando all'interno del campo MSG la struttura XML definita dallo standard RFC-3881: "Security Audit and Access Accountability Message XML Data Definitions for Healthcare Application" in accordo con la transazione IHE ITI-20: Record Audit Event e lo standard DICOM: "Audit Trail Message Format Profile".

Ogni transazione standardizzata definisce in modo mandatorio la struttura di questa porzione XML in modo tale da poter veicolare le informazioni necessarie al Security Officer. Per le transazioni non standardizzate (transazioni MEF ciclo prescrittivo, RVE-1, RVE-2, ecc...) verrà definita una specifica struttura dell'audit all'interno delle specifiche di riferimento.

I messaggi Syslog DEVONO essere inviati attraverso protocollo TLS garantendo la confidenzialità e l'autenticazione dei sistemi coinvolti. Le modalità per l'invio dei messaggi attraverso i protocolli sopracitati è definita negli standard IETF di riferimento: RFC5425 e RFC5426.

I principali set di informazioni che sono veicolati all'interno di un messaggio di audit sono:

- 1) Event Identification: informazioni che permettono di identificare lo specifico evento tracciato;

- 2) Active Participant Identification: informazioni relative all'utente che ha svolto l'evento. Veicola informazioni sull'identità che sono presenti nell'asserzione di identità. Deve quindi valorizzare l'activeParticipant per lo humanRequestor con quanto definito nelle specifiche IHE ITI TF-2b per la transazione ITI-40 e dovrebbe seguire anche quanto definito in Sezione [Audit Messages generato dal Retrieve Gateway](#).
- 3) Network Access Point Identification: identifica il punto di accesso alla rete da cui è stato eseguito l'evento
- 4) Audit Source Identification: individuazione della sorgente applicativa che ha generato l'Audit
- 5) Participant Object Identification: set di informazioni che permette di identificare i vari soggetti che partecipano all'evento o le varie istanze di dati coinvolte nell'evento tracciato.

3.7.2.1. Audit Messages generato dal Retrieve Gateway

L'attore Retrieve Gateway deve creare degli audit compliant con quanto definito nelle specifiche IHE ITI TF-2b per la transazione ITI-43. Inoltre l'elemento activeParticipant dell'HumanRequestor deve essere strutturato come definito nel paragrafo relativo a [ITI-40] Provide X-User Assertion presente all'interno dell' ultima versione delle "Specifiche Tecniche - ATNA - Security Considerations".

3.7.3. Standard di riferimento

IETF-RFC5424: The Syslog Protocol

IETF-RFC5425: Transport Layer Security (TLS) Transport Mapping for Syslog

IETF-RFC3881: Security Audit and Access Accountability Message XML Data Definitions for Healthcare Application

DICOM Audit Trail Message Format Profile

IHE ATNA profile

Volume 2

.....

Verrà definita un'infrastruttura per l'autenticazione degli user federata. In questo modo, un Service Provider potrà erogare servizi ad uno user non conosciuto sulla base di un'asserzione di identità (token SAML 2.0) creata da un Identity Provider Trusted. Gli attori Identity Provider (Assertion Creator) sono localizzati a livello Aziendale, in quanto gli Active Directory aziendali gestiscono già le credenziali di autenticazione di medici aziendali ed MMG. Nello stesso modo dovranno essere gestite le credenziali rilasciate al titolare di ogni farmacia territoriale. Il sistema Identity Provider aziendale dovrà sviluppare due servizi:

- 1) Un servizio di autenticazione e richiesta asserzione (RVE-1: Authenticate and Get Assertion) che permetterà ad un qualsiasi attore X-Service User (Cross-Enterprise Service User) che vuole accedere a servizi regionali o extra aziendali, di richiedere un'asserzione di identità previa autenticazione mediante l'utilizzo delle credenziali fornite dall'identity provider (I dettagli della transazione sono descritti di seguito nella sezione [RVE-1.a: Authenticate and Get Assertion](#)).
- 2) Un servizio applicativo per l'aggiornamento periodico delle credenziali di autenticazione (RVE-2: Update Password, sezione [RVE-2 Update Password](#))

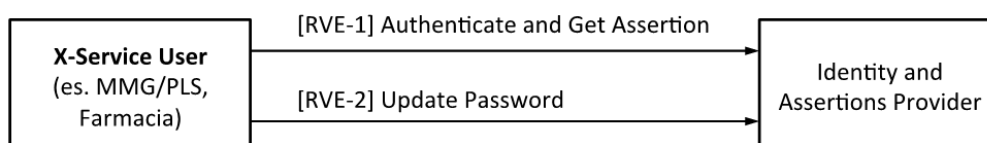


Figura 12. Transazioni Piattaforma di autenticazione federata FSEr

L'infrastruttura di Sicurezza è concepita in modo da poter essere integrata con il sistema di policy management che verrà creato a livello Regionale per garantire il controllo degli accessi ai PHI. Di seguito è presentato uno schema riassuntivo rappresenta l'infrastruttura creata per la richiesta, la produzione e l'utilizzo del token SAML 2.0.

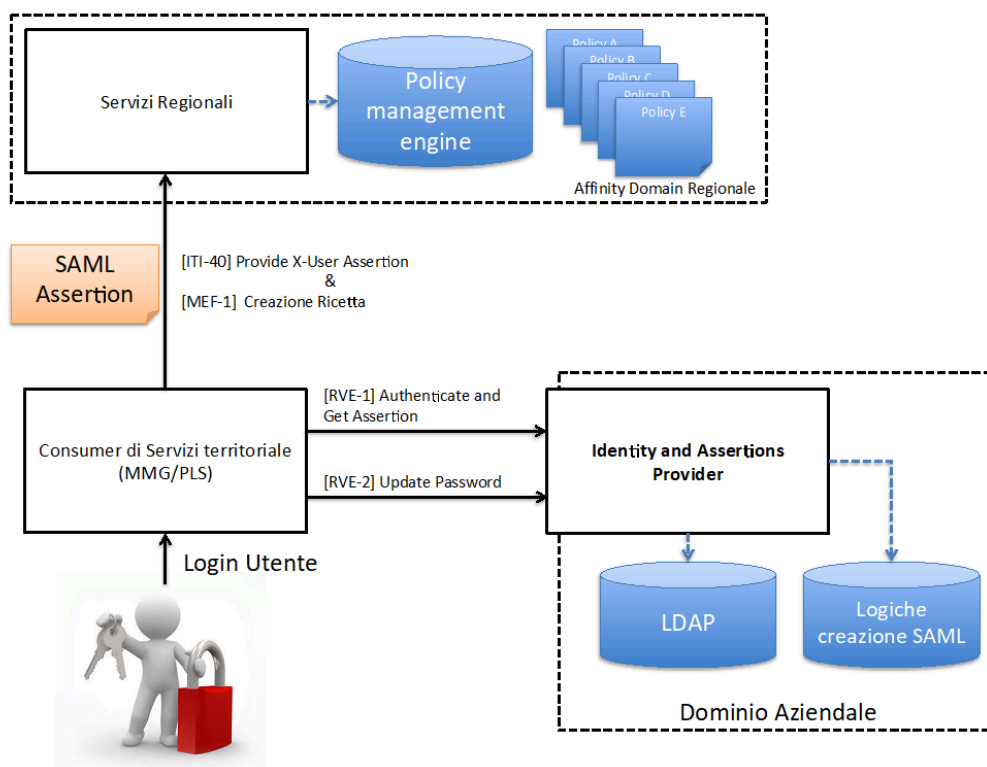


Figura 13. Infrastruttura per l'autenticazione degli utenti

Un utente che necessita di interfacciarsi sul sistema Fascicolo Sanitario Elettronico regionale dovrà autenticarsi nel proprio sistema locale secondo le regole impostate. L'applicativo utilizzato dall'utente richiederà allo Identity and Assertion Provider aziendale un'asserzione d'identità presentandosi con le credenziali aziendali di un responsabile (mappato quindi nell'LDAP aziendale). L'asserzione viene creata per lo specifico utente che ha eseguito la richiesta e conterrà informazioni relative al Ruolo, Contesto all'interno delle quali è stata realizzata la richiesta. L'asserzione firmata digitalmente (XML Signature) viene utilizzata come ticket per accedere ai servizi del FSEr di interesse. L'attore X-Service Provider sarà caratterizzato da un sistema di policy management in grado di verificare l'accessibilità alle risorse richieste.

4. Transazioni

4.1. [RVE-1.a] Authenticate and Get Assertion

Questa sezione descrive la transazione [RVE-1.a] individuando scopo, semantica dei messaggi scambiati e Expected Actions degli attori coinvolti. Questa transazione è utilizzata dall'X-Service User e dall' Identity and Assertions Provider. Questa transazione non descrive come utilizzare l'asserzione generata dall'Identity and Assertions Provider. L'utilizzo dell'asserzione di identità per accedere a servizi regionali o extra-aziendali è descritto all'interno della transazione [ITI-40] Provide X-User Assertion profilata da IHE (si faccia

riferimento alla sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#) di questo documento).

L'attore Identity and Assertion Provider si interfaccia direttamente con i sistemi aziendali. Il processo di autenticazione avviene all'interno dell'LDAP aziendale attraverso la configurazione di un connettore specifico. Le ulteriori informazioni necessarie per la verifica della richiesta di asserzione e per definire il contenuto informativo dell'asserzione stessa sono ricavati dall'attore Identity and Assertion Provider all'interno di opportune tabelle di confine configurate in modo tale da essere periodicamente aggiornate a seguito di un processo di query svolto sui sistemi aziendali. I connettori necessari per popolare le specifiche tabelle di frontiera sono configurati a livello aziendale.

In Figura [Comportamento dell'Attore Identity and Assertion Provider](#) è descritto il comportamento dell'attore Identity and Assertion Provider, individuando:

- i parametri forniti all'interno della richiesta
- i parametri inseriti all'interno dell'asserzione di identità
- le modalità di interfacciamento con i sistemi aziendali

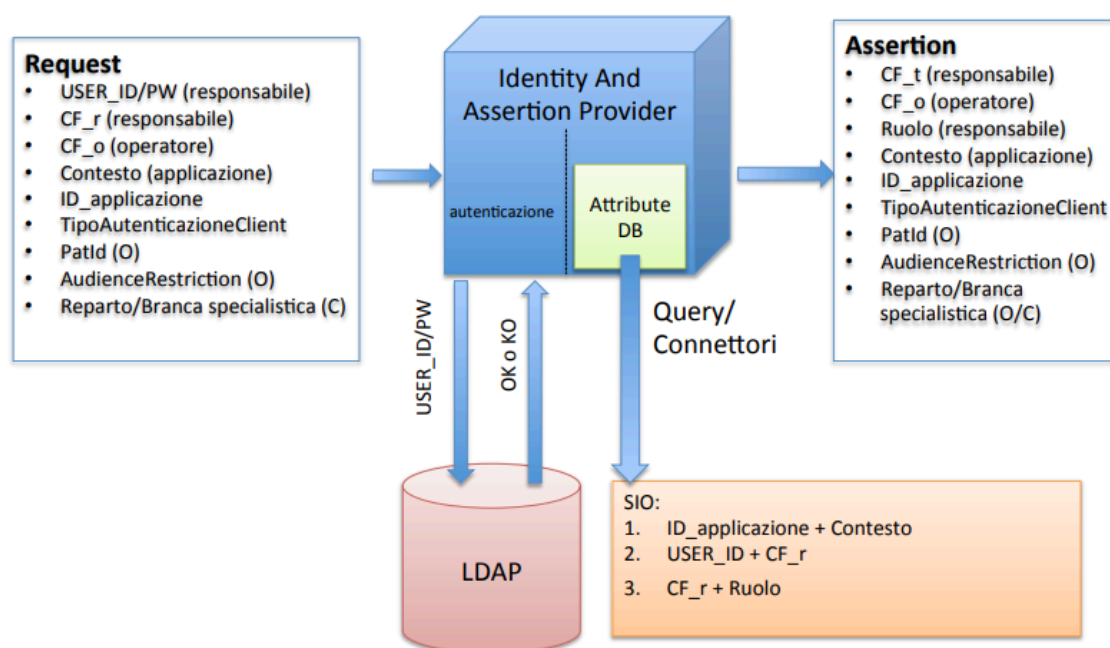


Figura 14. Comportamento dell'Attore Identity and Assertion Provider

4.1.1. Scopo

Questa transazione è utilizzata dall'X-Service User, ovvero un attore che deve accedere a servizi regionali o extra aziendali senza potersi autenticare direttamente all'X-Service Provider. Per questo motivo l'X-Service User richiede al proprio Identity and Assertions Provider di produrre un token SAML 2.0 che asserisca l'identità ed il ruolo dell'utente che si

è autenticato sul proprio sistema. Come definito in precedenza: una richiesta di asserzione è caratterizzata da un UTENTE che rappresenta l'effettivo richiedente e il RESPONSABILE, ovvero il detentore delle credenziali di autenticazione che sono utilizzate dall'utente per richiedere l'asserzione. L'utente è autenticato sul sistema client (X-Service User) utilizzando delle proprie credenziali. Il sistema X-Service User effettua una richiesta di asserzione presentando le credenziali di autenticazione (Username e Password) del responsabile. Queste due figure possono coincidere o meno a seconda dello use-case in esame (es. nel caso della farmacia territoriale, il responsabile è sempre il titolare della farmacia stessa, mentre i vari operatori che possono partecipare al processo di erogazione farmaceutica costituiscono i vari utenti).

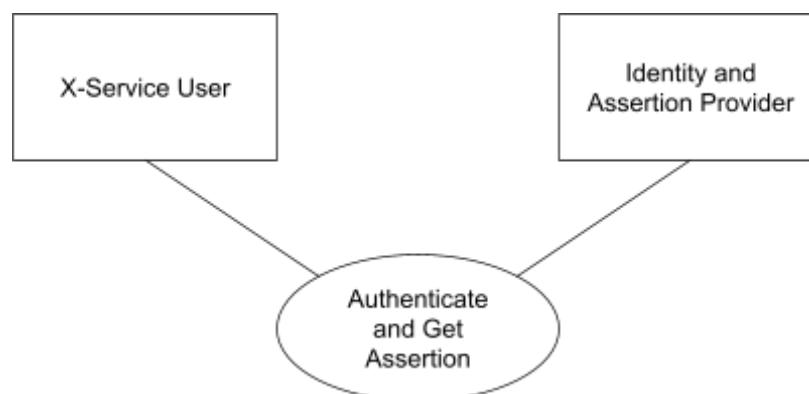
4.1.2. Attori e ruoli

Actor: X-Service User

Role: Richiede la creazione di un'asserzione di identità utilizzando delle credenziali di un responsabile conosciuto dall'Identity and Assertion Provider.

Actor: Identity and Assertion Provider

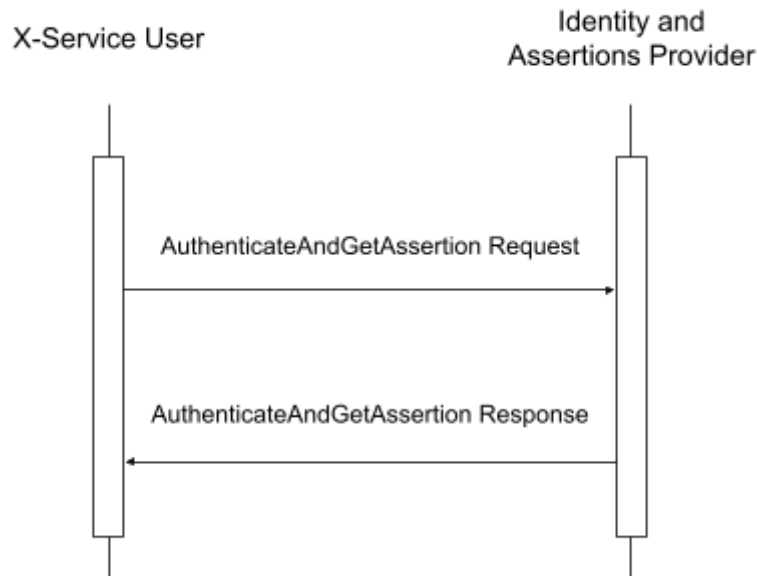
Role: Verifica l'identità dell'utente (e del responsabile) dell'attore X-Service User e sulla base di logiche interne crea un'asserzione valida o genera una risposta di errore.



4.1.3. Standard di riferimento

- W3C WS-Addressing 1.0 – SOAP Binding
- OASIS WS-Security
- OASIS WS-UsernameToken Profile
- OASIS SAML family spec.
- IHE ITI TF-2x: Appendix V
- IHE ITI TF-2b

4.1.4. Interaction Diagram



4.1.5. AuthenticateAndGetAssertion Request

Lo stesso Server (Identity And Assertion Provider) può essere invocato da tutti i client afferenti al suo dominio di autenticazione (tutti gli invocatori di servizi X-Service User).

4.1.5.1. Trigger Events

Il trigger events che determina la richiesta di una nuova asserzione d'identità è l'impossibilità di accedere ad un servizio esposto da un attore X-Service Provider a causa dell'utilizzo di un'asserzione non valida (vedi figura [Trigger Richiesta asserzione](#)). Oppure l'X-Service User è dotato di un servizio di keep-alive dell'asserzione in modo da poter riconoscere se l'asserzione sta per scadere o meno.

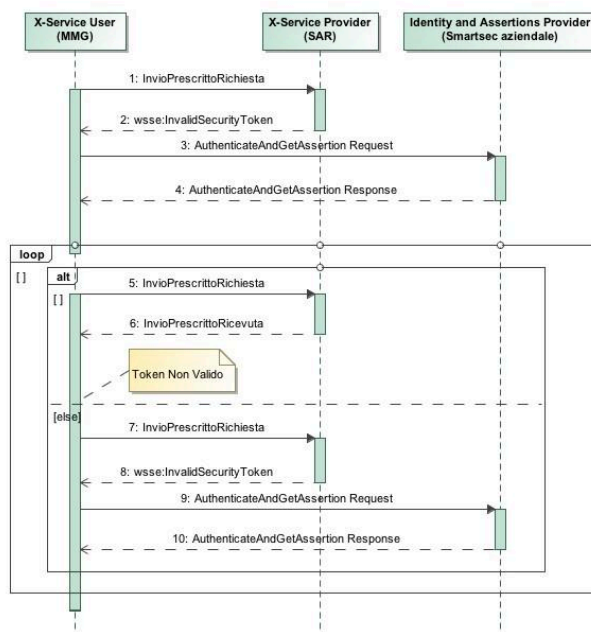


Figura 15. Trigger Richiesta asserzione

4.1.5.2. Message Semantics

Il messaggio creato dovrà essere un messaggio SOAP e quindi rispettare lo schema definito da <http://www.w3.org/2003/05/soap-envelope>.

L'Header del messaggio SOAP conterrà le informazioni relative all'autenticazione dello user Client. Si farà riferimento per questo elemento allo standard OASIS WS-Security ed in particolare allo UsernamePassword Token Profile.

Il Body conterrà la porzione di messaggio necessaria per effettuare la richiesta di asserzione.

4.1.5.2.1. SOAP Header

La struttura dell'Header DEVE essere conforme alle specifiche WS-Addressing 1.0 SOAP Binding redatte dal W3C (<http://www.w3.org/2005/08/addressing> nelle specifiche il namespace di riferimento sarà **wsa**). Queste specifiche permettono di individuare all'interno del messaggio scambiato il destinatario del messaggio stesso. Ogni messaggio NON DEVE contenere più di un elemento delle tipologie seguenti:

- **<wsa:To>** = indirizzo URI del destinatario ultimo del messaggio
- **<wsa:Action>** = URI che identifica la semantica attesa nel body ("urn:rve:AuthenticateAndGetAssertionRequest" identifica che il messaggio veicola una richiesta di autenticazione e una richiesta di asserzione)
- **<wsa:MessageID>** = identificativo univoco del messaggio

L'Header del messaggio SOAP deve anche contenere la porzione legata all'autenticazione dello responsabile, possessore delle credenziali (Username e password) necessarie per richiedere l'asserzione di identità per l'utente al Identity and Assertions Provider. Questa porzione è strutturata mediante l'utilizzo dello standard WS-Security: SOAP Message Security Version 1.1.1 (namespace di riferimento **wsse**). Accoppiando questo standard con il profilo WS Security UsernameToken Profile 1.0 (namespace di riferimento associato al WS-Utility profile: **utp**) è possibile definire come l'X-Service User deve utilizzare il token Username e Password per autenticare l'identità del responsabile attraverso l'Identity and Assertions Provider.

L'elemento UserNameToken, contenuto all'interno di un elemento Security DEVE contenere:

- **<wsse:Username>** = l'identificativo del responsabile conosciuto dall'Identity and Assertions Provider
- **<wsse:Password>** = non DEVE contenere la password in clearText. Questo elemento deve essere valorizzato con il base64 (password/@type="rve:PasswordEncrypted") come definito di seguito criptando con il certificato ULSSX.cer la concatenazione della password in chiaro, nonce ed un time stamp. Questo campo deve essere crittografato utilizzando tecniche di crittografia con la chiave pubblica RSA contenuta nel certificato X.509 fornito dalla ULSS ed applicando il padding PKCS#1 v 1.5. (La trasformazione deve essere conforme con quella ottenuta dall'esecuzione del comando del pacchetto open source "openssl", come a titolo di esempio: openssl rsautl -encrypt -in password_clearText.txt -out password.enc -inkey ULSSX.cer -certin -pkcs e deve essere successivamente codificato base64 per esempio utilizzando il comando: openssl base64 -e -in password.enc -out password_encrypted_base64.txt
- **<wsse:Nonce>** = valore random creato dall'inviante per ogni UserNameToken. Il Server deve mantenere l'elenco dei nonce utilizzati (accopiando il nonce con il creation time wsu:Created si può limitare il dispendio di risorse del server limitando la cache ai nonce più recenti).
- **<utp:Created>** = il time stamp di creazione dello usernameToken e coincide con l'istante di creazione del messaggio di richiesta. E' strutturato secondo il formato UTC.

Sia <wsse:Nonce> che <wsu:Created> DEVONO essere presenti e DEVONO essere inclusi nella composizione della password criptata:

rve:PasswordEncrypted = Base64 (encrypt(nonce + created + password))

La funzione di criptatura deve essere applicata alla concatenazione dei tre elementi descritti precedentemente. Il valore del campo created deve essere concatenato nella propria codifica UTF-8.

Di seguito è presentato un esempio di SOAP Header per il messaggio AuthenticateAndGetAssertion Request:

```
<?xml version="1.0" encoding="UTF-8"?>
<soap:Envelope xsi:schemaLocation="http://www.w3.org/2003/05/soap-envelope
soap-envelope.xsd" xmlns:soap="http://www.w3.org/2003/05/soap-envelope"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <soap:Header xsi:schemaLocation="http://www.w3.org/2005/08/addressing
ws-addr.xsd" xmlns:wsa="http://www.w3.org/2005/08/addressing">
```

```

        <wsa:Action>urn:rve:AuthenticateAndGetAssertionRequest</wsa:Action>
<wsa:MessageID>urn:uuid:9376254e-da05-41f5-9af3-ac56d63d8ebd</wsa:MessageID>
    <wsa:To>https://iap.ulssx.veneto.it/ws</wsa:To>
    <wsse:Security
xsi:schemaLocation="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssec
urity-secext-1.0.xsd oasis-200401-wss-wssecurity-secext-1.0.xsd"
xmlns:wsse="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-se
cext-1.0.xsd">
        <wsse:UsernameToken
xmlns:utp="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-uti
lity-1.0.xsd">
            <wsse:Username>pippo</wsse:Username>
            <wsse:Password
Type="rve:PasswordEncrypted">eUxvYS7u5aESbYalQu+KczY3L8PX9tZnxv1Fqpi3HlsvzcWD0ZPP
R/Y89QiSuldj
eEl3tkG8teYQEVmHmht1MPwbRRtFpRDKkt2qWxIJOKpShpDNUGnSqtVenX1zLAes
6umVZPLIIwmQRAQibTU4y9PN3kBNZ7JnPVks4scBLgI=</wsse:Password>
            <wsse:Nonce>randomX</wsse:Nonce>
            <utp:Created>2014-01-30T21:41:13Z</utp:Created>
        </wsse:UsernameToken>
    </wsse:Security>
</soap:Header>
    <soap:Body xsi:schemaLocation="urn:oasis:names:tc:SAML:2.0:protocol
saml-schema-protocol-2.0.xsd" xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol">
        <samlp:AuthnRequest ID="msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd"
Version="2.0" IssueInstant="2014-01-20T13:51:13Z">
<!-- qui va il body con la richiesta di asserzione -->
        </samlp:AuthnRequest>
    </soap:Body>
</soap:Envelope>

```

4.1.5.2.2. SOAP Body

Il body del messaggio SOAP deve essere strutturato in accordo con il protocollo SAML definito nelle specifiche “Assertions and Protocols for the OASIS SAML V2.0” e fa riferimento al namespace: **samlp**="urn:oasis:names:tc:SAML:2.0:protocol".

La richiesta di asserzione è costituita da un elemento **<samlp:AuthnRequest>** che possiede i seguenti attributi obbligatori:

- **ID:** è l'identificativo univoco della richiesta. Tipo di dato "ID" e corrisponde all'identificativo univoco contenuto nell'elemento del Header SOAP **<wsa:MessageID>** privato dei caratteri "urn:uuid:" (il dataType ID non permette l'utilizzo del carattere ":") e con l'aggiunta della stringa "msgId_".

es:

header/MessageID=urn:uuid:9376254e-da05-41f5-9af3-ac56d63d8ebd

body/ AuthnRequest/@ID=msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd

- **Version:** deve essere valorizzato con "2.0".
- **IssueInstant:** istante in cui è creata la richiesta in formato UTC.

All'interno dell'elemento <samlp:AuthnRequest> sono contenuti una serie di sotto-elementi che permettono di identificare l'attore che sta effettuando la richiesta, il soggetto per il quale DEVE essere creata l'asserzione ed il motivo. Il processo di autenticazione DEVE avvenire a seguito dell'analisi del contenuto dell'elemento UsernameToken contenuto nell'Header SOAP e quindi prima della lettura dell'elemento <samlp:AuthnRequest>.

I sotto elementi contenuti (riferimento al namespace **saml="urn:oasis:names:tc:SAML:2.0:assertion"**) sono:

- **<saml:Issuer>**: elemento che permette di identificare il **responsabile** che effettua la richiesta (tipo di dato complesso NameIDType). Questo elemento deve veicolare le stesse informazioni utilizzate per effettuare l'autenticazione attraverso il blocco WS-Security contenuto nel SOAP Header. Questo elemento contiene una stringa con il CODICE FISCALE del responsabile della richiesta. **Conseguentemente l'Issuer sarà sempre un attore conosciuto dall'attore Identity and Assertions Provider (soggetto presente nell'LDAP aziendale).**
- **<samlp:Extensions>**: è l'elemento che permette di veicolare verso l'attore Identity and Assertions Provider informazioni aggiuntive utili per creare l'asserzione stessa. L'elemento Extensions contiene un set di attributi, forniti dal sistema client, che poi comporranno l'asserzione. PUO' quindi contenere solamente un elemento **<AttributeStatment>**.
 - **<AttributeStatment>**: questo elemento contiene molteplici elementi
 - **<Attribute>**: è l'elemento che descrive l'attributo della richiesta di asserzione. Sono attesi almeno tre elementi Attribute all'interno di un messaggio AuthenticateAndGetAssertion Request:
 - **UserClientAuthentication**: descrive la tipologia di autenticazione eseguita dall'utente per accedere ai servizi del sistema X-Service User. I codici da utilizzare per questo attributo sono definiti in [Appendice A: CodeSystems](#).
 - **RequestContext**: descrive il contesto all'interno del quale si è resa necessaria la richiesta di servizio. Questo attributo può essere valorizzato con i codici definiti in [Appendice A: Code Systems](#).
 - **ApplicationID**: definisce l'ID dell'applicativo che esegue la richiesta di asserzione il formato dell'ID è: [ApplicationID]^[minor_release]^[installazione] dove "ApplicationID" è l'ID associato al prodotto software che ha superato la fase di labeling, "minor_release" rappresenta la versione successiva del software non labellata, "installazione" rappresenta un identificativo univoco per la specifica installazione del software labellato.
 - **PatientID**: rappresenta l'identificativo univoco del paziente nei confronti del quale l'utente sta agendo con il contesto dichiarato. L'opzionalità di questo attributo è dipendente dalla tipologia di servizio al quale si vuole accedere.
 - **codOTP**: veicola il codice OTP restituito dal sistema AMPS. L'opzionalità di questo attributo è dipendente dalla tipologia di servizio al quale si vuole accedere.
 - **<saml:Subject>**: specifica l'utente che effettua la richiesta. Esistono vari use-case per i quali il Subject di un'asserzione è diverso dall'Issuer della richiesta, in quanto una richiesta può essere effettuata solo presentando UsernameToken di responsabili accreditati dall'attore Identity and Assertions Provider. Per esempio:

- a) richiesta effettuata per un operatore di una farmacia diverso dal titolare:

UsernameToken= titolare , Issuer = titolare , Subject = operatore.

- b) richiesta effettuata da un medico sostituto con credenziali dell'MMG:

UsernameToken= MMG , Issuer = MMG , Subject = sostituto.

L'identità dell'utente è tracciata all'interno di un elemento di tipo NameIDType:

- **<NameID>**: DEVE contenere il codice fiscale del soggetto per cui viene richiesta l'asserzione. Questo utente deve essere caratterizzato anche dallo userID utilizzato per autenticarsi all'interno del client e dall'individuazione del provider che ha autenticato l'utente. Queste informazioni sono veicolate attraverso l'utilizzo dei seguenti attributi:
 - SPNameQualifier: il provider che qualifica il name (es. la farmacia)
 - SPProvidedID: l'ID utilizzato dallo user all'interno della struttura
- **<saml:Conditions>**: è l'elemento che permette di veicolare le condizioni SAML che l'X-Service User si aspetta di ottenere all'interno dell'asserzione per limitarne la validità e l'utilizzo. **L'attore Identity and Assertions Provider può modificare queste condizioni se necessario.** L'elemento <saml:Conditions> può contenere i seguenti attributi:
 - **NotBefore**: specifica il primo istante di tempo per cui l'asserzione è valida in formato UTC
 - **NotOnOrAfter**: specifica l'istante di tempo in cui l'asserzione scade in formato UTC

All'interno dell'elemento <saml:Conditions> è possibile aggiungere un elemento <AudienceRestriction>:

- **<AudienceRestriction>**: è un elemento opzionale che permette di specificare il Servizio regionale o extra-aziendale a cui si cercherà di accedere utilizzando l'asserzione richiesta. Per ogni destinatario individuato viene aggiunto un elemento:
 - <Audience>: che contiene l'URL del servizio a cui si cercherà di accedere utilizzando l'asserzione prodotta (questo servizio deve essere individuato specificando l'url completo e corrisponde all'attore X-Service Provider, vedi sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#)). Per ulteriori dettagli relativi all'utilizzo di questo elemento fare riferimento alla sezione [Audience Restriction use-case](#).

Di seguito è presentato un esempio di SOAP body per un messaggio AuthenticateAndGetAssertion Request:

```
<?xml version="1.0" encoding="UTF-8"?>
```

```

<soap:Envelope xsi:schemaLocation="http://www.w3.org/2003/05/soap-envelope
soap-envelope.xsd" xmlns:soap="http://www.w3.org/2003/05/soap-envelope"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <soap:Header xsi:schemaLocation="http://www.w3.org/2005/08/addressing
ws-addr.xsd" xmlns:wsa="http://www.w3.org/2005/08/addressing">
    <!-- qui va l'header SOAP con usernameToken -->
  </soap:Header>
  <soap:Body xsi:schemaLocation="urn:oasis:names:tc:SAML:2.0:protocol
saml-schema-protocol-2.0.xsd" xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol">
    <samlp:AuthnRequest ID="msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd"
Version="2.0" IssueInstant="2014-01-20T13:51:13Z">
      <Issuer
xmlns="urn:oasis:names:tc:SAML:2.0:assertion">ZNRMRA86L11B157N</Issuer>
      <samlp:Extensions>
        <AttributeStatement xmlns="urn:oasis:names:tc:SAML:2.0:assertion">
          <Attribute Name="UserClientAuthentication">
            <AttributeValue>A.1</AttributeValue>
          </Attribute>
          <Attribute Name="ApplicationID">
<AttributeValue>2.16.840.1.113883.2.9.2.50.4.5.0003</AttributeValue>
            </Attribute>
          <Attribute Name="PatientID">
            <AttributeValue>ZNRMRA86L11B157N</AttributeValue>
          </Attribute>
          <Attribute Name="RequestContext">
            <AttributeValue>C.1.1</AttributeValue>
          </Attribute>
        </AttributeStatement>
      </samlp:Extensions>
      <Subject xmlns="urn:oasis:names:tc:SAML:2.0:assertion">
        <NameID SPNameQualifier="ambulatorio di pippo"
SPProvidedID="user">ZNRMRA86L11B157N</NameID>
        </Subject>
        <Conditions NotBefore="2013-10-15T16:09:30Z"
NotOnOrAfter="2013-10-15T17:32:30Z"
xmlns="urn:oasis:names:tc:SAML:2.0:assertion">
          <AudienceRestriction>
<Audience>https://sar.regione.veneto.it/demInvioPrescritto</Audience>
            <!-- asserzione richiesta per accedere al servizio di invio
ricette -->
          </AudienceRestriction>
        </Conditions>
      </samlp:AuthnRequest>
    </soap:Body>
  </soap:Envelope>

```

4.1.5.3. Expected Actions

Il messaggio AuthenticateAndGetAssertion Request prevede due azioni consecutive:

- richiesta di autenticazione di un responsabile;
- richiesta di un'asserzione di identità per un utente.

Il processamento dell'header permette di eseguire l'autenticazione dello user. Se Lo usernameToken viene processato in modo corretto l'attore Identity and Assertions Provider riconosce l'identità del responsabile della richiesta. L'attore Identity and Assertions Provider DEVE:

- rigettare token creati che non utilizzano wsse:Nonce e wsu:Created.
- rigettare token con time stamp troppo datati (un intervallo di tempo indicativo di 5 minuti)
- tenere memoria dei nonce utilizzati all'interno del time limit impostato.

In caso di errore nel processo di autenticazione, l'attore Identity and Assertions Provider deve generare un messaggio di Response che veicola l'errore in accordo con le specifiche definite all'interno dello standard WS-Security section 12 "Error Handling" (la struttura di un messaggio di Response generato a seguito del fallimento del processo di autenticazione è definito in sezione [Scopo](#)):

- **<wsse:FailedAuthentication>**: Se il security Token non può essere autenticato o autorizzato. (Le specifiche tipologie di errore associate a questa classe di errore sono definite in [appendice A](#), sezione [wsse:FailedAuthentication](#)).

Se l'attore Identity and Assertions Provider è in grado di processare in modo corretto il body SOAP del messaggio AuthenticateAndGetAssertion Request, DEVE creare un messaggio di risposta AuthenticateAndGetAssertion Response contenente un'asserzione di identità per il <Subject> individuato nella richiesta. Se l'attore Identity and Assertions Provider ritiene una richiesta NON valida secondo la sintassi SAML o non ritiene di poter asserire l'identità dell'utente definito nell'elemento <Subject>, DEVE creare un messaggio di Response con al suo interno un elemento **<StatusCode>** che descrive la condizione di errore. Di seguito sono presentate le varie condizioni di errore che devono essere utilizzate all'interno dell'attributo **value**:

- *urn:oasis:names:tc:SAML:2.0:status:Requester*: la richiesta non è stata completata in quanto si è individuato un errore dal lato del client.
- *urn:oasis:names:tc:SAML:2.0:status:Responder*: la richiesta non è stata completata in quanto si è individuato un errore dal lato del server.
- *urn:oasis:names:tc:SAML:2.0:status:InvalidAttrNameOrValue*: contenuto non atteso o non valido è individuato negli attributi della richiesta.
- *urn:oasis:names:tc:SAML:2.0:status:RequestDenied*: il server è riuscito a processare la richiesta ma ha scelto di non rispondere con un successo.
- *urn:oasis:names:tc:SAML:2.0:status:RequestUnsupported*: il server non supporta la richiesta.

L'elemento <statusCode> può contenere altri sottoelementi che permettono di dettagliare la condizione di errore:

- **<StatusMessage>**: permette di veicolare all'operatore una stringa contenente maggiori informazioni sulla condizione di errore verificatosi.

4.1.5.3.1. Controlli eseguiti sui parametri della richiesta

In questa sezione verranno descritti i controlli mandatori e quelli opzionali che l'attore Identity and Assertion Provider deve eseguire sui parametri della richiesta di autenticazione. La gestione e il mantenimento dei flussi informativi necessari per effettuare la verifica è in carico all'azienda sanitaria di riferimento, la quale dovrà predisporre degli specifici connettori verso l'attore Identity and Assertion Provider.

Le principali verifiche mandatorie che l'attore deve garantire sono:

- Verificare che il contesto dichiarato dall'applicativo sia tra i contesti che l'azienda ha abilitato per quel determinato ApplicationID:

contesto dichiarato $\in$ (contesti + ApplicationID)

- Verificare che il CF del responsabile coincida con il CF memorizzato nei sistemi aziendali:

CF_r == CF conosciuto in azienda

- Verificare le seguenti condizioni per l'elemento attributeStatement/attribute relativo al codReparto
 - se è valorizzato in richiesta, l'attore Identity and Assertion Provider deve verificare che quest'ultimo sia corretto rispetto al CF dell'utente e all'ora in cui è stata richiesta l'asserzione.
 - se NON è valorizzato in richiesta, l'attore Identity and Assertion Provider deve assegnare il codReparto, verificandolo in base al CF dell'utente ed all'orario in cui è stata richiesta l'asserzione

Le verifiche opzionali che deve effettuare l'attore Identity and Assertion Provider sono presentate di seguito. L'opzionalità può essere legata a policy aziendali o a specificità legate al servizio a cui l'attore X-Service User cercherà di accedere utilizzando l'asserzione di identità. In questo caso DOVREBBE essere veicolato all'interno dei parametri della richiesta l'elemento AudienceRestriction specificante l'url del X-Service Provider (vedere sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#) per i dettagli):

- Verificare che l'ApplicationID non sia tra le installazioni o tra le minor release "bannate" dall'azienda:

ApplicationID $\notin$ applicativi Bannati Aziendali

- Verificare che lo specifico paziente (PatientID) sia nella relazione dichiarata (contesto) con l'utente che esegue la richiesta (es. per la consultazione di un documento da parte di un MMG può essere verificato che il paziente X sia veramente associato al medico Y in anagrafica di scelta e revoca):

PatientID $\in$ (contesto + PatientID)

- Verificare che la tipologia di autenticazione eseguita sul Client sia tra le tipologie di autenticazione ammesse (il valore aggiunto di questo attributo si vedrà nel momento in cui avremo medici autenticati con modalità diverse User/pw, smartCard ecc.):

UserClientAuthentication $\subseteq$ UserClientAuthentication ammessi

4.1.6. AuthenticateAndGetAssertion Response

Questo messaggio veicola verso l'attore X-Service User l'asserzione di identità necessaria per invocare successivi servizi regionali o extra-aziendali.

4.1.6.1. Trigger Events

Il messaggio di Response contenente l'asserzione viene generato in risposta ad un messaggio di Request.

4.1.6.2. Message Semantics

4.1.6.2.1. SOAP Header e Body

Il messaggio di response è un messaggio SOAP che descrive una **<soap:Action>** del tipo *urn:rve:AuthenticateAndGetAssertionResponse*. E' necessario tracciare nell'Header del messaggio SOAP l'identificativo del messaggio di Request che ha determinato la generazione della Response attraverso l'elemento **<wsa:RelatesTo>**.

Il SOAP Body contiene un elemento **<samlp:Response>** che DEVE contenere al suo interno:

- **<samlp:Status>** elemento obbligatorio che contiene a sua volta una serie di elementi:
 - **<samlp:StatusCode>**: Elemento obbligatorio che permette di veicolare un codice che descrive lo stato di attività della risposta alla richiesta corrispondente. Questo elemento DEVE contenere un attributo:
 - **Value**: valorizzato con "urn:oasis:names:tc:SAML:2.0:status:Success" in caso di successo, o con una condizione di errore descritta in "Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0", sezione 60.
 - **<samlp:StatusMessage>**: elemento opzionale che permette di veicolare un messaggio all'utente che richiede un'asserzione.
- **<saml:Assertion>**: se la richiesta è stata processata in modo corretto (Status di successo), l'elemento Response deve contenere un elemento assertion che permette di strutturare l'asserzione di identità in accordo con lo schema "urn:oasis:names:tc:SAML:2.0:assertion".

Di seguito viene presentato un esempio di messaggio SOAP per il messaggio AuthenticateAndGetAssertion Response (il contenuto dell'asserzione di identità è descritto nella sezione seguente).

```
<soap:Envelope xmlns:soap="http://www.w3.org/2003/05/soap-envelope"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <soap:Header>
```

```

        <wsa:Action
xmlns:wsa="http://www.w3.org/2005/08/addressing">urn:rve:AuthenticateAndGetAssert
ionResponse</wsa:Action>
        <wsa:MessageID
xmlns:wsa="http://www.w3.org/2005/08/addressing">urn:uuid:6364ad23-89f7-11e3-a222
-0010f32f794e</wsa:MessageID>
        <wsa:To
xmlns:wsa="http://www.w3.org/2005/08/addressing">http://X-ServiceUser</wsa:To>
        <wsa:RelatesTo
xmlns:wsa="http://www.w3.org/2005/08/addressing">urn:uuid:9376254e-da05-41f5-9af3
-ac56d63d8ebd</wsa:RelatesTo>
    </soap:Header>
    <soap:Body>
        <samlp:Response Version="2.0" ID="63651e2689f711e3a03b0010f32f794e"
InResponseTo="msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd"
IssueInstant="2014-01-30T21:42:16Z"
xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol"
xmlns:tns="http://www.bit4id.com/xmlns/ipam/">
            <samlp:Status>
                <samlp:StatusCode
Value="urn:oasis:names:tc:SAML:2.0:status:Success"/>
                <samlp:StatusMessage>OK</samlp:StatusMessage>
            </samlp:Status>
            <saml:Assertion>
<!-- qui va il contenuto del token di identità -->
                </saml:Assertion>
            </saml:Response>
        </soap:Body>
    </soap:Envelope>

```

4.1.6.2.2. Struttura dell'asserzione di identità

L'elemento **<saml:Assertion>** DEVE contenere i seguenti attributi:

- **Version:** deve essere "2.0"
- **ID:** identificativo univoco dell'asserzione creata dall'Identity and Assertions Provider. Questo identificativo DEVE essere necessariamente univoco a livello regionale. Per questo motivo si suggerisce di strutturare l'ID in questo modo:

ID = "assertion" + "_" + [OID_azienda] + "_" + [AuthnRequest/@ID]

es. un'asserzione generata dalla ULSS 12 di Milano a seguito della richiesta con ID "erbtgfvcsaewc":

assertion_2.16.840.1.113883.2.9.2.50112_msgId_erbtgfvcsaewc

- **IssueInstant:** istante temporale in cui è stata creata l'asserzione

L'elemento **<saml:Assertion>** contiene i seguenti elementi:

- **<saml:Issuer>**: elemento obbligatorio che descrive il creatore dell'Asserzione. Dovrebbe essere valorizzato con l'url dell'attore Identity and Assertions Provider che ha creato l'asserzione
- **<ds:Signature>**: Questo elemento è OBBLIGATORIO e permette di firmare l'asserzione con un XML signature autenticando l'attore Identity and Assertions Provider. Questa firma è eseguita in accordo alle specifiche definite dal namespace **ds**: "<http://www.w3.org/2000/09/xmldsig#>". L'elemento **<ds:Signature>** DEVE contenere due elementi **<ds:SignedInfo>** e **<ds:SignatureValue>**. **<ds:SignatureInfo>** permette di definire i parametri dell'algoritmo di firma utilizzato utilizzando i seguenti elementi obbligatori:
 - **<ds:CanonicalizationMethod>**: l'attributo **Algorithm** contiene la definizione dell'algoritmo di canonicalizzazione. Un applicativo conforme a SAML 2.0 dovrebbe utilizzare un algoritmo di canonicalizzazione esclusiva [Excl-C14N] definita dal seguente uri "<http://www.w3.org/2001/10/xml-exc-c14n#>".
 - **<ds:SignatureMethod>**: l'attributo **Algorithm** contiene la definizione dell'algoritmo di firma utilizzato (XML Signature con utilizzo di algoritmo RSA) che potrà essere:
 - "<http://www.w3.org/2000/09/xmldsig#rsa-sha1>" : (deprecato e sconsigliato)
 - "<http://www.w3.org/2001/04/xmldsig-more#rsa-sha256>"
 - **<ds:Reference>**: deve essere UNICO e deve contenere l'attributo **URI** che fa riferimento all'attributo Assertion/@ID contenuto nell'asserzione preceduto da "#". Questo elemento DEVE contenere i seguenti elementi:
 - **<ds:DigestMethod>**: l'attributo **Algorithm** contiene la definizione dell'algoritmo utilizzato per creare il Digest. Deve essere:
 - "<http://www.w3.org/2000/09/xmldsig#sha1>" : (deprecato e sconsigliato)
 - "<http://www.w3.org/2001/04/xmldsig-more#sha256>"
 - **<ds:DigestValue>**: questo elemento contiene il valore del Digest in formato base64

Il secondo elemento **<ds:SignatureValue>** veicola la firma dell'asserzione in formato base64.

- **<saml:Subject>**: questo elemento DEVE essere presente e DEVE riportare le stesse informazioni contenute le **<saml:Subject>** della richiesta (rappresenta dunque l'utente per cui è creata l'asserzione di identità).

Nel caso in cui l'asserzione di identità sia creata durante una transazione [RVE-1.b] (autorizzazione rilasciata per applicativi trusted), il valore di questo elemento deve essere l'identificativo univoco dell'utente a cui sono associate le credenziali (username) dell'operatore stesso. Questo identificativo (Codice Fiscale) deve essere individuato dall'attore IAP mediante processo di query eseguita verso DB o sistema Directory Server di riferimento (in funzione delle modalità di configurazione dell'attore IAP).

- **<saml:Conditions>**: definisce le condizioni di validità dell'asserzione. Possono essere ereditate dal messaggio di Request o possono essere sovrascritte dall'attore Identity and Assertions Provider, in accordo con le policy di accesso ai servizi definite a livello regionale. L'elemento **<saml:Conditions>** DEVE avere valorizzati i seguenti attributi:

- **NotBefore:** istante di inizio della validità dell'asserzione in formato UTC
- **NotOnOrAfter:** istante di fine validità dell'asserzione in formato UTC

Questo elemento PUO' contenere un elemento <saml:AudienceRestriction> (con zero o più sotto elementi <saml:Audience> valorizzati con l'url di un servizio) per individuare il o gli attori X-Service Provider che possono accettare l'asserzione di identità.

- **<saml:AttributeStatment>:** sezione che permette di veicolare gli attributi dell'asserzione che sono associati allo user richiedente dall'attore Identity and Assertions Provider. Queste sono le informazioni che verranno analizzate dall'attore X-Service Provider per valutare l'accessibilità o meno ai propri servizi. Questo elemento contiene una serie di elementi **<saml:Attribute>**. Certi elementi <saml:Attribute> sono ereditati dal messaggio di Request (**ApplicationID**, **PatientID**, **codReparto** , **RequestContext**, **UserClientAuthentication**) altri sono definiti direttamente dall'attore Identity and Assertions Provider:
 - **Role:** permette di definire il ruolo associato allo user autenticato attraverso l'asserzione di identità. Il codeSystem per questo attributo è definito in [Appendice A: CodeSystems](#)
 - **ResponsibleParty:** permette di veicolare all'interno dell'asserzione il Codice Fiscale del Responsabile (il codice fiscale dell'Issuer del messaggio di richiesta). Nel caso in cui l'asserzione di identità sia creata a seguito di una transazione [RVE-1.b] (autorizzazione rilasciata per applicativi trusted), il valore di questo elemento deve essere l'identificativo univoco dell'utente a cui sono associate le credenziali (username) dell'operatore stesso. Questo identificativo (Codice Fiscale) deve essere individuato dall'attore IAP mediante processo di query eseguita verso DB o sistema Directory Server di riferimento (in funzione delle modalità di configurazione dell'attore IAP).
 - **codStruttura:** questo dato permette di individuare la struttura di appartenenza dell'utente autenticato. Tale codice deve essere assegnato a partire dal sistema di codifica STS11 o altro sistema di codifica definito a livello regionale.
 - **UserGrants:** questo dato permette di veicolare all'interno dell'asserzione l'informazione relativa al privilegio di accesso ad una data funzionalità applicativa per l'utente autenticato. Tale informazione viene prelevata da un apposito campo in LDAP e deve essere strutturato come definito in [Appendice F: UserGrants](#).
 - **codOTP:** questo dato permette di veicolare all'interno dell'asserzione il codice OTP restituito dal sistema APMS se indicato in fase di richiesta. Se non veicolato in richiesta tale attributo non deve essere presente.
 - **codVerifica:** veicola il codice di verifica associato ad un codice OTP restituito dal sistema AMPS qualora l'autenticazione a 2 fattori sia stata eseguita dallo IAP.

- **<saml:AuthnStatment>**: Elemento creato dall'attore Identity and Assertions Provider per veicolare all'interno dell'asserzione i dettagli del processo di autenticazione che ha portato alla creazione dell'asserzione stessa. Contiene un attributo **authnInstant**, che traccia l'istante a cui è avvenuta l'autenticazione ed un elemento **<saml:AuthnContext>** che descrive le modalità di autenticazione. Questo elemento contiene una serie di sottoelementi:
 - **<saml:AuthnContextClassRef>**: contiene l'URI che descrive le modalità di autenticazione: "urn:oasis:names:tc:SAML:2.0:ac:classes:InternetProtocolPass word"
 - **<saml:AuthenticatingAuthority>**: l'url del servizio che ha eseguito l'autenticazione.

```
<saml:Assertion Version="2.0" IssueInstant="2014-01-30T21:42:16Z"
ID="assertion_1.2.3.4.5_msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd"
xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion">
  <saml:Issuer>https://access.bit4id.org:8006</saml:Issuer>
  <ds:Signature xmlns:ds="http://www.w3.org/2000/09/xmldsig#">
    <ds:SignedInfo>
      <ds:CanonicalizationMethod
Algorithm="http://www.w3.org/2001/10/xml-exc-c14n#" />
      <ds:SignatureMethod
Algorithm="http://www.w3.org/2000/09/xmldsig#rsa-sha1" />
      <ds:Reference
URI="#assertion_1.2.3.4.5_msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd">
        <ds:Transforms>
          <ds:Transform
Algorithm="http://www.w3.org/2000/09/xmldsig#enveloped-signature" />
          <ds:Transform
Algorithm="http://www.w3.org/2001/10/xml-exc-c14n#" />
        </ds:Transforms>
        <ds:DigestMethod
Algorithm="http://www.w3.org/2000/09/xmldsig#sha1" />
        <ds:DigestValue>TX0E4NB0z0s+c3EsSgX0kQmao8Q=</ds:DigestValue>
      </ds:Reference>
    </ds:SignedInfo>
    <ds:SignatureValue>Lr+6O0yeyznBvzNu0fTf0B2cTaJ22AS0WlSnESYnfbwTF/FxH2GMcSeB/BfPnCb
ag6B8DHLhcnsAOl35eiyKs+ZN36v++5bhovZR7ts8Rf1IiDjEN6uN2U9U3RSSKKEZV8NsI5UJGJaA84C7
WvrKeo709xNmFbyfmYou05bgilf0=</ds:SignatureValue>
    <ds:KeyInfo>
      <ds:X509Data>
        <ds:X509Certificate>MIICjDCCAfWgAwIBAgIP+45MfDQR45ktABDzL3omMA0GCSqGSIb3DQEBBQUAM
FoxCzAJBgNVBAYTAklUMRkwFwYDVQQKExBDTVMcTlJHQU5JWkFUSU9OMRowGAYDVQQLExFDTVMgV29ya2
luZyBHcm91cDEUMBIGA1UEAxMLQ001TIFRlc3QgQ0EwHhcNMTEzMDk0MDU0WhcNMTEyMjI4MDk0MDU0
WjBAMRowGAYDVQQDExFhY2N1c3MuYm10NGlkLm9yZzEwMBQGA1UECwMNQm10NE1EIC0gRGVtbzEXMBUG
A1UEChMOUmVnaW9uZSBWZW5ldG8xCzAJBgNVBAYTAklUMIGFMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBg
```

```

QCRE9jS9zJSGs3+0pV5lwdJXoqOnyT6KvLAVwBNBQTxx7VvmWtvjNHsfxzRFpSpR6578EjKmXyyYw4Y
AIhCS4YbXlZTXNxpWxXbY0o33IvpvC+l1Tpl/0K7Kl7C9Z+GJdaOFAlc7RRBc4SaGLfUdOPbqmfHmPR
XAiq3IqtyAQIDAQABolQwUjAJBgNVHRMEAjAAMBGA1UdJQQMMAoGCCsGAQUFBwMBMB0GA1UdBAQWMBQw
DjAMBgorBgEEAYI3AgEWAwIHgDARBgIghkgBhvCAQEEBAMCBBAwDQYJKoZIhvcNAQEFBQADgYEAVwNj
Krinclpmjwnga3HYzeleSKC+FJcUPHoeqcochOzvLXyg8J/a+3bBwQl9t+cPO3Jt7jdDXAHoixLJEstg6
R2wlhKtUkdNx01fFPnajE4r019/zjVHUbngEJ0GCUeEeQV2yu77W3wNGkbXDmtA/9ADGmRRWkiCSLjikbv
+BjI=
```

```

</ds:X509Certificate>
</ds:X509Data>
<ds:KeyValue>
  <ds:RSAKeyValue>

<ds:Modulus>kRPY0vcyUhrN/tKVeZcHSV6Kjp8k+irywFcATQUE8UMcelVZlrb4zR7H8c0RaUqUeue/B
Iyp18smMOGACIQkuGG15WU1zcaVsV22NKN9yL6bwvpdU6Zf9CuypewvWfhiXWjhQJX00UQXOEmhi31HTj
26pn6Mh5j0VwIqtyKrcgE</ds:Modulus>
  <ds:Exponent>AQAB</ds:Exponent>
</ds:RSAKeyValue>
</ds:KeyValue>
</ds:KeyInfo>
</ds:Signature>
<saml:Subject>
  <saml:NameID SPNameQualifier="ambulatorio di pippo"
SPProvidedID="user">ZNRMRA86L11B157N</saml:NameID>
</saml:Subject>
<saml:Conditions NotBefore="2014-01-30T21:42:16Z"
NotOnOrAfter="2014-01-31T01:42:16Z">
  <saml:AudienceRestriction>
    <saml:Audience>http://X-ServiceProvider</saml:Audience>
  </saml:AudienceRestriction>
</saml:Conditions>
  <saml:AuthnStatement AuthnInstant="2014-01-30T21:42:16Z">
    <saml:AuthnContext>

<saml:AuthnContextClassRef>urn:oasis:names:tc:SAML:2.0:ac:classes:InternetProtoco
lPassword</saml:AuthnContextClassRef>

<saml:AuthenticatingAuthority>https://access.bit4id.org:8006</saml:Authenticating
Authority>
  </saml:AuthnContext>
</saml:AuthnStatement>
<saml:AttributeStatement>
  <saml:Attribute Name="UserClientAuthentication">
    <saml:AttributeValue>A.1</saml:AttributeValue>
  </saml:Attribute>
  <saml:Attribute Name="ApplicationID">

<saml:AttributeValue>2.16.840.1.113883.2.9.2.50.4.5.0003</saml:AttributeValue>
  </saml:Attribute>
  <saml:Attribute Name="PatientID">

<saml:AttributeValue>GRLMSM60R31F770Y</saml:AttributeValue>
  </saml:Attribute>
  <saml:Attribute Name="RequestContext">
    <saml:AttributeValue>C.1.1</saml:AttributeValue>
  </saml:Attribute>

```

```
        </saml:Attribute>
        <saml:Attribute Name="Role"
NameFormat="urn:oasis:names:tc:xacml:2.0:subject:role">
            <saml:AttributeValue>R.1.1</saml:AttributeValue>
        </saml:Attribute>
        <saml:Attribute Name="ResponsibleParty">
            <saml:AttributeValue>ZNRMRA86L11B157N</saml:AttributeValue>
        </saml:Attribute>
        <saml:Attribute Name="codStruttura">
            <saml:AttributeValue>123456</saml:AttributeValue>
        </saml:Attribute>
    </saml:AttributeStatement>
</saml:Assertion>
```

4.1.6.3. Expected Actions

In caso di errore l'X-Service User può tentare di creare una nuova Request in funzione degli errori ricevuti.

Se il messaggio di Response ha veicolato correttamente un'Asserzione di identità, questo token verrà utilizzato dal X-Service User per richiedere l'accesso a ulteriori servizi Regionali o extra aziendali in accordo alla transazione [ITI-40] Provide X-User Assertion descritta in sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#).

4.1.7. Security e Audit Considerations

L'evento associato alla richiesta di autenticazione ed asserzione è un evento di rilevanza dal punto di vista della sicurezza del sistema. Per questo motivo l'evento DEVE essere tracciato attraverso messaggi di Audit Record generati dagli attori coinvolti.

Per la struttura e la valorizzazione dei messaggi di Audit relativi all'attore Identity and Assertion Provider e X-Service User si faccia riferimento all'ultima versione delle "Specifiche Tecniche - ATNA - Security Considerations".

4.1.8. Sintesi scambio informativo transazione [RVE-1.a]

In questa sezione viene presentata una rappresentazione tabellare per descrivere dove deve essere veicolato il contenuto informativo in fase di Request e Response, specificando l'opzionalità (R: Required, O: Optional) dei parametri forniti dal richiedente, quali sono ereditati (dalla richiesta) e/o controllati (sulla base delle informazioni possedute dall'attore IAP, vedi sezione [Controlli eseguiti sui parametri della richiesta](#)), quali sono aggiunti dall'attore Identity and Assertion Provider:

Tabella 3. Contenuto informativo transazione [RVE-1.a]

Parametro	Request		Asserzione		Ereditato	Controllato	Aggiunto
	elemento	opt	elemento	opt			
CF_responsabile	Issuer	R	attribute ResponsibleParty	R	SI	SI	NO
CF operatore	Subject/NameID	R	Subject/NameID	R	SI	NO	NO
contesto clinico della richiesta	attribute RequestContext	R	attribute RequestContext	R	SI	NO	NO
Applicazione che effettua la richiesta	attribute ApplicationID	R	attribute ApplicationID	R	SI	SI	NO
Il paziente nei confronti del quale si vuole intervenire	attribute PatientID	O	attribute PatientID	O	SI	NO	NO
Servizio al quale si accederà/potrà accedere usando l'asserzione	AudienceRestriction/Audience	O	AudienceRestriction/Audience	O	SI (attore IAP crea un'asserzione solo per la risorsa specificata in richiesta)	SI (attore IAP verifica accessibilità ad una risorsa)	SI (attore IAP concede accesso solo ad una specifica risorsa)
userID operatore	Subject/NameID/@SPProvidedID	O	N/A	-	NO	NO	NO
ruolo del responsabile	N/A	-	attribute Role	R	NO	NO	SI
modalità di autenticazione sul dispositivo Client	attribute AuthorClientAuthentication	R	attribute AuthorClientAuthentication	R	SI	NO	NO
modalità di autenticazione eseguita	N/A	-	authnContext	R	NO	NO	SI

dall'attore IAP							
credenziali di autenticazione del responsabile	usernameToken	R	N/A	-	NO	SI	NO
codice struttura operatore	N/A	-	attribute codStruttura	O	NO	NO	SI
privilegio di accesso ad una data applicazione	N/A	-	attribute UserGrants	RE	NO	NO	SI

4.2. [RVE-1.b] Authenticate And Get Assertion-b (per applicazioni Trusted)

Questa sezione descrive la transazione RVE-1.b individuando scopo, semantica dei messaggi scambiati e Expected Actions degli attori coinvolti. Questa transazione è utilizzata dall'X-Service User e dall' Identity and Assertions Provider. Questa transazione non descrive come utilizzare l'asserzione generata dall'Identity and Assertions Provider. L'utilizzo dell'asserzione di identità per accedere a servizi regionali o extra-aziendali è descritto all'interno della transazione [ITI-40] Provide X-User Assertion profilata da IHE (si faccia riferimento alla sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#) di questo documento).

4.2.1. Scopo

Questa transazione è utilizzata dall'attore X-Service User aziendale che gode di un trust applicativo con l'attore Identity and Assertion Provider. L'X-Service User trusted richiede al proprio Identity and Assertions Provider di produrre un token SAML 2.0 che asserisca l'identità ed il ruolo dell'utente che si è autenticato sull'applicativo (X-Service User). L'attore X-Service User esegue la richiesta di asserzione veicolando: username (del Directory Server o locale, in funzione dei dati gestiti a livello aziendale), UserClientAuthentication, RequestContext e ApplicationID (vedere la transazione [RVE-1.a] per la descrizione di tali attributi). L'asserzione prodotta sarà strutturata in accordo a quanto definito nella transazione [RVE-1.a], messaggio AuthenticateAndGetAssertion Response.

4.2.2. Attori e ruoli

Actor: X-Service User

Role: Richiede la creazione di un'asserzione di identità utilizzando username e ApplicationID.

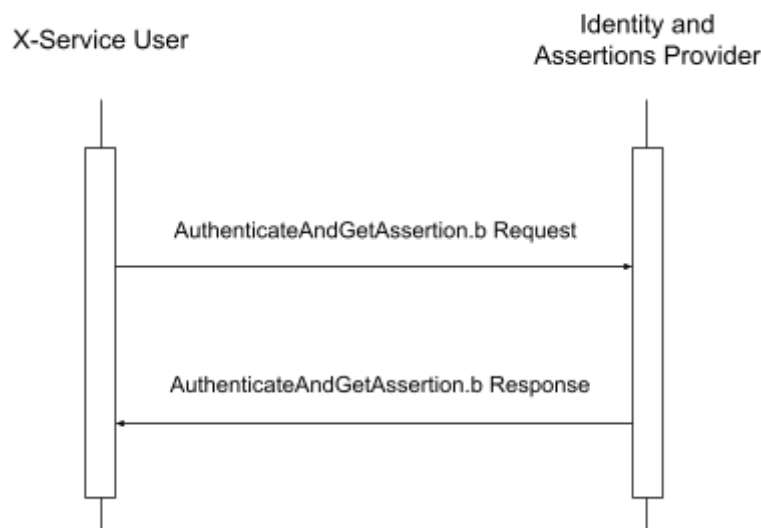
Actor: Identity and Assertion Provider

Role: Verifica l'identità dell'utente dell'attore X-Service User (verificando l'esistenza dell'operatore all'interno del Directory Server aziendale) e sulla base di logiche interne crea un'asserzione valida o genera una risposta di errore.

4.2.3. Standard di riferimento

- W3C WS-Addressing 1.0 – SOAP Binding
- OASIS WS-Security
- OASIS SAML family spec.
- IHE ITI TF-2x: Appendix V
- IHE ITI TF-2b

4.2.4. Interaction Diagram



4.2.5. AuthenticateAndGetAssertion.b Request

Lo stesso Server (Identity And Assertion Provider) può essere invocato da tutti i client afferenti al suo dominio di autenticazione (tutti gli invocator di servizi X-Service User). Solo attori caratterizzati da un'identità digitale nota all'attore IAP possono utilizzare questa transazione.

4.2.5.1. Trigger Events

Il trigger events che determina la richiesta di una nuova asserzione d'identità è l'impossibilità di accedere ad un servizio esposto da un attore X-Service Provider (servizio regionale o extra-aziendale) a causa dell'utilizzo di un'asserzione non valida o senza un'asserzione di identità valida. L'attore X-Service User deve generare un messaggio AuthenticateAndGetAssertion-b Request ogni volta che un parametro contenuto nell'asserzione di identità in carico viene modificato (modifica del Contesto, modifica dell'operatore ecc.).

4.2.5.2. Message Semantics

Il messaggio creato dovrà essere un messaggio SOAP v1.2 e quindi rispettare lo schema definito da <http://www.w3.org/2003/05/soap-envelope>.

L'Header del messaggio SOAP conterrà le informazioni necessarie per il routing del messaggio e per l'identificazione dell'operatore (username).

Il Body conterrà la porzione di messaggio necessaria per effettuare la richiesta di asserzione (veicolando una serie di attributi che asseriscono l'identità e il contesto di operatività dell'utente).

La struttura dell'Header DEVE essere conforme alle specifiche WS-Addressing 1.0 SOAP Binding redatte dal W3C (<http://www.w3.org/2005/08/addressing> nelle specifiche il namespace di riferimento sarà **wsa**). Queste specifiche permettono di individuare all'interno del messaggio scambiato il destinatario del messaggio stesso. Ogni messaggio NON DEVE contenere più di un elemento delle tipologie seguenti:

- **<wsa:To>** = indirizzo URI del destinatario ultimo del messaggio
- **<wsa:Action>** = URI che identifica la semantica attesa nel body ("urn:rve:AuthenticateAndGetAssertionRequest-b" identifica che il messaggio veicola una richiesta di autenticazione e una richiesta di asserzione asserzione)
- **<wsa:MessageID>** = identificativo univoco del messaggio

L'Header del messaggio SOAP deve anche contenere un elemento che permette di identificare l'operatore. Questa porzione è strutturata mediante l'utilizzo dello standard WS-Security: SOAP Message Security Version 1.1.1 (namespace di riferimento **wsse**). L'elemento <UserNameToken>, contenuto all'interno di un elemento <Security> DEVE contenere solamente l'elemento **<wsse:Username>**, che permette di veicolare l'identificativo del responsabile conosciuto dall'Identity and Assertions Provider. **E' fortemente consigliato che questo username sia lo stesso gestito nel Directory Server aziendale. Se ciò non è possibile, deve essere gestita a livello di attore IAP una tabella di transcodifica che permette di individuare lo username del Directory Server sulla base della chiave usernameLocale + ApplicationID.**

Il body del messaggio SOAP deve essere strutturato in accordo con il protocollo SAML definito nelle specifiche "Assertions and Protocols for the OASIS SAML V2.0" e fa riferimento al namespace: **samlp**="urn:oasis:names:tc:SAML:2.0:protocol".

La richiesta di asserzione è costituita da un elemento **<samlp:AuthnRequest>** che possiede i seguenti attributi obbligatori:

- **ID:** è l'identificativo univoco della richiesta. Tipo di dato "ID" e corrisponde all'identificativo univoco contenuto nell'elemento del Header SOAP **<wsa:MessageID>** privato dei caratteri "urn:uuid:" (il dataType ID non permette l'utilizzo del carattere ".") e con l'aggiunta della stringa "msgId_".

es:

header/MessageID=urn:uuid:9376254e-da05-41f5-9af3-ac56d63d8ebd

body/ AuthnRequest/@ID=msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd

- **Version:** deve essere valorizzato con "2.0".
- **IssueInstant:** istante in cui è creata la richiesta in formato UTC

All'interno dell'elemento **<samlp:AuthnRequest>** sono contenuti una serie di sotto-elementi che permettono di identificare l'attore che sta effettuando la richiesta, il soggetto per il quale DEVE essere creata l'asserzione ed il motivo.

I sotto elementi contenuti (riferimento al namespace **saml="urn:oasis:names:tc:SAML:2.0:assertion"**) sono:

- **<samlp:Extensions>**: è l'elemento che permette di veicolare verso l'attore Identity and Assertions Provider informazioni aggiuntive utili per creare l'asserzione stessa. L'elemento Extensions contiene un set di attributi, forniti dal sistema client, che poi comporranno l'asserzione. PUO' quindi contenere solamente un elemento **<AttributeStatement>**.
 - **<AttributeStatement>**: questo elemento contiene molteplici elementi
 - **<Attribute>**: è l'elemento che descrive l'attributo della richiesta di asserzione. Sono attesi almeno tre elementi Attribute all'interno di un messaggio AuthenticateAndGetAssertion Request:
 - **UserClientAuthentication:** descrive la tipologia di autenticazione eseguita dall'utente per accedere ai servizi del sistema X-Service User. Il codice da utilizzare deve essere A.1.1.
 - **RequestContext:** descrive il contesto all'interno del quale si è resa necessaria la richiesta di servizio. Questo attributo può essere valorizzato con i codici definiti in [Appendice A: CodeSystems](#).
 - **ApplicationID:** definisce l'ID dell'applicativo che esegue la richiesta di asserzione. Il formato dell'ID è: [ApplicationID]^[minor_release]^[installazione] dove "ApplicationID" è l'ID associato al prodotto software che ha superato la fase di labeling, "minor_release" rappresenta la versione successiva del software non labellata, "installazione" rappresenta un identificativo univoco per la specifica installazione del software labellato.
 - **PatientID:** rappresenta l'identificativo univoco del paziente nei confronti del quale l'utente sta agendo con il contesto dichiarato. L'opzionalità di questo attributo è dipendente dalla tipologia di servizio al quale si vuole accedere.

- **codOTP:** veicola il codice OTP restituito dal servizio AMPS. L'opzionalità di questo attributo è dipendente dalla tipologia di servizio al quale si vuole accedere.

All'interno delle progettualità regionali possono essere previsti ulteriori parametri in fase di richiesta. Per la definizione di questi ultimi fare riferimento a quanto previsto per la transazione [RVE-1.d] Authenticate And Get Assertion-d al paragrafo ["Message Semantics"](#)

- **<saml:Conditions>:** è l'elemento che permette di veicolare le condizioni SAML che l'X-Service User si aspetta di ottenere all'interno dell'asserzione per limitarne la validità e l'utilizzo. **L'attore Identity and Assertions Provider può modificare queste condizioni se necessario.** L'elemento <saml:Conditions> può contenere i seguenti attributi:
 - **NotBefore:** specifica il primo istante di tempo per cui l'asserzione è valida in formato UTC
 - **NotOnOrAfter:** specifica l'istante di tempo in cui l'asserzione scade in formato UTC

All'interno dell'elemento <saml:Conditions> è possibile aggiungere un elemento <AudienceRestriction>:

- **<AudienceRestriction>:** è un elemento opzionale che permette di specificare il Servizio regionale o extra-aziendale a cui si cercherà di accedere utilizzando l'asserzione richiesta. Per ogni destinatario individuato viene aggiunto un elemento:
 - **<Audience>:** che contiene l'URL del servizio a cui si cercherà di accedere utilizzando l'asserzione prodotta (questo servizio deve essere individuato specificando l'url completo e corrisponde all'attore X-Service Provider, vedi sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#)). Per ulteriori dettagli relativi all'utilizzo di questo elemento fare riferimento alla sezione [Audience Restriction use-case](#).

Di seguito è presentato un esempio di messaggio SOAP AuthenticateAndGetAssertion-b Request:

```
<?xml version="1.0" encoding="UTF-8"?>
<soap:Envelope      xsi:schemaLocation="http://www.w3.org/2003/05/soap-envelope
soap-envelope.xsd"      xmlns:soap="http://www.w3.org/2003/05/soap-envelope"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <soap:Header      xsi:schemaLocation="http://www.w3.org/2005/08/addressing
ws-addr.xsd"      xmlns:wsa="http://www.w3.org/2005/08/addressing">
    <wsa:Action>urn:rve:AuthenticateAndGetAssertionRequest-b</wsa:Action>

<wsa:MessageID>urn:uuid:9376254e-da05-41f5-9af3-ac56d63d8ebd</wsa:MessageID>
    <wsa:To>https://iap.ulssx.veneto.it/ws</wsa:To>
    <wsse:Security
xsi:schemaLocation="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssec
urity-secext-1.0.xsd      oasis-200401-wss-wssecurity-secext-1.0.xsd"
xmlns:wsse="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-se
cext-1.0.xsd">
```

```

        <wsse:UsernameToken
xmlns:utp="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-uti
lity-1.0.xsd">
        <wsse:Username>pippo</wsse:Username>
        </wsse:UsernameToken>
    </wsse:Security>
</soap:Header>
    <soap:Body      xsi:schemaLocation="urn:oasis:names:tc:SAML:2.0:protocol
saml-schema-protocol-2.0.xsd" xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol">
        <samlp:AuthnRequest ID="msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd"
Version="2.0" IssueInstant="2014-01-20T13:51:13Z">
            <samlp:Extensions>
                <AttributeStatement xmlns="urn:oasis:names:tc:SAML:2.0:assertion">
                    <Attribute Name="UserClientAuthentication">
                        <AttributeValue>A.1.1</AttributeValue>
                    </Attribute>
                    <Attribute Name="ApplicationID">
                        <AttributeValue>2.16.840.1.113883.2.9.2.50.4.5.0999</AttributeValue>
                    </Attribute>
                    <Attribute Name="PatientID">
                        <AttributeValue>ZNRMRA86L11B157N</AttributeValue>
                    </Attribute>
                    <Attribute Name="RequestContext">
                        <AttributeValue>C.1.6</AttributeValue>
                    </Attribute>
                </AttributeStatement>
            </samlp:Extensions>
            <Conditions      NotBefore="2013-10-15T16:09:30Z"
NotOnOrAfter="2013-10-15T17:32:30Z"
xmlns="urn:oasis:names:tc:SAML:2.0:assertion">
                <AudienceRestriction>
                    <Audience>https://sar.regione.veneto.it/demVisualizzaErogatoCUP</Audience>
                    <!-- asserzione richiesta per accedere al servizio di invio
ricette -->
                </AudienceRestriction>
            </Conditions>
        </samlp:AuthnRequest>
    </soap:Body>
</soap:Envelope>

```

4.2.5.3. Expected Actions

Alla ricezione del messaggio AuthenticateAndGetAssertion-b Request, l'attore Identity and Assertion Provider deve:

- Opzionalmente individuare lo username gestito nel Directory Server aziendale, transcodificando lo username locale associato all'ApplicationID;

- Recuperare dal Directory Server (o da DB) i dati relativi a Codice Fiscale e Ruolo

In caso di errore nel processo di recupero di tali informazioni (e.g. username non presente nel Directory Server), l'attore Identity and Assertions Provider deve generare un messaggio di Response che veicola l'errore in accordo con le specifiche definite all'interno dello standard WS-Security section 12 "Error Handling" (la struttura di un messaggio di Response generato a seguito del fallimento del processo di autenticazione è definito in sezione [Scopo](#)):

- **<wsse:FailedAuthentication>**: Se il security Token non può essere autenticato o autorizzato. (Le specifiche tipologie di errore associate a questa classe di errore sono definite in [appendice A](#), sezione [wsse:FailedAuthentication](#)).

Se l'attore Identity and Assertions Provider è in grado di processare in modo corretto il body SOAP del messaggio AuthenticateAndGetAssertion-b Request, DEVE creare un messaggio di risposta AuthenticateAndGetAssertion Response contenente un'asserzione di identità individuando nell'elemento <Subject> il Codice fiscale individuato. Se l'attore Identity and Assertions Provider ritiene una richiesta NON valida secondo la sintassi SAML, DEVE creare un messaggio di Response con al suo interno un elemento **<StatusCode>** che descrive la condizione di errore. Di seguito sono presentate le varie condizioni di errore che devono essere utilizzate all'interno dell'attributo **value**:

- *urn:oasis:names:tc:SAML:2.0:status:Requester*: la richiesta non è stata completata in quanto si è individuato un errore dal lato del client
- *urn:oasis:names:tc:SAML:2.0:status:Responder*: la richiesta non è stata completata in quanto si è individuato un errore dal lato del server
- *urn:oasis:names:tc:SAML:2.0:status:InvalidAttrNameOrValue*: contenuto non atteso o non valido è individuato negli attributi della richiesta
- *urn:oasis:names:tc:SAML:2.0:status:RequestDenied*: il server è riuscito a processare la richiesta ma ha scelto di non rispondere con un successo.
- *urn:oasis:names:tc:SAML:2.0:status:RequestUnsupported*: il server non supporta la richiesta

L'elemento <statusCode> può contenere altri sottoelementi che permettono di dettagliare la condizione di errore:

- **<StatusMessage>**: permette di veicolare all'operatore una stringa contenente maggiori informazioni sulla condizione di errore verificatosi.

4.2.5.3.1. Controlli eseguiti sui parametri della richiesta

In questa sezione verranno descritti i controlli mandatori e quelli opzionali che l'attore Identity and Assertion Provider deve eseguire sui parametri della richiesta. La gestione e il mantenimento dei flussi informativi necessari per effettuare la verifica è in carico all'azienda sanitaria di riferimento, la quale dovrà predisporre degli specifici connettori verso l'attore Identity and Assertion Provider.

Le principali verifiche mandatorie che l'attore deve garantire sono:

- Verificare che l'identità digitale dell'X-Service User appartenga ad una lista configurabile e modificabile.

- Verificare che il contesto dichiarato dall'applicativo sia tra i contesti che l'azienda ha abilitato per quel determinato ApplicationID:

contesto dichiarato $\in$ (contesti + ApplicationID)

- Verificare che la tipologia di autenticazione eseguita sul Client sia tra le tipologie di autenticazione ammesse (il valore aggiunto di questo attributo si vedrà nel momento in cui avremo medici autenticati con modalità diverse User/pw, smartCard ecc.):

UserClientAuthentication $\in$ UserClientAuthentication ammessi

Le verifiche opzionali che deve effettuare l'attore Identity and Assertion Provider sono presentate di seguito. L'opzionalità può essere legata a policy aziendali o a specificità legate al servizio a cui l'attore X-Service User cercherà di accedere utilizzando l'asserzione di identità. In questo caso DOVREBBE essere veicolato all'interno dei parametri della richiesta l'elemento AudienceRestriction specificante l'url del X-Service Provider (vedere sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#) per i dettagli):

- Verificare che l'ApplicationID non sia tra le installazioni o tra le minor release "bannate" dall'azienda:

ApplicationID $\notin$ applicativi Bannati Aziendali

- Verificare che lo specifico paziente (PatientID) sia nella relazione dichiarata (contesto) con l'utente che esegue la richiesta (es. per la consultazione di un documento da parte di uno specialista, può essere verificato che il paziente X sia veramente ricoverato nel reparto in cui opera lo specialista):

PatientID $\in$ (contesto + PatientID)

4.2.6. **AuthenticateAndGetAssertion.b Response**

Questo messaggio veicola verso l'attore X-Service User l'asserzione di identità necessaria per invocare successivi servizi regionali o extra-aziendali si faccia riferimento alla sezione [AuthenticateAndGetAssertion Response](#) per la struttura di questo messaggio.

4.2.7. **Security e Audit Considerations**

L'evento associato alla richiesta di autenticazione ed asserzione è un evento di rilevanza dal punto di vista della sicurezza del sistema. Per questo motivo l'evento DEVE essere tracciato attraverso messaggi di Audit Record generati dagli attori coinvolti.

Per la struttura e la valorizzazione dei messaggi di Audit relativi all'attore Identity and Assertion Provider e X-Service User si faccia riferimento all'ultima versione delle "Specifiche Tecniche - ATNA - Security Considerations".

4.3. [RVE-1.c] Autenticazione Web

Questa sezione descrive la transazione [RVE-1.c] Autenticazione Web utilizzata per l'autenticazione prevista per le applicazioni Web coinvolte nell'infrastruttura FESr e nel dossier FSSEZero, individuando scopo, semantica dei messaggi scambiati e Expected Actions degli attori coinvolti. Questa transazione viene utilizzata quando l'utente necessita di autenticarsi utilizzando uno dei servizi Web di autenticazione, compliant con le specifiche SPID, offerti dai sistemi di Identity and Assertion Provider.

4.3.1. Scopo

Questa transazione è utilizzata dall'attore Service Provider verso l'attore Identity Provider. Il Service Provider, dopo aver richiesto all'utente di selezionare il proprio Identity Provider di riferimento, esegue una richiesta di autenticazione SAML SSO web verso i Servizi Web del sistema Identity Provider scelto. Una volta eseguita l'autenticazione dell'utente, l'Identity Provider genera un'asserzione di identità SAML, che dovrà essere intercettata dal Service Provider per generare la sessione.

4.3.2. Attori e ruoli

Actor: Service Provider

Role: Costruisce ed inoltra all'Identity Provider una richiesta di autenticazione per l'utente che necessita di accedere ad un determinato servizio

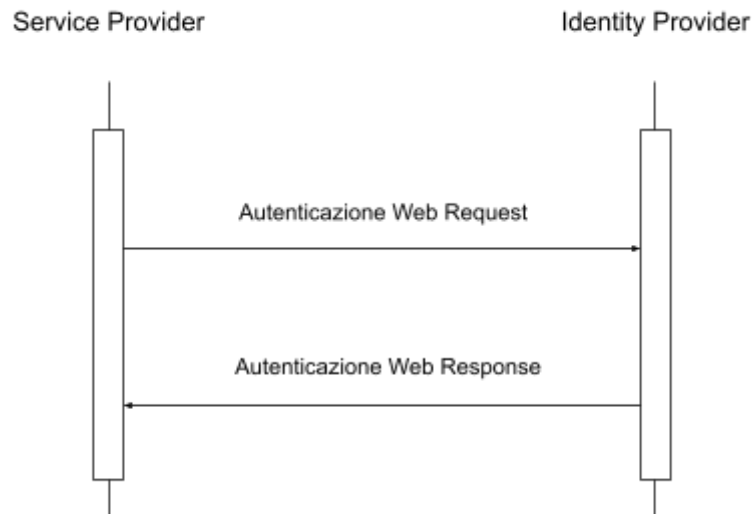
Actor: Identity Provider

Role: Autentica l'utente e prepara l'asserzione necessaria a quest'ultimo per accedere al servizio fornito da Service Provider

4.3.3. Standard di riferimento

- W3C WS-Addressing 1.0 – SOAP Binding
- OASIS WS-Security
- OASIS SAML family spec.

4.3.4. Interaction Diagram



4.3.5. Autenticazione Web Request

4.3.5.1. Trigger Events

Il messaggio di Autenticazione Web Request viene inviato dal Service Provider all'Identity Provider scelto dall'utente, in seguito alla necessità da parte di un utente di autenticarsi all'interno di un applicativo Web regionale.

4.3.5.2. Message Semantics

Per la strutturazione del messaggio Autenticazione Web Request si faccia riferimento all'ultima versione disponibile delle regole tecniche SPID disponibili al link <https://docs.italia.it/italia/spid/spid-regole-tecniche/it/stabile/index.html>, nello specifico al paragrafo "Single Sign-On".

4.3.5.3. Expected Actions

Alla ricezione del messaggio Autenticazione Web Request, l'attore Identity Provider deve:

- Opzionalmente individuare lo username gestito nel Directory Server aziendale, transcodificando lo username locale associato all'ApplicationID;
- Recuperare dal Directory Server (o da DB) i dati relativi all'utente

In caso di errore nel processo di recupero di tali informazioni (e.g. username non presente nel Directory Server), l'attore Identity Provider deve generare un messaggio di Response che veicola l'errore in accordo con quanto previsto dall'ultima versione disponibile delle regole tecniche SPID disponibili al link <https://docs.italia.it/italia/spid/spid-regole-tecniche/it/stabile/index.html>.

4.3.6. Autenticazione Web Response

Questo messaggio veicola verso l'attore Service Provider l'asserzione di identità necessaria per autenticare l'utente

4.3.6.1. Trigger Events

Il messaggio Autenticazione Web Response contenente l'asserzione viene generato in risposta ad una richiesta di rilascio di un'asserzione da parte di un utente che necessita di accedere ad un applicativo Web.

4.3.6.2. Message Semantics

Per la strutturazione del messaggio Autenticazione Web Response si faccia riferimento all'ultima versione disponibile delle regole tecniche SPID disponibili al link <https://docs.italia.it/italia/spid/spid-regole-tecniche/it/stabile/index.html>, nello specifico al paragrafo "Single Sign-On".

L'attributo *SPProvidedID* contenuto nell'elemento `<saml:Assertion>/<saml:Subject>/<saml:NameID>` DEVE essere presente e DEVE riportare l'informazione sull'utente che si è autenticato.

Il valore di questo elemento deve essere l'identificativo univoco dell'utente a cui sono associate le credenziali (username) dell'operatore stesso.

4.3.7. Security e Audit Considerations

L'evento associato alla richiesta di autenticazione ed asserzione è un evento di rilevanza dal punto di vista della sicurezza del sistema. Per questo motivo l'evento DEVE essere tracciato attraverso messaggi di Audit Record generati dagli attori coinvolti.

Per la struttura e la valorizzazione dei messaggi di Audit relativi all'attore Service Provider e Identity Provider si faccia riferimento all'ultima versione delle "Specifiche Tecniche - ATNA - Security Considerations".

4.3.8. [RVE-1.d] Authenticate And Get Assertion-d

Questa sezione descrive la transazione RVE-1.d Authenticate And Get Assertion-d individuando scopo, semantica dei messaggi scambiati e Expected Actions degli attori coinvolti. Questa transazione è utilizzata dall'X-Service User trusted e dall'Attribute Assertions Provider. Questa transazione non descrive come utilizzare l'asserzione generata dall'Attribute and Assertions Provider. L'utilizzo dell'asserzione di identità per accedere a servizi regionali o extra-aziendali è descritto all'interno della transazione [ITI-40] Provide

X-User Assertion profilata da IHE (si faccia riferimento alla sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#) di questo documento).

4.3.9. Scopo

Questa transazione è utilizzata dall'attore X-Service User aziendale che gode di un trust applicativo con l'attore Attribute Assertion Provider. L'X-Service User trusted richiede al proprio Attribute and Assertions Provider di produrre un token SAML 2.0 che asserisca l'identità ed il ruolo dell'utente che si è autenticato sull'applicativo (X-Service User). L'attore X-Service User esegue la richiesta di asserzione veicolando: username (il CF dell'operatore), UserClientAuthentication, RequestContext e ApplicationID (vedere la transazione [RVE-1.a] per la descrizione di tali attributi).

L'asserzione prodotta sarà strutturata in accordo a quanto definito nella transazione [RVE-1.a], messaggio [AuthenticateAndGetAssertion Response](#).

4.3.10. Attori e ruoli

Actor: X-Service User

Role: Richiede la creazione di un'asserzione di attributo utilizzando username e ApplicationID.

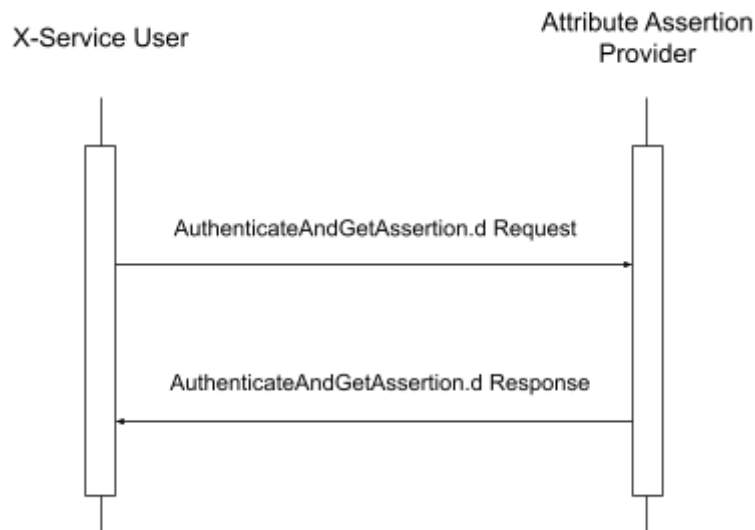
Actor: Attribute Assertion Provider

Role: Verifica l'identità dell'utente dell'attore X-Service User (verificando l'esistenza dell'operatore all'interno del Directory Server aziendale) e sulla base di logiche interne crea un'asserzione d'attributo valida o genera una risposta di errore.

4.3.11. Standard di riferimento

- W3C WS-Addressing 1.0 – SOAP Binding
- OASIS WS-Security
- OASIS SAML family spec.
- IHE ITI TF-2x: Appendix V
- IHE ITI TF-2b

4.3.12. Interaction Diagram



4.3.13. AuthenticateAndGetAssertion.d Request

Lo stesso Server (Attribute Assertion Provider) può essere invocato da tutti i client afferenti al suo dominio di autenticazione (tutti gli invocatori di servizi X-Service User). Solo attori caratterizzati da un'identità digitale nota all'attore AAP possono utilizzare questa transazione.

4.3.13.1. Trigger Events

Il trigger events che determina la richiesta di una nuova asserzione d'attributo è l'impossibilità di accedere ad un servizio esposto da un attore X-Service Provider (servizio regionale o extra-aziendale) a causa dell'utilizzo di un'asserzione non valida o senza un'asserzione di attributo valida. L'attore X-Service User deve generare un messaggio AuthenticateAndGetAssertion-d Request ogni volta che un parametro contenuto nell'asserzione di attributo in carico viene modificato (modifica del Contesto, modifica dell'operatore ecc.).

4.3.13.2. Message Semantics

Il messaggio creato dovrà essere un messaggio SOAP v1.2 e quindi rispettare lo schema definito da <http://www.w3.org/2003/05/soap-envelope>.

L'Header del messaggio SOAP conterrà le informazioni necessarie per il routing del messaggio e per l'identificazione dell'operatore (username).

Il Body conterrà la porzione di messaggio necessaria per effettuare la richiesta di asserzione (veicolando una serie di attributi che asseriscono l'identità e il contesto di operatività dell'utente).

La struttura dell'Header DEVE essere conforme alle specifiche WS-Addressing 1.0 SOAP Binding redatte dal W3C (<http://www.w3.org/2005/08/addressing> nelle specifiche il namespace di riferimento sarà **wsa**). Queste specifiche permettono di individuare all'interno del messaggio scambiato il destinatario del messaggio stesso. Ogni messaggio NON DEVE contenere più di un elemento delle tipologie seguenti:

- **<wsa:To>** = indirizzo URI del destinatario ultimo del messaggio
- **<wsa:Action>** = URI che identifica la semantica attesa nel body ("urn:rve:AuthenticateAndGetAssertionRequest-d" identifica che il messaggio veicola una richiesta di autenticazione e una richiesta di asserzione asserzione)
- **<wsa:MessageID>** = identificativo univoco del messaggio

L'Header del messaggio SOAP deve anche contenere un elemento che permette di identificare l'operatore. Questa porzione è strutturata mediante l'utilizzo dello standard WS-Security: SOAP Message Security Version 1.1.1 (namespace di riferimento **wsse**). L'elemento **<UserNameToken>**, contenuto all'interno di un elemento **<Security>** DEVE contenere solamente l'elemento **<wsse:Username>**, che permette di veicolare il Codice Fiscale dell'operatore conosciuto dall'Attribute Assertions Provider.

Il body del messaggio SOAP deve essere strutturato in accordo con il protocollo SAML definito nelle specifiche "Assertions and Protocols for the OASIS SAML V2.0" e fa riferimento al namespace: **samlp**="urn:oasis:names:tc:SAML:2.0:protocol".

La richiesta di asserzione è costituita da un elemento **<samlp:AuthnRequest>** che possiede i seguenti attributi obbligatori:

- **ID**: è l'identificativo univoco della richiesta. Tipo di dato "ID" e corrisponde all'identificativo univoco contenuto nell'elemento del Header SOAP **<wsa:MessageID>** privato dei caratteri "urn:uuid:" (il dataType ID non permette l'utilizzo del carattere ":") e con l'aggiunta della stringa "msgId_".

es:

header/MessageID=urn:uuid:9376254e-da05-41f5-9af3-ac56d63d8ebd

body/ AuthnRequest/@ID=msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd

- **Version**: deve essere valorizzato con "2.0".
- **IssueInstant**: istante in cui è creata la richiesta in formato UTC

All'interno dell'elemento **<samlp:AuthnRequest>** sono contenuti una serie di sotto-elementi che permettono di identificare l'attore che sta effettuando la richiesta, il soggetto per il quale DEVE essere creata l'asserzione ed il motivo.

I sotto elementi contenuti (riferimento al namespace **saml**="urn:oasis:names:tc:SAML:2.0:assertion") sono:

- **<samlp:Extensions>**: è l'elemento che permette di veicolare verso l'attore Attribute Assertions Provider informazioni aggiuntive utili per creare l'asserzione stessa. L'elemento Extensions contiene un set di attributi, forniti dal sistema client, che poi comporranno l'asserzione. PUO' quindi contenere solamente un elemento **<AttributeStatment>**.

- **<AttributeStatment>**: questo elemento contiene molteplici elementi
- **<Attribute>**: è l'elemento che descrive l'attributo della richiesta di asserzione. Sono attesi almeno tre elementi Attribute all'interno di un messaggio AuthenticateAndGetAssertion Request:
 - **UserClientAuthentication**: descrive la tipologia di autenticazione eseguita dall'utente per accedere ai servizi del sistema X-Service User. Il codice da utilizzare deve essere B.1.
 - **RequestContext**: descrive il contesto all'interno del quale si è resa necessaria la richiesta di servizio. Questo attributo può essere valorizzato con i codici definiti in [Appendice A: CodeSystems](#).
 - **ApplicationID**: definisce l'ID dell'applicativo che esegue la richiesta di asserzione. Il formato dell'ID è: [ApplicationID]^[minor_release]^ [installazione] dove "ApplicationID" è l'ID associato al prodotto software che ha superato la fase di labeling, "minor_release" rappresenta la versione successiva del software non labellata, "installazione" rappresenta un identificativo univoco per la specifica installazione del software labellato.
 - **PatientID**: rappresenta l'identificativo univoco del paziente nei confronti del quale l'utente sta agendo con il contesto dichiarato. L'opzionalità di questo attributo è dipendente dalla tipologia di servizio al quale si vuole accedere.
 - **MotivazioneAccesso**: veicola la motivazione della richiesta di accesso ai documenti nel caso di forzatura della presa in carico. Questo attributo può essere valorizzato con i codici definiti in [Appendice A: CodeSystems](#)
 - **codStruttura**: attributo OPZIONALE che veicola il codice relativo alla struttura di afferenza dell'utente che richiede l'autenticazione. Tale codice deve essere assegnato a partire dal sistema di codifica STS11 o altro sistema di codifica definito a livello regionale.
 - **codUdO**: attributo OPZIONALE che veicola l'Unità di Offerta di afferenza dell'utente che richiede l'autenticazione.

codUO: attributo OPZIONALE che veicola l'Unità Operativa di afferenza dell'utente che richiede l'autenticazione.

- **<saml:Conditions>**: è l'elemento che permette di veicolare le condizioni SAML che l'X-Service User si aspetta di ottenere all'interno dell'asserzione per limitarne la validità e l'utilizzo. **L'attore Attribute Assertions Provider può modificare queste condizioni se necessario.** L'elemento <saml:Conditions> può contenere i seguenti attributi:
 - **NotBefore**: specifica il primo istante di tempo per cui l'asserzione è valida in formato UTC
 - **NotOnOrAfter**: specifica l'istante di tempo in cui l'asserzione scade in formato UTC

All'interno dell'elemento <saml:Conditions> è possibile aggiungere un elemento <AudienceRestriction>:

- **<AudienceRestriction>**: è un elemento opzionale che permette di specificare il Servizio regionale o extra-aziendale a cui si cercherà di accedere utilizzando l'asserzione richiesta. Per ogni destinatario individuato viene aggiunto un elemento:

- <Audience>: che contiene l'URL del servizio a cui si cercherà di accedere utilizzando l'asserzione prodotta (questo servizio deve essere individuato specificando l'url completo e corrisponde all'attore X-Service Provider, vedi sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#)). Per ulteriori dettagli relativi all'utilizzo di questo elemento fare riferimento alla sezione [Audience Restriction use-case](#).

4.3.13.3. Expected Actions

L'attore Attribute Assertion Provider deve:

- Individuare e recuperare le informazioni di attributo relative all'utente mediante il CF presente nella richiesta
- Verificare se il certificato client dell'applicativo invocante è censito all'interno della WL aziendale
- Verificare se l'ApplicationID del chiamante è censito all'interno della WL aziendale

In caso di errore nel processo di recupero o di verifica di tali informazioni, l'attore Attribute Assertions Provider deve generare un messaggio di Response che veicola l'errore in accordo con le specifiche definite all'interno dello standard WS-Security section 12 "Error Handling" (la struttura di un messaggio di Response generato a seguito del fallimento del processo di autenticazione è definito in sezione [Scopo](#)):

- **<wsse:FailedAuthentication>**: Se il security Token non può essere autenticato o autorizzato. (Le specifiche tipologie di errore associate a questa classe di errore sono definite in [appendice A](#), sezione [wsse:FailedAuthentication](#)).

Se l'attore Attribute Assertions Provider è in grado di processare in modo corretto il body SOAP del messaggio AuthenticateAndGetAssertion-d Request, DEVE creare un messaggio di risposta AuthenticateAndGetAssertion-d Response contenente un'asserzione di attributo individuando nell'elemento <Subject> il Codice fiscale individuato.

Se l'attore Attribute Assertions Provider ritiene una richiesta NON valida secondo la sintassi SAML, DEVE creare un messaggio di Response con al suo interno un elemento **<StatusCode>** che descrive la condizione di errore. Di seguito sono presentate le varie condizioni di errore che devono essere utilizzate all'interno dell'attributo **value**:

- *urn:oasis:names:tc:SAML:2.0:status:Requester*: la richiesta non è stata completata in quanto si è individuato un errore dal lato del client
- *urn:oasis:names:tc:SAML:2.0:status:Responder*: la richiesta non è stata completata in quanto si è individuato un errore dal lato del server
- *urn:oasis:names:tc:SAML:2.0:status:InvalidAttrNameOrValue*: contenuto non atteso o non valido è individuato negli attributi della richiesta
- *urn:oasis:names:tc:SAML:2.0:status:RequestDenied*: il server è riuscito a processare la richiesta ma ha scelto di non rispondere con un successo.
- *urn:oasis:names:tc:SAML:2.0:status:RequestUnsupported*: il server non supporta la richiesta

Nel caso in cui nel messaggio di richiesta vengano specificati anche gli attributi *codStruttura*, *codUdO* e *codUO* veicolanti rispettivamente la struttura, l'Unità di Offerta e l'Unità Operativa

di afferenza dell'utente, l'attore Attribute Assertion Provider verificherà la configurazione di quest'ultimo e, se presenti le codifiche passate in request, genererà l'asserzione riportando esclusivamente i valori di contesto.

Se tali codifiche non rispettano la configurazione dell'utente l'Attribute Assertion Provider deve ritornare un opportuno errore di FailedAuthentication.

4.3.14. AuthenticateAndGetAssertion.d Response

Questo messaggio veicola verso l'attore X-Service User trusted l'asserzione di attributo necessaria per invocare successivi servizi regionali o extra-aziendali.

4.3.14.1. Trigger Events

Il messaggio di Response contenente l'asserzione di attributo viene generato in risposta ad un messaggio di Request.

4.3.14.2. Message Semantics

4.3.14.2.1. SOAP Header e Body

Il messaggio di response è un messaggio SOAP che descrive una **<soap:Action>** del tipo *urn:rve:AuthenticateAndGetAssertion-dResponse*. E' necessario tracciare nell'Header del messaggio SOAP l'identificativo del messaggio di Request che ha determinato la generazione della Response attraverso l'elemento **<wsa:RelatesTo>**.

Il SOAP Body contiene un elemento **<samlp:Response>** che DEVE contenere al suo interno:

- **<samlp:Status>** elemento obbligatorio che contiene a sua volta una serie di elementi:
 - **<samlp:StatusCode>**: Elemento obbligatorio che permette di veicolare un codice che descrive lo stato di attività della risposta alla richiesta corrispondente. Questo elemento DEVE contenere un attributo:
 - **Value**: valorizzato con "urn:oasis:names:tc:SAML:2.0:status:Success" in caso di successo, o con una condizione di errore descritta in "Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0", sezione 60.
 - **<samlp:StatusMessage>**: elemento opzionale che permette di veicolare un messaggio all'utente che richiede un'asserzione.
- **<saml:Assertion>**: se la richiesta è stata processata in modo corretto (Status di successo), l'elemento Response deve contenere un elemento assertion che permette di strutturare l'asserzione in accordo con lo schema "urn:oasis:names:tc:SAML:2.0:assertion".

Di seguito viene presentato un esempio di messaggio SOAP per il messaggio AuthenticateAndGetAssertion-d Response (il contenuto dell'asserzione di attributo è descritto nella sezione seguente).

```

<soap:Envelope xmlns:soap="http://www.w3.org/2003/05/soap-envelope"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <soap:Header>
    <wsa:Action
xmlns:wsa="http://www.w3.org/2005/08/addressing">urn:rve:AuthenticateAndGetAssert
ion-dResponse</wsa:Action>
    <wsa:MessageID
xmlns:wsa="http://www.w3.org/2005/08/addressing">urn:uuid:6364ad23-89f7-11e3-a222
-0010f32f794e</wsa:MessageID>
    <wsa:To
xmlns:wsa="http://www.w3.org/2005/08/addressing">http://X-ServiceUser</wsa:To>
    <wsa:RelatesTo
xmlns:wsa="http://www.w3.org/2005/08/addressing">urn:uuid:9376254e-da05-41f5-9af3
-ac56d63d8ebd</wsa:RelatesTo>
  </soap:Header>
  <soap:Body>
    <samlp:Response Version="2.0" ID="63651e2689f711e3a03b0010f32f794e"
InResponseTo="msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd"
IssueInstant="2014-01-30T21:42:16Z"
xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol"
xmlns:tns="http://www.bit4id.com/xmlns/ipam/">
      <samlp:Status>
        <samlp:StatusCode
Value="urn:oasis:names:tc:SAML:2.0:status:Success"/>
        <samlp:StatusMessage>OK</samlp:StatusMessage>
      </samlp:Status>
      <saml:Assertion>
<!-- qui va il contenuto del token di attributo -->
      </saml:Assertion>
    </samlp:Response>
  </soap:Body>
</soap:Envelope>

```

4.3.14.2.2. Struttura dell'asserzione di attributo

L'elemento **<saml:Assertion>** DEVE contenere i seguenti attributi:

- **Version:** deve essere "2.0"
- **ID:** identificativo univoco dell'asserzione creata dall'Attributo Assertions Provider. Questo identificativo DEVE essere necessariamente univoco a livello regionale. Per questo motivo si suggerisce di strutturare l'ID in questo modo:

ID = "assertion" + " _" + [OID_azienda] + " _" + [AuthnRequest/@ID]

es. un'asserzione generata dalla AULSS 1 Dolomiti a seguito della richiesta con ID "erbtgfvcsaewc":

assertion_2.16.840.1.113883.2.9.2.50501_msgId_erbtgfvcsaewc

- **IssueInstant**: istante temporale in cui è stata creata l'asserzione

L'elemento <saml:Assertion> contiene i seguenti elementi:

- **<saml:Issuer>**: elemento obbligatorio che descrive il creatore dell'Asserzione. Dovrebbe essere valorizzato con l'url dell'attore Attribute Assertions Provider che ha creato l'asserzione
- **<ds:Signature>**: Questo elemento è OBBLIGATORIO e permette di firmare l'asserzione con un XML signature autenticando l'attore Attribute Assertions Provider. Questa firma è eseguita in accordo alle specifiche definite dal namespace **ds**: "http://www.w3.org/2000/09/xmldsig#". L'elemento <ds:Signature> DEVE contenere due elementi **<ds:SignedInfo>** e **<ds:SignatureValue>**. <ds:SignatureInfo> permette di definire i parametri dell'algoritmo di firma utilizzato utilizzando i seguenti elementi obbligatori:
 - **<ds:CanonicalizationMethod>**: l'attributo **Algorithm** contiene la definizione dell'algoritmo di canonicalizzazione. Un applicativo conforme a SAML 2.0 dovrebbe utilizzare un algoritmo di canonicalizzazione esclusiva [Excl-C14N] definita dal seguente uri "http://www.w3.org/2001/10/xml-exc-c14n#".
 - **<ds:SignatureMethod>**: l'attributo **Algorithm** contiene la definizione dell'algoritmo di firma utilizzato (XML Signature con utilizzo di algoritmo RSA): "http://www.w3.org/2001/04/xmldsig-more#rsa-sha256"
 - **<ds:Reference>**: deve essere UNICO e deve contenere l'attributo **URI** che fa riferimento all'attributo Assertion/@ID contenuto nell'asserzione preceduto da "#". Questo elemento DEVE contenere i seguenti elementi:
 - **<ds:DigestMethod>**: l'attributo **Algorithm** contiene la definizione dell'algoritmo utilizzato per creare il Digest. Deve essere "<http://www.w3.org/2001/04/xmldsig-more#sha256>"
 - **<ds:DigestValue>**: questo elemento contiene il valore del Digest in formato base64

Il secondo elemento <ds:SignatureValue> veicola la firma dell'asserzione in formato base64.

- **<saml:Subject>**: questo elemento DEVE essere presente e DEVE riportare le stesse informazioni contenute le <saml:Subject> della richiesta (rappresenta dunque l'utente per cui è creata l'asserzione di identità).
- **<saml:Conditions>**: definisce le condizioni di validità dell'asserzione. Possono essere ereditate dal messaggio di Request o possono essere sovrascritte dall'attore Attribute Assertions Provider, in accordo con le policy di accesso ai servizi definite a livello regionale. L'elemento <saml:Conditions> DEVE avere valorizzati i seguenti attributi:
 - **NotBefore**: istante di inizio della validità dell'asserzione in formato UTC
 - **NotOnOrAfter**: istante di fine validità dell'asserzione in formato UTC

Questo elemento PUO' contenere un elemento <saml:AudienceRestriction> (con zero o più sotto elementi <saml:Audience> valorizzati con l'url di un servizio) per individuare il o gli attori X-Service Provider che possono accettare l'asserzione di identità.

- **<saml:AttributeStatement>**: sezione che permette di veicolare gli attributi dell'asserzione che sono associati allo user richiedente

dall'attore Attribute Assertions Provider. Queste sono le informazioni che verranno analizzate dall'attore X-Service Provider per valutare l'accessibilità o meno ai propri servizi. Questo elemento contiene una serie di elementi **<saml:Attribute>**. Alcuni elementi **<saml:Attribute>** sono ereditati dal messaggio di Request (**ApplicationID**, **PatientID**, **codReparto** , **RequestContext**, **UserClientAuthentication**) altri sono definiti direttamente dall'attore Attribute Assertions Provider (**vengono di seguito riportati degli attributi a titolo esemplificativo e non esaustivo in attesa di indicazioni dal gruppo di lavoro privacy**):

- **UserClientAuthentication:** descrive la tipologia di autenticazione eseguita dall'utente per accedere ai servizi del sistema X-Service User. Il codice da utilizzare deve essere B.1.
- **Role:** permette di definire il ruolo associato allo user autenticato attraverso l'asserzione di identità. Il codeSystem per questo attributo è definito in [Appendice A: CodeSystems](#)
- **ResponsibleParty:** permette di veicolare all'interno dell'asserzione il Codice Fiscale dell'operatore.
- **RequestContext:** descrive il contesto all'interno del quale si è resa necessaria la richiesta di servizio. Questo attributo può essere valorizzato con i codici definiti in [Appendice A: CodeSystems](#).
- **ApplicationID:** definisce l'ID dell'applicativo che esegue la richiesta di asserzione. Il formato dell'ID è: [ApplicationID]^[minor_release]^[installazione] dove "ApplicationID" è l'ID associato al prodotto software che ha superato la fase di labeling, "minor_release" rappresenta la versione successiva del software non labellata, "installazione" rappresenta un identificativo univoco per la specifica installazione del software labellato.
- **codStruttura:** questo dato permette di individuare la struttura di appartenenza dell'utente autenticato. Tale codice deve essere assegnato a partire dal sistema di codifica STS11 o altro sistema di codifica definito a livello regionale. Se non specificato in richiesta, può essere presente un'occorrenza di tale attributo per ogni Struttura associata all'utente;
- **PatientID:** rappresenta l'identificativo univoco del paziente nei confronti del quale l'utente sta agendo con il contesto dichiarato. L'opzionalità di questo attributo è dipendente dalla tipologia di servizio al quale si vuole accedere.
- **codUdO:** veicola la codifica relativa all'Unità di Offerta dal quale è effettuata la richiesta di autenticazione. Se non specificato in richiesta, può essere presente un'occorrenza di tale attributo per ogni Unità di Offerta associata all'utente;
- **codUO:** veicola la codifica relativa all'Unità Operativa dal quale è effettuata la richiesta di autenticazione. Se non specificato in richiesta, può essere presente un'occorrenza di tale attributo per ogni Unità Operativa associata all'utente;

- **codSpecialitaUO**: veicola la codifica relativa alla specialità dell'Unità Operativa dal quale è effettuata la richiesta di autenticazione
- **<saml:AuthnStatment>**: Elemento creato dall'attore Attribute Assertions Provider per veicolare all'interno dell'asserzione i dettagli del processo di autenticazione che ha portato alla creazione dell'asserzione stessa. Contiene un attributo **authnInstant**, che traccia l'istante a cui è avvenuta l'autenticazione ed un elemento **<saml:AuthnContext>** che descrive le modalità di autenticazione. Questo elemento contiene una serie di sottoelementi:
 - **<saml:AuthnContextClassRef>**: contiene l'URI che descrive le modalità di autenticazione: "urn:oasis:names:tc:SAML:2.0:ac:classes:InternetProtocolPass word"
 - **<saml:AuthenticatingAuthority>**: l'url del servizio che ha eseguito l'autenticazione.

```
<saml:Assertion Version="2.0" IssueInstant="2014-01-30T21:42:16Z"
ID="assertion_1.2.3.4.5_msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd"
xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion">
  <saml:Issuer>https://access.bit4id.org:8006</saml:Issuer>
  <ds:Signature xmlns:ds="http://www.w3.org/2000/09/xmldsig#">
    <ds:SignedInfo>
      <ds:CanonicalizationMethod
Algorithm="http://www.w3.org/2001/10/xml-exc-c14n#" />
      <ds:SignatureMethod
Algorithm="http://www.w3.org/2000/09/xmldsig#rsa-sha1" />
      <ds:Reference
URI="#assertion_1.2.3.4.5_msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd">
        <ds:Transforms>
          <ds:Transform
Algorithm="http://www.w3.org/2000/09/xmldsig#enveloped-signature" />
          <ds:Transform
Algorithm="http://www.w3.org/2001/10/xml-exc-c14n#" />
        </ds:Transforms>
        <ds:DigestMethod
Algorithm="http://www.w3.org/2000/09/xmldsig#sha1" />
        <ds:DigestValue>TX0E4NB0z0s+c3EsSgX0kQmao8Q=</ds:DigestValue>
      </ds:Reference>
    </ds:SignedInfo>
    <ds:SignatureValue>Lr+6O0yeyznBvzNu0fTf0B2cTaJ22AS0WlSnESYnfbwTF/FxH2GMcSeB/BfPnCba
g6B8DHLhcnsA0l35eiyKs+ZN36v++5bhovZR7ts8Rf1IiDjEN6uN2U9U3RSSKKEZV8NsI5UJGJaA84C7
WvrKeo709xNmFbyfmYou05bgilf0=</ds:SignatureValue>
    <ds:KeyInfo>
      <ds:X509Data>
        <ds:X509Certificate>MIICjDCCAfWgAwIBAgIP+45MfDQR45ktABDzL3omMA0GCSqGSIb3DQEBBQUAM
FoxCzAJBgNVBAYTAklUMRkwFwYDVQQKExBDTVMgT1JHQU5JWkFUSU9OMRowGAYDVQQLExFDTVMgV29ya2
```

```

luZyBHcm91cDEUMBIGA1UEAxMLQ01TIFRlc3QgQ0EwHhcNMTQwMTEzMDkyMDU0WhcNMTYxMjI4MDkyMDU
0WjBaMRowGAYDVQQDExFhY2N1c3MuYml0NGlkLm9yZzEWMBQGA1UECzMNQMl0NE1EIC0gRGVtbzEXMBUG
A1UEChMOUmVnaW9uZSBWZW5ldG8xCzAJBgNVBAYTAklUMIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBg
QCRE9jS9zJSGs3+0pV5lwdJXoqOnyT6KvLAVwBNBQTxx7VvmWtvjNHsfxzRFpSpR6578EjKmXyyYw4Y
AIhCS4YbXlZTXNxpWxxbY0o33IvpvC+l1TPl/0K7Kl7C9Z+GJdaOFAlc7RRBc4SaGLfUdOPbqmfOyHmPR
XAiq3IqtyAQIDAQABo1QwUjAJBgNVHRMEAjAAMBMGA1UdJQQMMAoGCCsGAQUFBwMBMB0GA1UdBAQWMBQw
DjAMBgorBgEEAYI3AgEWAwIHgDARBgglghkgBhvhCAQEEBAMCBBAwDQYJKoZIhvcNAQEFBQADgYEAVwNj
Krinclpmjwnga3HYzeleSKC+FJcUPHoeqcochOzvLXyg8J/a+3bBwQ19t+cPO3Jt7jdDXAHoixLJEstg6
R2wlhKtUkdNx01fFPnaje4r019/zjVHUbneJ0GCuEeQV2yu77W3wNGkbXDmtA/9ADGmRRWkiCSLjikbv
+BjI=
```

```

</ds:X509Certificate>
</ds:X509Data>
<ds:KeyValue>
  <ds:RSAKeyValue>
    <ds:Modulus>kRPY0vcyUhrN/tKVeZcHSV6Kjp8k+irywFcATQUE8UMcelVZlrb4zR7H8c0RaUqUeue/B
    Iypl8smMOGACIQkuGG15WU1zcaVsV22NKN9yL6bwvdpU6Zf9CuypewvWfhiXWjhQJX00UQXOEmhi3lHTj
    26pn6Mh5j0VwIqtyKrcgE=
```

```

    </ds:Modulus>
    <ds:Exponent>AQAB
```

```

    </ds:Exponent>
  </ds:RSAKeyValue>
</ds:KeyValue>
</ds:KeyInfo>
</ds:Signature>
<saml:Subject>
  <saml:NameID SPNameQualifier="ambulatorio di pippo"
SPProvidedID="user">ZNRMRA86L11B157N
```

```

</saml:NameID>
</saml:Subject>
<saml:Conditions NotBefore="2014-01-30T21:42:16Z"
NotOnOrAfter="2014-01-31T01:42:16Z">
  <saml:AudienceRestriction>
    <saml:Audience>http://X-ServiceProvider
```

```

</saml:Audience>
  </saml:AudienceRestriction>
</saml:Conditions>
  <saml:AuthnStatement AuthnInstant="2014-01-30T21:42:16Z">
    <saml:AuthnContext>
      <saml:AuthnContextClassRef>urn:oasis:names:tc:SAML:2.0:ac:classes:InternetProtocolPassword
```

```

</saml:AuthnContextClassRef>
<saml:AuthenticatingAuthority>https://access.bit4id.org:8006
```

```

</saml:AuthenticatingAuthority>
    </saml:AuthnContext>
  </saml:AuthnStatement>
  <saml:AttributeStatement>
    <saml:Attribute Name="UserClientAuthentication">
      <saml:AttributeValue>A.1
```

```

</saml:AttributeValue>
    </saml:Attribute>
    <saml:Attribute Name="ApplicationID">
      <saml:AttributeValue>2.16.840.1.113883.2.9.2.50.4.5.0003
```

```

</saml:AttributeValue>
    </saml:Attribute>
    <saml:Attribute Name="PatientID">
      <saml:AttributeValue>GRLMSM60R31F770Y
```

```

</saml:AttributeValue>

```

```

        </saml:Attribute>
        <saml:Attribute Name="RequestContext">
            <saml:AttributeValue>C.1.1</saml:AttributeValue>
        </saml:Attribute>
        <saml:Attribute Name="Role"
NameFormat="urn:oasis:names:tc:xacml:2.0:subject:role">
            <saml:AttributeValue>R.1.1</saml:AttributeValue>
        </saml:Attribute>
        <saml:Attribute Name="ResponsibleParty">
            <saml:AttributeValue>ZNRMRA86L11B157N</saml:AttributeValue>
        </saml:Attribute>
        <saml:Attribute Name="codStruttura">
            <saml:AttributeValue>123456</saml:AttributeValue>
        </saml:Attribute>
    </saml:AttributeStatement>
</saml:Assertion>

```

4.3.14.3. Expected Actions

In caso di errore l'X-Service User trusted può tentare di creare una nuova Request in funzione degli errori ricevuti.

Se il messaggio di Response ha veicolato correttamente un'asserzione di attributo, questo token verrà utilizzato dal X-Service User trusted per richiedere l'accesso a ulteriori servizi Regionali o extra aziendali in accordo alla transazione [ITI-40] Provide X-User Assertion descritta in sezione [Richiesta Servizi: \[ITI-40\] Provide X-User Assertion](#).

4.3.15. Security e Audit Considerations

L'evento associato alla richiesta di asserzione è un evento di rilevanza dal punto di vista della sicurezza del sistema. Per questo motivo l'evento DEVE essere tracciato attraverso messaggi di Audit Record generati dagli attori coinvolti.

Per la struttura e la valorizzazione dei messaggi di Audit relativi all'attore Identity and Assertion Provider e X-Service User si faccia riferimento all'ultima versione delle "Specifiche Tecniche - ATNA - Security Considerations".

4.4. GET Metadata WAYF

Questa sezione descrive la transazione GET Metadata WAYF utilizzata per ottenere l'elenco dei metadata federati a livello regionale, individuando scopo, semantica dei messaggi scambiati e Expected Actions degli attori coinvolti. Questa transazione viene utilizzata quando il Service Provider necessita ottenere l'elenco dei metadata federati a livello regionale.

4.4.1. Scopo

Questa transazione è utilizzata dall'attore Service Provider per richiedere al WAYF Service l'elenco dei metadata federati a livello regionale.

4.4.2. Attori e ruoli

Actor: Service Provider

Role: Richiede l'elenco dei metadata federati a livello regionale

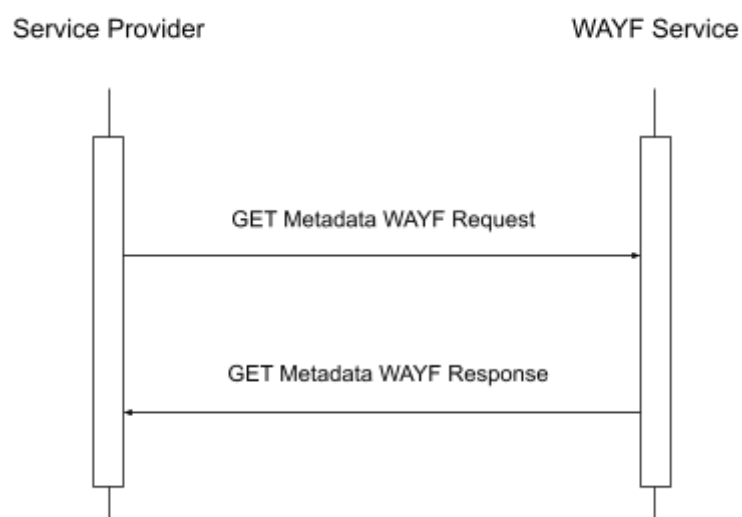
Actor: WAYF Service

Role: Invia al Service Provider l'elenco dei metadata federati a livello regionale

4.4.3. Standard di riferimento

- W3C WS-Addressing 1.0 – SOAP Binding
- OASIS WS-Security
- OASIS SAML family spec.
- IHE ITI TF-2x: Appendix V
- IHE ITI TF-2b

4.4.4. Interaction Diagram



4.4.5. Metadata WAYF Request

4.4.5.1. Trigger Events

Il messaggio di Request per la transazione GET Metadata WAYF viene generato quando il Service Provider necessita di recuperare l'elenco dei metadata federati a livello regionale dal WAYF Service.

4.4.5.2. Message Semantics

Il messaggio di Metadata WAYF request è una richiesta di tipo HTTP GET inviata dal Service Provider al WAYF Service.

La chiamata è formattata in questo modo:

GET <scheme>://<authority>/<path>/api/metadata

Dove:

- **<scheme>** deve essere di tipo http o https;
- **<authority>** deve essere rappresentato come un host (indirizzo IP o DNS) seguito opzionalmente dalla porta;
- **<path>** può essere valorizzato con il percorso attraverso cui è possibile raggiungere il servizio;
- **“api/metadata”** è una parte obbligatoria dell'URL che indica che classifica il tipo di query;

Un esempio di chiamata al servizio è riportato di seguito:

GET https://wayf-test.azero.veneto.it/api/metadata

4.4.5.3. Expected Actions

Il WAYF Service, ricevuto il messaggio GET Metadata WAYF request, deve ritornare l'elenco dei metadata federati a livello regionale.

4.4.6. Metadata WAYF Response

4.4.6.1. Trigger Events

Il messaggio di Response per la transazione GET Metadata WAYF viene generato quando il WAYF Service invia l'elenco dei metadata federati a livello regionale al Service Provider.

4.4.6.2. Message Semantics

Se la richiesta fornisce risultati, il WAYF Service deve riportare uno status code della risposta pari a 200 – OK, il ContentType associato alla risposta dovrà essere `text/xml` e

il body del messaggio conterrà l'xml con l'elenco dei metadati federati a livello regionale secondo quanto descritto nelle specifiche "Metadata for the OASIS Security Assertion Markup Language (SAML) V2.0 " o successive versioni definite da OASIS.

Dovrà essere presente l'elemento `EntitiesDescriptor`, il quale raggruppa una serie di elementi `EntityDescriptor` che descrivono i metadati dei singoli IdP.

4.4.6.3. Expected Actions

Il Service Provider deve essere in grado di recepire le informazioni contenute nel messaggio di risposta ed in caso di esito negativo effettuare una nuova transazione dopo averne analizzato gli errori e corretto il messaggio di richiesta.

4.5. GET Snippet

4.5.1. Scopo

Questa transazione è utilizzata dall'attore Service Provider verso l'attore Snippet Provider per recuperare la lista degli IdP attivi, l'endpoint dei singoli metadati, l'etichetta da mostrare all'utente per identificare l'IdP e l'icona che lo identifica.

4.5.2. Attori e ruoli

Actor: Service Provider

Role: Richieda allo Snippet Provider la lista degli IdP attivi

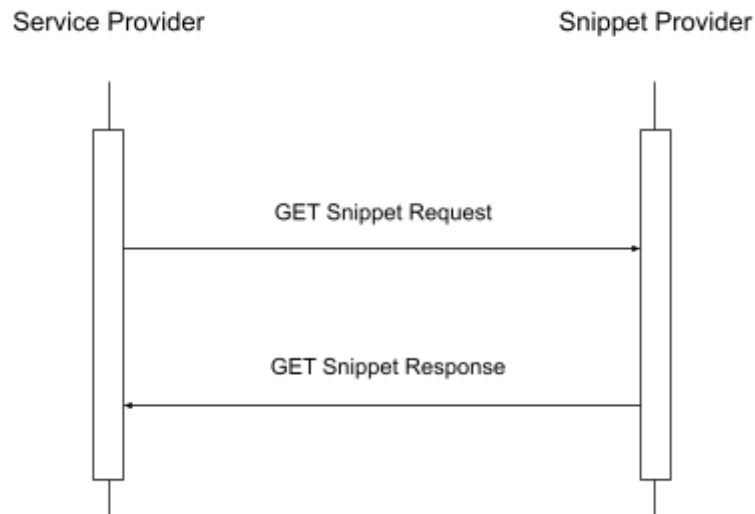
Actor: Snippet Provider

Role: Restituisce la lista degli IdP attivi al Service Provider

4.5.3. Standard di riferimento

- RFC2616: IETF Hypertext Transfer Protocol - HTTP/1.1
- RFC4627: The application/json Media Type for JavaScript Object Notation (JSON)

4.5.4. Interaction Diagram



4.5.5. Snippet Request

4.5.5.1. Trigger Events

Il messaggio di Request per la transazione GET Snippet viene generato quando il Service Provider necessita di recuperare dallo Snippet Provider la lista degli IdP attivi, l'endpoint dei singoli metadata, l'etichetta da mostrare all'utente per identificare l'IdP e l'icona che lo identifica.

4.5.5.2. Message Semantics

Il messaggio di Snippet request è una richiesta di tipo HTTP GET inviata dal Service Provider allo Snippet Provider.

La chiamata è formattata in questo modo:

GET <scheme>://<authority>/<path>/api/snippet

Dove:

- **<scheme>** deve essere di tipo http o https;
- **<authority>** deve essere rappresentato come un host (indirizzo IP o DNS) seguito opzionalmente dalla porta;
- **<path>** può essere valorizzato con il percorso attraverso cui è possibile raggiungere il servizio;
- **“api/snippet”** è una parte obbligatoria dell'URL che indica che classifica il tipo di query;

Un esempio di chiamata al servizio è riportato di seguito:

```
GET https://wayf-test.azero.veneto.it/api/snippet
```

4.5.5.3. Expected Actions

Lo Snippet Provider, ricevuto il messaggio GET Snippet request, deve ritornare la lista degli IdP attivi, l'endpoint dei singoli metadata, l'etichetta da mostrare all'utente per identificare l'IdP e l'icona che lo identifica.

4.5.6. Snippet Response

Questo messaggio veicola verso l'attore Service Provider la lista degli IdP attivi, l'endpoint dei singoli metadata, l'etichetta da mostrare all'utente per identificare l'IdP e l'icona che lo identifica.

4.5.6.1. Trigger Events

Il messaggio di Response per la transazione GET Snippet viene generato quando lo Snippet Provider invia la lista degli IdP attivi, l'endpoint dei singoli metadata, l'etichetta da mostrare all'utente per identificare l'IdP e l'icona che lo identifica al Service Provider.

4.5.6.2. Message Semantics

Se la richiesta fornisce risultati, lo Snippet Provider deve riportare uno status code della risposta pari a 200 - OK, il ContentType associato alla risposta dovrà essere application/json ed il payload dovrà contenere un elemento `providers` di tipo Array le cui entry sono così strutturate:

Campo	Cardinalità	Formato	Descrizione
logo	1..1	String	Contiene l'end-point da cui recuperare il logo
label	1..1	String	Contiene l'etichetta da mostrare all'utente
isActive	1..1	Boolean	Se valorizzato "true" indica che l'IdP deve essere mostrato all'interno della lista degli IdP disponibili. Se valorizzato "false" l'IdP non deve essere mostrato all'interno della lista degli IdP disponibili.
provider	1..1	String	Contiene l'end-point da cui è possibile recuperare i metadata del particolare IdP.

4.5.6.2.1. Esempio

```
{  
  "providers": [  
    {
```

```

    "logo": "https://wayf-test.azero.veneto.it/media/idp_images/azero_un3Vzq6.png",
    "label": "AULSS 3 Serenissima - Ex ULSS 14 Chioggia - VERIFICATO",
    "isActive": true,
    "provider": "https://webauth.asl14chioggia.veneto.it/idp/metadata"
  },
  {
    "logo": "https://wayf-test.azero.veneto.it/media/idp_images/azero_bibcGjj.png",
    "label": "AULSS 1 Dolomiti - Ex ULSS 1 Belluno - VERIFICATO",
    "isActive": true,
    "provider": "https://webauth.ulss.belluno.it/idp/metadata"
  }
]
}

```

4.5.6.3. Expected Actions

Il Service Provider deve essere in grado di recepire le informazioni contenute nel messaggio di risposta ed in caso di esito negativo effettuare una nuova transazione dopo averne analizzato gli errori e corretto il messaggio di richiesta.

Il Service Provider può' opzionalmente filtrare la lista degli IdP in base al dominio di afferenza.

4.6. Richiesta Servizi: [ITI-40] Provide X-User Assertion

Questa transazione descrive come un attore X-Service User deve utilizzare un'asserzione di attributo generata dall'attore Identity and Assertions Provider, o generata in caso del SIO, per ottenere l'erogazione di servizi applicativi da parte di un attore X-Service Provider (fornitore di servizi Regionale o extra-aziendale). Gli attori coinvolti rispettano le specifiche tecniche definite da IHE nel profilo XUA (IHE-ITI-TF-1 sezione 13), e la transazione di riferimento è la [ITI-40] Provide X-User Assertion, descritta (IHE-ITI-TF-2b sezione 3.40).

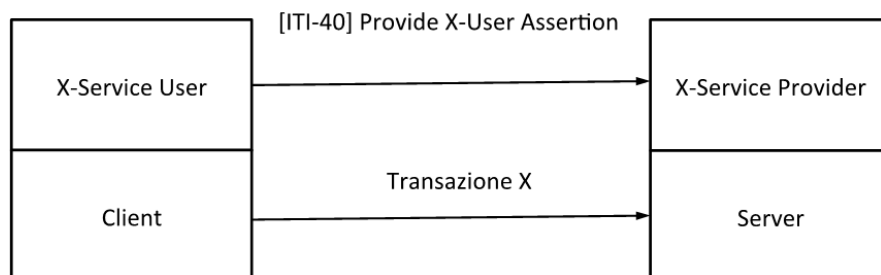


Figura 16. Raggruppamento tra attori per l'utilizzo di SAML token

Questa transazione permette di descrivere come un Client di servizi DEVE utilizzare un'asserzione di attributo di cui dispone per invocare altri servizi applicativi.

I messaggi applicativi verranno veicolati:

- se il servizio utilizza il protocollo SOAP: all'interno imbustamento SOAP. Il token deve essere veicolato all'interno dell'header di un messaggio di richiesta di servizi applicativi utilizzando l'elemento **<wss:Security>**.
- se il servizio utilizza il protocollo REST: viene definito all'interno della singola specifica la modalità di utilizzo del token. Qualora il token debba essere veicolato all'interno dell'HTTP Header Authorization del messaggio di richiesta è necessario eseguire la compressione del token tramite algoritmo Deflate e successiva codifica tramite Base64 Encode. Il token dovrà poi essere validato dall'attore X-Service Provider, previa decodifica tramite Base64 Decode e decompressione tramite Inflate.

Per garantire un periodo transitorio di adeguamento alla nuova modalità di condivisione del token è necessario che l'attore X-Service Provider che espone dei servizi che utilizzano protocollo REST garantisca una doppia modalità di validazione del token, permettendo l'accesso ai servizi sia in caso di token compresso che no.

Di seguito è presentato un esempio di Messaggio soap con Security header che veicola un'asserzione SAML 2.0 (l'esempio si riferisce al caso d'uso di invio di una ricetta dematerializzata):

```
<S:Envelope xmlns:S="http://schemas.xmlsoap.org/soap/envelope/">
  <S:Header>
    <wsse:Security
      xmlns:wsse="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-secext-1.0.xsd">
      <saml:Assertion Version="2.0" IssueInstant="2013-11-13T13:35:38Z"
        ID="assertion_1.2.3.4.5_msgId_9376254e-da05-41f5-9af3-ac56d63d8ebd"
        xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion">
        <!-- qui va l'asserzione di identità esattamente come viene restituita dal
        servizio di autenticazione SENZA modifiche di nessun tipo: tabulazioni, spazi,
        ecc... -->
        </saml:Assertion></wsse:Security>
      </S:Header>
      <S:Body>
        <pre:InvioPrescrittoRichiesta
          xsi:schemaLocation="http://invioprescrittorichiesta.xsd.dem.sanita.finanze.it
          InvioPrescrittoRichiestaRVE.xsd"
          xmlns:pre="http://invioprescrittorichiesta.xsd.dem.sanita.finanze.it"
          xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
            <pre:pinCode>ewrg2r</pre:pinCode>
            <pre:cfMedico1>BRGPLA59L22M048Q</pre:cfMedico1>
            <pre:codRegione>050</pre:codRegione>
            <pre:codASLAo>109</pre:codASLAo>
            <pre:codSpecializzazione>F</pre:codSpecializzazione>

            <pre:codiceAss>QXolacF/B/EXpRSkFQujY7AzfkZv1iEvwq2Ru6X68Xfew8DMoKip9jjQJ2NmDRlKVv
            WpmPRXXyToR3HCAqHa0x4FFSy+IGZa06M5pWAmZCQ7cMniX0RNP7r7D1sobHYiVTcZXdL0RWd1CwbIlg
            XBpI109hxiOQ8iRulZ1WvTkI=</pre:codiceAss>
            <pre:indirizzo>viale oberdan 5</pre:indirizzo>
            <pre:tipoPrescrizione>F</pre:tipoPrescrizione>
            <pre:nonEsente>1</pre:nonEsente>
            <pre:dataCompilazione>2014-02-28 00:00:00</pre:dataCompilazione>
            <pre:tipoVisita>A</pre:tipoVisita>
            <pre:dispReg>1</pre:dispReg>
            <pre:provAssistito>VE</pre:provAssistito>
          </pre:InvioPrescrittoRichiesta>
        </S:Body>
      </S:Envelope>
```

```

        <pre:aslAssistito>112</pre:aslAssistito>
        <pre:ElencoDettagliPrescrizioni>
        <ns1:DettaglioPrescrizione
xmlns:ns1="http://tipodati.xsd.dem.sanita.finanze.it">
            <ns1:codProdPrest>036635023</ns1:codProdPrest>
            <ns1:descrProdPrest>DIBASE*IM OS 6F 1ML
100000UI/M</ns1:descrProdPrest>
            <ns1:codGruppoEquival>JNB</ns1:codGruppoEquival>
            <ns1:descrGruppoEquival>COLECALCIF.6x100.000UI
-OS/PAR</ns1:descrGruppoEquival>
            <ns1:quantita>1</ns1:quantita>
        </ns1:DettaglioPrescrizione>
        <ns2:DettaglioPrescrizione
xmlns:ns2="http://tipodati.xsd.dem.sanita.finanze.it">
            <ns2:codProdPrest>027753108</ns2:codProdPrest>
            <ns2:descrProdPrest>ZOLOFT*30CPR RIV 50MG</ns2:descrProdPrest>
            <ns2:codGruppoEquival>CGA</ns2:codGruppoEquival>
            <ns2:descrGruppoEquival>SERTRALINA 30x50MG -
OS</ns2:descrGruppoEquival>
            <ns2:nonSost>1</ns2:nonSost>
            <ns2:codMotivazione>1</ns2:codMotivazione>
            <ns2:quantita>1</ns2:quantita>
        </ns2:DettaglioPrescrizione>
    </pre:ElencoDettagliPrescrizioni>
    </pre:InvioPrescrittoRichiesta>
</S:Body>
</S:Envelope>

```

Di seguito è presentato un esempio di messaggio REST con HTTP Header Authorization che veicola un'asserzione SAML 2.0 previa compressione tramite algoritmo Deflate e Base64 Encode (l'esempio si riferisce al caso d'uso di richiesta di un codice OTP per l'autenticazione a due fattori):

```

POST https://apms-api-mfa-app.azero.veneto.it/mfaapplicativo/richiesta HTTP/1.1
Accept-Encoding: gzip,deflate
Content-Type: application/json
Authorization: IHE-SAML 5VhZb6tIFv4rUfrRygVssCHqG4nVBgNmMxheWuxgs5kdfv2U41x3bs/Nq
GdG8zSKlrlOneWr75wq6tTvjZtnr2TThHWblsXTmGdF83oTfn/u6uK1dJu0eS3cPGxeW/9VJyXxdfkNf=
Content-Length: 162
Host: apms-api-mfa-app.azero.veneto.it
Connection: Keep-Alive
User-Agent: Apache-HttpClient/4.5.5 (Java/16.0.2)

{
  "idSessione": "urn:uuid:76931fac-dab2-36c2-8b87-6ae44r6a62d7",
  "applicazione": "urn:uuid:jk345bd3-2618-49f6-9a60-c49999363167",
  "idUtente": "LRTRNS56B54H123B"
}

```

4.6.1. Gestione delle condizioni di Errore (Fault)

Se la validazione del token SAML fallisce, l'attore raggruppato con l'entità X-Service Provider DEVE restituire un codice di errore come descritto nelle specifiche tecniche WS-Security section 12 "Error Handling" usando il meccanismo SOAP Fault.

Le classi di fault che possono essere generati da un attore X-Service Provider sono descritti di seguito:

- **wsse:FailedCheck:** La firma utilizzata per verificare la validità dell'asserzione non è corretta
- **wsse:SecurityTokenUnavailable:** La richiesta di servizio non veicola all'interno della porzione WS-Security un'asserzione di identità SAML 2.0
- **wsse:MessageExpired:** Intervallo di validità dell'asserzione non corretto
- **wsse:InvalidSecurityToken:** se parte del contenuto dell'asserzione non è conforme ai requisiti necessari per accedere al Servizio richiesto.
- **wsse:FailedAuthentication:** Non è possibile autenticare l'utente o l'asserzione di identità.

La struttura del messaggio di Risposta veicolante una condizione di errore deve essere conforme allo standard SOAP 1.2 (permette di individuare la classe di errore) e dallo standard WS-BaseFault 1.2 (che permette di dettagliare la condizione di errore: "Web Services Base Faults 1.2").

L'Header del messaggio di risposta veicherà le informazioni che permettono di associare la Response contenente il Fault al messaggio di Request che non è stato possibile processare.

La classe del Fault generato è descritta all'interno del body del messaggio SOAP attraverso l'utilizzo dei seguenti elementi:

- **<Code>:** veicola un codice di fault (un elemento <value>).
 - **<Value>:** valore che permette di descrivere la classe di errore (soap:Receiver, soap:Sender, soap:MustUnderstand, soap:VersionMismatch, soap: DataEncodingUnknown)
- **<Reason>:** elemento che permette di veicolare delle stringhe di testo che descrivono la condizione di errore (si propone di utilizzare per questo campo la definizione descritta precedentemente in corrispondenza dello specifico codice di errore)
 - **<Text>:** elemento specifico che permette di comunicare la stringa corrisponde ad un errore.
 - **@xml:lang:** deve assumere valore fisso "ita"
- uno specifico elemento, del tipo BaseFault, caratterizzante la specifica tipologia di errore (es. <wsse:FailedCheck>). Questo elemento contiene una serie di sotto-elementi definiti dallo standard WS-BaseFault:
 - **<wsrf-bf:Timestamp>:** istante temporale in cui si è generato l'errore
 - **<wsrf-bf:ErrorCode>:** elemento che contiene lo specifico codice di errore definito in accordo con il vocabolario degli errori definito per il progetto FSEr di Regione del Veneto (**@dialect="RVE:FSE"**). **<wsrf-bf:Description>:** una descrizione dettagliata per l'errore

Si faccia riferimento alla sezione [Error Codes, dialect RVE:FSE](#) in [Appendice A](#) di questo documento per la definizione dei codici di errore che possono essere generati e le relative description.

Di seguito è presentato un esempio di messaggio SOAP 1.2 veicolante una condizione di Fault.

```
<?xml version="1.0" encoding="UTF-8"?>
<soap:Envelope xmlns:soap="http://www.w3.org/2003/05/soap-envelope"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  <soap:Header xmlns:wsa="http://www.w3.org/2005/08/addressing" >
    <wsa:To>https://X-ServiceUser</wsa:To>
    <wsa:Action>http://docs.oasis-open.org/wsrf/fault</wsa:Action> <!-- il
messaggio SOAP di richiesta ERA una query ITI-18 -->
    <wsa:MessageID>uuid:6662eab5-2ac2-4ad4-8c87-e8c468a623af</wsa:MessageID>
    <wsa:RelateTo>uuid:1232ffb5-2qq1-8id4-78ui-efkr679566at</wsa:RelateTo>
  </soap:Header>
  <soap:Body>
    <soap:Fault
      xmlns:wsse="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-secext-1.0.xsd"
      xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
      xsi:schemaLocation="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-secext-1.0.xsd
        oasis-200401-wss-wssecurity-secext-1.0.xsd">
        <soap:Code>
          <soap:Value>soap:Sender</soap:Value>
        </soap:Code>
        <soap:Reason>
          <soap:Text xml:lang="ita">Parte del contenuto dell'asserzione non è
conforme ai requisiti necessari per accedere al Servizio richiesto</soap:Text>
        </soap:Reason>
        <soap:Detail>
          <wsse:InvalidSecurityToken
            xmlns:wsrf-bf="http://docs.oasis-open.org/wsrf/bf-2"
            xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
            xsi:schemaLocation="http://docs.oasis-open.org/wsrf/bf-2 bf-2.xsd">
              <wsrf-bf:Timestamp>2005-05-04T20:18:44.970Z</wsrf-bf:Timestamp>
              <wsrf-bf:ErrorCode
                dialect="RVE:FSE">ERR_00010</wsrf-bf:ErrorCode>
              <wsrf-bf:Description>il contesto asserito non ammette
accesso al servizio </wsrf-bf:Description>
            </wsse:InvalidSecurityToken>
          </soap:Detail>
        </soap:Fault>
      </soap:Body>
    </soap:Envelope>
```

4.7. [RVE-2] Update Password

Lo use-case di riferimento per questa transazione è rappresentato dalla necessità di un applicativo territoriale (e quindi non direttamente integrato con LDAP aziendale) di aggiornare le credenziali di accesso conservate dall'azienda.

4.7.1. Scopo

La transazione [RVE-2] Update Password permette ad un attore territoriale X-Service User di aggiornare, in modo applicativo, la password (gestita dall'azienda di riferimento) utilizzata per richiedere asserzioni di identità. Questa operazione viene effettuata a seguito di un'autenticazione dell'utente.

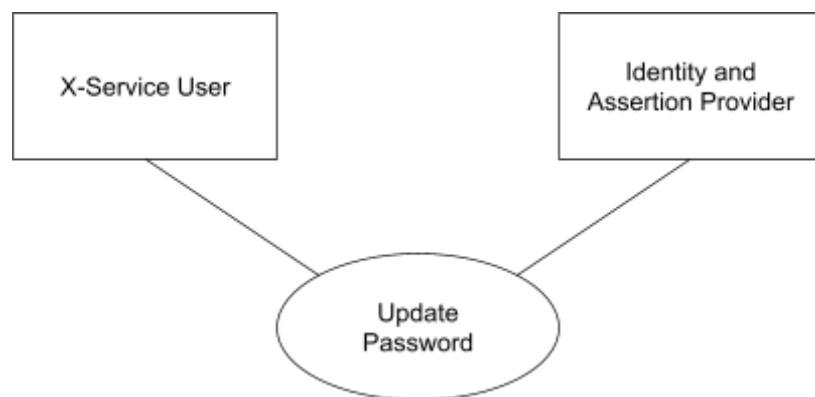
4.7.2. Attori e Ruoli

Actor: X-Service User

Role: Richiede l'aggiornamento della password gestita dall'identity provider di riferimento.

Actor: Identity and Assertion Provider

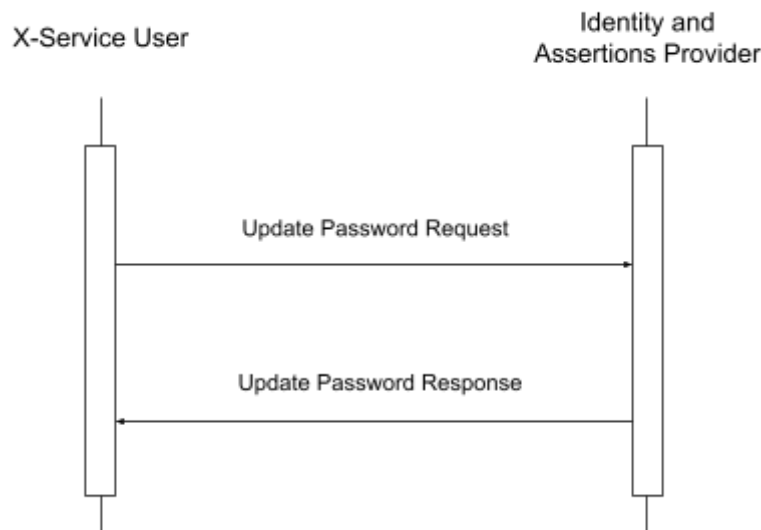
Role: Riceve una richiesta di aggiornamento di password e restituisce conferma o meno dell'avvenuta operazione.



4.7.3. Standard di riferimento

- W3C WS-Addressing 1.0 – SOAP Binding
- OASIS WS-Security
- OASIS WS-UsernameToken Profile

4.7.4. Interaction Diagram



4.7.5. PasswordUpdate Request message

Lo stesso Server (Identity And Assertion Provider) può essere invocato da tutti i client afferenti al suo dominio di autenticazione (tutti gli invocatori di servizi X-Service User). Solo attori caratterizzati da un'identità digitale nota all'attore IAP possono utilizzare questa transazione.

4.7.5.1. Trigger Events

Questo messaggio viene generato a seguito della necessità di rinnovare delle credenziali scadute o in scadenza. Quindi può essere generato a seguito della ricezione di un messaggio di errore di classe FailedAuthentication del tipo ERR_00056 "Password Scaduta", o a seguito di un meccanismo di monitoraggio della validità delle credenziali stesse (questo periodo di validità è gestito dall'azienda di riferimento ed è restituito come informazione nella Response di ogni transazione di aggiornamento password).

4.7.5.2. Message Semantic

Il messaggio creato dovrà essere un messaggio SOAP e quindi rispettare lo schema definito da <http://www.w3.org/2003/05/soap-envelope>.

Si farà riferimento per questo elemento allo standard OASIS WS-Security ed in particolare ad un'estensione del UsernamePassword Token Profile.

Il Body del messaggio SOAP veicola la richiesta di aggiornamento della password.

La struttura dell'Header DEVE essere conforme alle specifiche WS-Addressing 1.0 SOAP Binding permettendo il corretto instradamento e processamento del messaggio di richiesta.

- **<wsa:To>** = indirizzo URI del destinatario ultimo del messaggio

- **<wsa:Action>** = URI che identifica la semantica attesa nel body ("urn:rve:UpdatePasswordRequest" identifica che il messaggio veicola una richiesta di aggiornamento password)
- **<wsa:MessageID>** = identificativo univoco del messaggio

L'operazione di aggiornamento password è simile al processo di autenticazione, per questo motivo l'Header del messaggio SOAP è strutturato mediante l'utilizzo dello standard WS-Security: SOAP Message Security Version 1.1.1 (namespace di riferimento **wsse**). Accoppiando questo standard con una specifica estensione del profilo WS Security UsernameToken Profile 1.0 (namespace di riferimento associato al WS-Utility profile: **utp**) è possibile utilizzare il token Username e Password per aggiornare le credenziali dell'utente che gestisce l'attore X-Service User attraverso l'Identity and Assertions Provider. Il processo di autenticazione precedente all'aggiornamento password deve infatti essere eseguito garantendo i massimi livelli di sicurezza.

L'elemento UsernameToken, contenuto all'interno di un elemento Security DEVE contenere:

- **<wsse:Username>** = l'identificativo del responsabile conosciuto dall'Identity and Assertions Provider;
- **<wsse:Password>** = non DEVE contenere la password in clearText. Questo elemento deve essere valorizzato con il base64 (password/@type="rve:PasswordEncrypted") come definito di seguito criptando con il certificato ULSSX.cer la concatenazione della password in chiaro, nonce ed un time stamp.
- **<wsse:Nonce>** = valore random creato dall'inviante per ogni UsernameToken. Il Server deve mantenere l'elenco dei nonce utilizzati (accoppiando il nonce con il creation time wsu:Created si può limitare il dispendio di risorse del server limitando la cache ai nonce più recenti).
- **<utp:Created>** = il time stamp di creazione dello usernameToken e coincide con l'istante di creazione del messaggio di richiesta. E' strutturato secondo il formato UTC.
- **<rve-h:NewPassword>** = questo elemento (definito per estendere lo standard UsernameToken profile) deve contenere la nuova password criptata con un certificato ULSSX.cer (dove X rappresenta l'ULSS di riferimento).

Il body del messaggio contiene l'elemento vuoto **<rve:UpdatePasswordRequest>**.

Di seguito è presentato un esempio SOAP per il messaggio UpdatePassword Request:

```
<soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/"
xmlns:oas="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-sec
ext-1.0.xsd" xmlns:add="http://www.w3.org/2005/08/addressing"
xmlns:urn="urn:rve:2013:rve-body">
  <soap:Header xmlns:wsa="http://www.w3.org/2005/08/addressing">
    <wsa:Action>urn:rve:UpdatePassword</wsa:Action>

    <wsa:MessageID>urn:uuid:9376254e-da05-41f5-9af3-ac56d63d8ebd</wsa:MessageID>
    <wsa:To>http://identityAndAssertionsProvider</wsa:To>
    <wsse:Security
xmlns:wsse="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-se
cext-1.0.xsd">
```

```

        <wsse:UsernameToken
xmlns:utp="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-uti
lity-1.0.xsd">
        <wsse:Username>pippo</wsse:Username>
        <wsse:Password
Type="rve:PasswordEncrypted">YWxRQailLSGGuCuQsteUAFGVYjkbIYI16wYpVT1j0HecWqBCyMBK
3DO+5mOR5Jd9

vaoflNPuJj14V0/fEcmg7jGqJZ41cF3DfmGj2U0LCQvhZWLGyR4q9a4EIkXvFg6I
C/+AZEvh3A6JIIYKWD+vUTUWbm1DgOw2mDI+9TbIZo=</wsse:Password>
        <rve-h:NewPassword
xmlns:rve-h="urn:2013:rve:body">ghNHG91tipjAlFFeXCn4AhfjtUZT5opK8vUrcZmuypTPjY80x
YFB3OwdqL/TsxeP

7falF3lOdWF/fjc4mirtPuQLsxlretfw44BaPAQ5RW+KrGcyw+8QK3O0iz9Dd4HK

dcdTbZU9khdSDm4VREQygmZwBZGzmDDAjd404cJ/pC8==</rve-h:NewPassword>
        <wsse:Nonce>prova8</wsse:Nonce>
        <utp:Created>2014-01-30T22:20:13Z</utp:Created>
        </wsse:UsernameToken>
    </wsse:Security>
</soap:Header>
<soap:Body>
    <urn:UpdatePasswordRequest/>
</soap:Body>
</soap:Envelope>

```

4.7.5.3. Expected Actions

Se il messaggio è processato correttamente (decriptatura del campo password e verifica della corrispondenza di nonce e created) e la Password specificata è corretta (viene ottenuto in OK di autenticazione dall'LDAP aziendale) viene creato un messaggio di PasswordUpdate Response che attesta il corretto aggiornamento della password. In caso contrario il messaggio di Response veicola un fault SOAP (come descritto in sezione [Gestione delle condizioni di Errore \(Fault\)](#)).

4.7.6. PasswordUpdate Response message

4.7.6.1. Trigger Events

Questo messaggio viene generato a seguito della ricezione di un messaggio PasswordUpdate Request.

4.7.6.2. Message Semantic

Questo messaggio è strutturato secondo lo standard SOAP envelope. Il messaggio di Response DEVE contenere nell'header l'elemento action al quale è associato l'urn: **urn:rve:UpdatePasswordResponse**. Se la richiesta di aggiornamento può essere processata, Il messaggio restituisce all'attore X-Service User il periodo di validità delle

nuove credenziali aggiornate. L'header del messaggio SOAP non veicola specifiche informazioni. Il body del messaggio SOAP deve essere strutturato in accordo allo schema rve-b: "rve-body.xsd":

- **<rve-b:UpdatePasswordResponse>**: elemento strutturato che notifica l'avvenuto aggiornamento della password e il periodo di validità delle nuove credenziali;
 - **<rve-b:expirationDate>**: elemento che veicola la data di scadenza delle credenziali in formato UTC. Questa durata viene definita dalle policy aziendali.

In caso di errore il Body del messaggio SOAP veicola un fault appartenente alle seguenti classi:

- **wsse:FailedAuthentication**: se la password utilizzata non è valida o se la newPassword non rispetta i requisiti aziendali.
- **wsse:FailedCheck**: se la password utilizzata non è criptata con il certificato corretto

Di seguito è presentato un esempio di messaggio SOAP PasswordUpdate Response:

```
<soap:Envelope xmlns:soap="http://www.w3.org/2003/05/soap-envelope"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <soap:Header>
    <wsa:Action xmlns:wsa="http://www.w3.org/2005/08/addressing"/>
    <wsa:MessageID
xmlns:wsa="http://www.w3.org/2005/08/addressing">urn:uuid:ee1ae83d-89fc-11e3-9102-0010f32f794e</wsa:MessageID>
    <wsa:To
xmlns:wsa="http://www.w3.org/2005/08/addressing">http://X-ServiceUser</wsa:To>
    <wsa:RelatesTo
xmlns:wsa="http://www.w3.org/2005/08/addressing">urn:uuid:9376254e-da05-41f5-9af3-ac56d63d8ebd</wsa:RelatesTo>
  </soap:Header>
  <soap:Body>
    <rve-b:UpdatePasswordResponse xmlns:rve-b="urn:rve:2013:rve-body"
xmlns:tns="http://www.bit4id.com/xmlns/ipam/"
xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion">
      <rve-b:expirationDate>2014-03-01T22:21:57Z</rve-b:expirationDate>
    </rve-b:UpdatePasswordResponse>
  </soap:Body>
</soap:Envelope>
```

4.7.6.3. Expected Actions

Una volta ricevuto il messaggio di Response contenente l'elemento <rve-b:UpdatePasswordResponse> l'attore X-ServiceUser deve memorizzare le nuove credenziali in modo da poterle usare nel messaggio di Request della transazione Authenticate and Get Assertion [RVE-1] (vedi sezione [RVE-1.a: Authenticate and Get Assertion](#)).

Se il messaggio di Response veicola un SOAP Fault, la transazione non è andata a buon fine e deve essere ripetuta per poter accedere ai servizi del FSEr.

4.7.7. Security e Audit Considerations

La transazione Update Password è caratterizzata da un elevato livello di rischio. Per questo motivo si richiede di definire a livello aziendale un certificato (file ULSSX.cer) da utilizzare per criptare mediante algoritmo RSA il contenuto del campo NewPassword.

Si ritiene non necessario criptare la vecchia password, in quanto non può ulteriormente essere utilizzata per accedere ai servizi FSEr.

Si ritiene necessario tracciare il cambiamento di password con una copia di Audit messages generati dagli attori Identity and Assertion Provider e X-Service User.

4.7.7.1. Audit Identity and Assertions Provider

Real World Entities	Field Name	Opt.	Value Constraints
Event	EventID	M	EV (110114, DCM,"User Authentication")
	EventActionCode	M	E=Execute
	EventDateTime	M	Ora della creazione del messaggio di Response alla richiesta di aggiornamento della password
	EventOutcomeIndicator	M	<i>not specialized</i>
	EventTypeCode	M	EV("RVE-2", "Transactions", "Update Password")
Source (X-Service User) (1)			
Human Requestor (0..1)			
Destination (Identity and Assertions Provider) (1)			

Human Requestor (0..1)	UserID	M	CF del Responsabile
	AlternativeUserID	U	Not specialized
	UserName	U	Not specialized
	UserIsRequestor	M	not specialized

	RoleIDCode	M	Not specialized
	NetworkAccessPointTypeCode	NA	-
	NetworkAccessPointID	NA	-

Destination: AuditMessage/ ActiveParticipant (1)	UserID	M	Identity and Assertion Provider SOAP URI
	AlternativeUserID	U	not specialized
	UserName	U	not specialized
	UserIsRequestor	M	"false"
	RoleIDCode	M	EV (110152, DCM, "Destination")
	NetworkAccessPointTypeCode	U	"1" per il nome (DNS) "2" per l'indirizzo IP
	NetworkAccessPointID	U	Il nome del servizio (DNS) o l'indirizzo IP

4.7.7.2. Audit X-Service User

Real World Entities	Field Name	Opt.	Value Constraints
Event	EventID	M	EV (110114, DCM, "User Authentication")
	EventActionCode	M	E=Execute
	EventDateTime	M	Ora della creazione del messaggio di Response alla richiesta di aggiornamento della password
	EventOutcomeIndicator	M	<i>not specialized</i>
	EventTypeCode	M	EV("RVE-2", "Transactions", "Update Password")
Source (X-Service User) (1)			
Human Requestor (0..1)			

Destination (Identity and Assertions Provider) (1)
--

Source: AuditMessage / ActiveParticipant	UserID	M	Il valore del ApplicationID
	AlternativeUserID	M	not specialized
	<i>UserName</i>	<i>U</i>	<i>not specialized</i>
	<i>UserIsRequestor</i>	<i>M</i>	"true"
	RoleIDCode	M	EV (110153, DCM, "Source")
	NetworkAccessPointTypeCode	U	deve essere "2" identifica il fatto che è un indirizzo IP
	NetworkAccessPointID	U	Indirizzo IP del X-Service User

Human Requestor (1)	UserID	M	CF del Responsabile
	AlternativeUserID	U	Not specialized
	UserName	U	Not specialized
	UserIsRequestor	M	not specialized
	RoleIDCode	M	Not specialized
	NetworkAccessPointTypeCode	NA	
	NetworkAccessPointID	NA	

Destination: AuditMessage / ActiveParticipant (1)	UserID	M	Identity and Assertion Provider SOAP URI
	AlternativeUserID	U	not specialized
	UserName	U	not specialized

	UserIsRequestor	M	"false"
	RoleIDCode	M	EV (110152, DCM, "Destination")
	NetworkAccessPointTypeCode	U	"1" per il nome (DNS) "2" per l'indirizzo IP
	NetworkAccessPointID	U	Il nome del servizio (DNS) o l'indirizzo IP

Appendici

Appendice A: CodeSystems

A.1. CodeSystem Ruoli (attributo “Role”)

Di seguito è presentata una tabella che rappresenta i Ruoli possibili per gli operatori in grado di accedere ai servizi del Fascicolo Sanitario Elettronico regionale.

Tabella 4. CodeSystem Ruoli

Gruppo	Sottogruppo	Ruolo	Codice
SANITARI	Personale ad alta specializzazione	medico	R.1.1
		biologo	R.1.2
		farmacista	R.1.3
		chimico	R.1.4
		veterinario	R.1.5
		psicologo	R.1.6
		fisico	R.1.7
		odontoiatra	R.1.8
		direzione professioni sanitarie	R.1.9
	Personale infermieristico	infermiere	R.1.10
		infermiere pediatrico	R.1.11
		ostetrico	R.1.12
	Personale di riabilitazione	fisioterapista	R.1.13
		logopedista	R.1.14
		ortottista	R.1.15
		podologo	R.1.16
		educatore professionale	R.1.17
		terapista della neuro e psicomotricità dell'età evolutiva	R.1.18
		tecnico dell'educazione e riabilitazione psichiatrica e psico-sociale	R.1.19
		terapista occupazionale	R.1.20

	Personale tecnico-sanitario (area tecnico-assistenziale)	dietista	R.1.21
		igienista dentale	R.1.22
		tecnico audio-protista	R.1.23
		tecnico di fisiopatologia cardiocircolatoria e perfusione cardiovascolare	R.1.24
		tecnico ortopedico	R.1.25
		Operatore Socio Sanitario	R.1.34
		Odontotecnico	R.1.35
	Personale tecnico-sanitario (area tecnico-diagnostica)	tecnico audiometrista	R.1.26
		tecnico di neurofisiopatologia	R.1.27
		tecnico sanitario di laboratorio biomedico	R.1.28
		tecnico sanitario di radiologia medica	R.1.29
	Area prevenzione	tecnico della prevenzione negli ambienti e nei luoghi di lavoro	R.1.30
		assistente sanitario	R.1.31
	Personale Universitario	specializzando	R.1.32
	Personale frequentatore esterno	Personale frequentatore esterno	R.1.33
PROFESSIONALI		Professionale	R.2.1
		Direzione Ruolo Professionale	R.2.2
TECNICI		Tecnico	R.3.1
		Direzione Ruolo Tecnico	R.3.2
AMMINISTRATIVI		Amministrativo	R.4.1
		Direzione Ruolo Amministrativo	R.4.2
		Direzione Sanitaria	R.4.3
		Direzione Socio Sanitaria	R.4.4
		Direzione Generale	R.4.5
		Direzione Amministrativa	R.4.6
APPLICATIVO		Utenza Applicativa	R.5
SOCIALI	Personale socio-assistenziale	Assistente Sociale	R.6.1
CITTADINO	Cittadino		R.0

A.2. CodeSystem Contesti Clinici (attributo “RequestContext”)

Di seguito è presentata la tabella di codifica per i vari contesti clinici all'interno dei quali può essere richiesto l'accesso ai servizi del Fascicolo Sanitario Elettronico regionale da parte di un operatore.

Tabella 5. CodeSystem Contesti

Macro-attività	Contesto	Codice
Continuità di cura	Assistenza Primaria (MMG, PLS)	C.1.1
	Medicina di Gruppo (UTAP sostituzione)	C.1.2
	Continuità Assistenziale (guardia medica/turistica)	C.1.3
	Contesto di Cura	C.1.4
Attività specialistico/diagnostica	per interni	C.2.1
	per esterni	C.2.2
	per esterni in day-service	C.2.3
	in libera professione	C.2.4
Ricovero	Ricovero	C.3.1
	Ricovero in libera professione	C.3.2
Pronto Soccorso – Emergenza Sanitaria 118	Pronto Soccorso – Emergenza Sanitaria 118	C.4
Attività Erogativa Farmaceutica	Ospedaliera	C.5.1
	Territoriale	C.4.2
Attività amministrative	Prenotazioni CUP	C.6.1
	Ritiro Referti	C.6.2
	Attività Amministrative Generiche	C.6.3
	Gestione Consensi	C.6.5
Servizi	Medicina legale -fiscale	C.7.1

	Invalidi civili	C.7.2
	Assistenza Protesica	C.7.3
	Assistenza domiciliare integrata	C.7.4
	Vaccinazioni – medicina scolastica	C.7.5
	Sert/Tossicodipendenze	C.7.6
	Consultori – Adozioni	C.7.7
	Neuropsichiatria infantile	C.7.8
	Donazione organi – Dichiarazioni di volontà	C.7.9
	Igiene e sanità pubblica (SISP)	C.7.10
	Igiene alimenti e nutrizione	C.7.11
	Prevenzione igiene e sicurezza sul luogo del lavoro	C.7.12
	Salute mentale	C.7.13
	Screening	C.7.14
	Associazioni di volontariato	C.7.15
	Autorità giudiziaria	C.7.16
RSA	RSA	C.8
Reti di Patologia	Reti di Patologia	C.9
Governo/Monitoraggio	Governo/Monitoraggio	C.10
Amministratore di Sistema	Amministratore di Sistema / Supporto	C.11
Dossier cittadino AOUVR	DSE cittadino AOUVR	C.12

A.3. CodeSystem UserClientAuthentication

Di seguito è definita la tabella di codifica per le modalità di autenticazione degli utenti all'interno degli applicativi Client che si vogliono autenticarsi con un Identity and Assertion Provider aziendale oppure un Attribute Assertion Provider.

Tabella 6. Modalità di autenticazione

Tipologia Autenticazione	Codice
--------------------------	--------

User e Password (con autenticazione AD)	A.1
User e Password Trusting	A.1.1
Strong Authentication con Card	A.2
Strong Authentication con Token	A.3
User Trusted (per asserzione attributo)	B.1

A.4. CodeSystem Motivazione Accesso (attributo "MotivazioneAccesso")

Di seguito è definita la tabella di codifica per le motivazioni delle richieste di accesso ai documenti nel caso di forzatura della presa in carico.

Tabella 7. Codici Motivazione Accesso

Motivazione Accesso	ID
Consulto telefonico	1
Verifica amministrativa SDO	2
Didattica	3
Verifica Farmacia	4
Validazione appropriatezza richiesta	5
Incidente Occupazionale Aziendale	6
Indagine epidemiologica	7
Valutazione idoneità donatori di sangue ed emocomponenti	8
Completamento CEDAP	9
Controllo prescrizione antibiotici (progetto SAVE)	10
Valutazione disponibilità sierologie infettivologiche delle neo mamme	11
Altro - (necessaria descrizione testuale)	12_[Descrizione testuale motivazione]
Accesso in Emergenza al FSEr per paziente senza consensi - primo livello *	U1

Accesso in Emergenza al FSEr per paziente senza consensi - secondo livello **	U2
---	----

* Tale motivazione consente l'accesso al FSEr di un paziente che non ha rilasciato i relativi consensi in situazioni di urgenza, accedendo in prima istanza al PSS, come definito dal DM 07/09/2023

** Tale motivazione consente l'accesso al FSEr di un paziente che non ha rilasciato i relativi consensi in situazioni di urgenza, nel caso in cui i dati contenuti all'interno del PSS non fossero sufficienti alla cura del paziente stesso come definito dal DM 07/09/2023. Verranno quindi restituiti gli altri documenti presenti nel FSEr oltre al PSS

A.5. Error Codes, dialect RVE:FSE

In questa sezione sono definiti gli specifici errori generati dall'attore X-Service Provider che rifiuta l'erogazione di un servizio applicativo. Questi errori sono classificati in funzione della classe di Fault alla quale appartengono. Le classi di Fault sono definite e descritte in sezione [Gestione delle condizioni di Errore \(Fault\)](#).

A.5.1. wsse:FailedCheck

La firma utilizzata per verificare la validità dell'asserzione non è corretta.

Tabella 8. codifiche errori FailedCheck

ErrorCode	Description
ERR_00011	mismatch tra firma e chiave pubblica
ERR_00012	firma digitale strutturata in modo non corretto
ERR_00013	Password criptata utilizzando un certificato non corretto

A.5.2. wsse:SecurityTokenUnavailable

La richiesta di servizio non veicola all'interno della porzione WS-Security un'asserzione di identità SAML 2.0.

Tabella 9. codifiche errori SecurityTokenUnavailable

ErrorCode	Description
ERR_00021	Assenza del Security token
ERR_00022	Assenza del token di Asserzione

ERR_00023	il token SAML utilizzato non è well-formed e non può essere riconosciuto
...	

A.5.3. wsse:MessageExpired

Intervallo di validità dell'asserzione non corretto.

Tabella 10. codifiche errori MessageExpired

ErrorCode	Description
ERR_00031	Il valore dell'attributo NotBefore è posteriore all'istante di utilizzo dell'asserzione
ERR_00032	Il valore dell'attributo NotOnOrAfter è precedente all'istante di utilizzo dell'asserzione
ERR_00033	L'intervallo temporale dell'asserzione non è conforme alle policy regionali
...	

A.5.4. wsse:InvalidSecurityToken

Il contenuto dell'asserzione non è conforme ai requisiti necessari per accedere al Servizio richiesto.

Tabella 11. codifiche errori InvalidSecurityToken

ErrorCode	Description
ERR_00041	Il valore dell'attributo RequestContext non permette l'accesso al servizio
ERR_00042	Il valore dell'attributo Role non permette l'accesso al servizio
ERR_00043	Il valore dell'attributo ClientUserAuthentication non permette l'accesso al servizio
ERR_00044	Il valore dell'elemento AudienceRestriction non permette l'accesso al servizio
ERR_00045	Il valore dell'elemento ApplicationID non permette l'accesso al servizio

A.5.5. wsse:FailedAuthentication

Non è possibile autenticare l'utente o l'asserzione di identità.

Tabella 12. codifiche errori FailedAuthentication

ErrorCode	Description
ERR_00051	Il firmatario dell'asserzione non è un attore trustabile
ERR_00052	Il responsabile o l'utente non possono accedere al servizio
ERR_00053	L'asserzione di identità non è firmata
ERR_00054	Password Errata
ERR_00055	Data e Ora disallineate
ERR_00056	Password Scaduta
ERR_00057	Password che non rispetta le policy aziendali
ERR_00058	Parametri della richiesta di asserzione non conformi alle policy aziendali.
ERR_00059	Il Codice Fiscale del Responsabile non coincide con quello gestito dalla ULSS
ERR_00060	Ruolo non presente o non valido in LDAP
ERR_00061	La password utente deve essere cambiata
ERR_00062	Account operatore è disabilitato
ERR_00063	Utente non trovato
ERR_00064	L'attributo codOTP veicola un codice OTP scaduto o non valido

Appendice B: Schemi .XSD definiti per messaggi

Schema **rve-body.xsd** per il body dei messaggi di Request e Response del servizio aggiornamento password:

```
<?xml version="1.0" encoding="UTF-8"?>
<xs:schema xmlns:xs="http://www.w3.org/2001/XMLSchema" targetNamespace="urn:rve:2013:rve-body"
xmlns:tns="urn:rve:2013:rve-body">
  <xs:element name="UpdatePasswordRequest" fixed=""/>
    <xs:element name="UpdatePasswordResponse" type="tns:tUpdatePasswordResponse"/>
  <xs:complexType name="tUpdatePasswordResponse">
    <xs:sequence>
      <xs:element maxOccurs="1" minOccurs="1" type="xs:dateTime" name="expirationDate"/>
    </xs:sequence>
  </xs:complexType>
</xs:schema>
```

Schema **rve-header.xsd** per il body dei messaggi di Request del servizio aggiornamento password:

```
<?xml version="1.0" encoding="UTF-8"?>
<xs:schema xmlns:xs="http://www.w3.org/2001/XMLSchema" targetNamespace="rve-header.xsd">
  <xs:element name="NewPassword" type="xs:base64Binary"/>
</xs:schema>
```

Appendice C: Criteri Complessità Password

Tutti gli applicativi devono gestire le password in accordo le misure minime di sicurezza (codice Privacy, allegato B 196/03). Questa normativa impone dei criteri minimi di complessità nel caso di sistemi di autenticazione basati su username e password.

In funzione di un'analisi di fattibilità, e con l'obiettivo di garantire i requisiti di minima imposti dalla normativa, il GDL-O Sicurezza ha definito i criteri di complessità per la creazione e gestione delle password:

- Il sistema Directory Server deve memorizzare almeno tre password precedenti a quella attuale (Enforce password history: 3)
- Le password hanno validità di 90 giorni (Maximum password age : 90gg)
- Le password possono essere cambiate in qualsiasi momento (Minimum password age: 0gg)
- La password deve avere almeno lunghezza di 8 caratteri (Minimum password length: 8)
- La password deve essere complessa, ovvero non deve contenere parti dello username e deve contenere almeno tre caratteri tra numeri, minuscole, maiuscole e simboli di punteggiatura. (Passwords must meet complexity requirements)

Appendice D: Gestione Utente Applicative

Questa appendice formalizza i requisiti per la creazione di utenze applicative all'interno dei sistemi di autenticazione (LDAP) aziendali.

Nel caso in cui una ULSS/AO ritenga necessario creare un'utenza applicativa in grado di interfacciarsi con i sistemi/servizi regionali, tale utenza dovrà essere assegnata ad un utente reale che ne sarà responsabile. Tale utenza deve quindi essere profilata mediante l'utilizzo del Codice Fiscale dell'utente reale responsabile e ad essa può essere associato l'apposito ruolo R.5.

Appendice E: estensione regionale della codifica HSP12

La codifica HSP12 copre i reparti di degenza. Di seguito viene riportata la regola per l'estensione della codifica HSP12 anche ai reparti non per degenza, di seguito HSP12ext.

HSP12ext=HSP11+codDisciplina+divisione.

Dove:

- codDisciplina è il codice a 2 cifre relativo alla disciplina che ricopre il reparto
- divisione è il codice a 2 cifre che identifica univocamente il reparto. nel caso in cui non siano presenti altri reparti per la stessa disciplina dev'essere valorizzato con 00.

Ad esempio per CARDIOLOGIA 1di treviso il codice sarà un HSP12: 0505020801, per il consultorio di TREVISO il codice sarà un HSP12ext: 0505028201.

Di seguito si riporta l'OID associato a tale codifica: 2.16.840.1.113883.2.9.2.50.4.11.3.

Appendice F:

Deve essere previsto un apposito campo in LDAP/database in cui per ogni utenza vengono definiti i privilegi di accesso ad una data funzionalità applicativa per l'utente autenticato. Tale informazione viene prelevata da un apposito campo in LDAP.

Il campo **DEVE** essere strutturato come di seguito:

[codice che identifica una app]+":"+[ruolo previsto per quella app]

Ad es. "CON:ADMIN" per un ADMIN della applicazione per raccogliere i consensi.

Nel caso in cui un operatore abbia più ruoli su più applicazioni **DEVE** essere previsto in inserimento su LDAP delle coppie "APPLICAZIONE:RUOLO" separate da un elemento separatore "|".

Ad esempio, se per l'operatore sono previsti più ruoli per più applicazioni dovrà essere inserita la lista "CON:ADMIN|ACN:USER".

Se il campo in LDAP non è configurato, il dato non deve essere restituito come attributo dallo IAP aziendale.

Di seguito un esempio di valorizzazione del dato all'interno della risposta generata dallo IAP aziendale

```
<saml:Attribute Name="UserGrants"
NameFormat="urn:oasis:names:tc:SAML:2.0:attrname-format:basic">
  <saml:AttributeValue
xsi:type="xs:string">CON:ADMIN</saml:AttributeValue>
  <saml:AttributeValue
xsi:type="xs:string">ACN:USER</saml:AttributeValue>
</saml:Attribute>
```

F.1. Valori Previsti UserGrants

Di seguito è presentata una tabella che rappresenta i Ruoli possibili per gli operatori in grado di accedere ai servizi del Fascicolo Sanitario Elettronico regionale.

Tabella 13. codifiche ruoli UserGrants

Applicazione		Ruolo	
Descrizione	Valore	Descrizione	Valore
Gestione consenso	CON	Amministratore	ADMIN
		Utente	USER
Cruscotto ACN	ACN	Utente ULSS	ULSS
		Utente MMG	MMG
		Utente Azienda Zero	AZERO
		Utente Regione Veneto	RVE
		Amministratore	ADMIN
Cruscotto Delibera	DLB	Amministratore	ADMIN
		Utente	USER
Rete Oncologica Veneta	ROV	Data manager	DMNG
		Monitor	MNT
		Medico	MED
		Medico validatori	MEDV
		Infermiere somministratore	INFS
		farmacista	FRM
		farmacista validatore	FRMV
		tecnico	TNC
Sistema Informativo Ospedaliero	SIO	Amministratore	ADMIN
		Utente	USER
Radiology Information System	RIS	Amministratore	ADMIN
		Utente	USER

Bibliografia

.....

DA COMPLETARE, I RIFERIMENTI SI TROVANO ANCHE ALL'INTERNO DEL DOCUMENTO.